

Medium

Finding 1 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3853

Location

Line Number
1
File Path
.semgrepignore

Description

Result message: node_modules/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 2 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3854

Location

Line Number
2
File Path
.semgrepignore

Description

Result message: dist/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 3 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3855

Location

Line Number
3
File Path
.semgrepignore

Description

Result message: build/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 4 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3856

Location

Line Number
4
File Path
.semgrepignore

Description

Result message: *.min.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 5 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3857

Location

Line Number
5
File Path
.semgrepignore

Description

Result message: *.bundle.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

https://semgrep.dev/docs/ignoring-files-folders-code/

Images

No images found.

Finding 6 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3858

Location

Line Number
6
File Path
.semgrepignore

Description

Result message: *.min.css has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

https://semgrep.dev/docs/ignoring-files-folders-code/

Images

No images found.

Finding 7 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3859

Location

Line Number
7
File Path
.semgrepignore

Description

Result message: frontend/src/assets/private/three.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

https://semgrep.dev/docs/ignoring-files-folders-code/

Images

No images found.

Finding 8 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3860

Location

Line Number
8
File Path
..semgrepignore

Description

Result message: frontend/src/assets/private/OrbitControls.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 9 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3861

Location

Line Number
9
File Path
..semgrepignore

Description

Result message: data/static/codefixes/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 10 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3862

Location	
Line Number	
10	
File Path	
.semgrepignore	

Description

Result message: *.json has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 11 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3863

Location	
Line Number	
11	
File Path	
.semgrepignore	

Description

Result message: *.yaml has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 12 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116 3864

Location	
Line Number	
116	
File Path	
frontend/src/app/about/about.component.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 13 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3865

Location

Line Number	
73	
File Path	
frontend/src/app/administration/administration.component.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 14 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	3866

Location

Line Number	
46	
File Path	
frontend/src/app/app.guard.spec.ts	

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 15 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3867

Location

Line Number
46
File Path
frontend/src/app/app.guard.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 16 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	3868

Location

Line Number
72
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: JWT token detected

References

https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/

Images

No images found.

Low

Finding 17 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3869

Location

Line Number
72
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 18 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321 3870

Location

Line Number
78
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Medium

Finding 19 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3871

Location

Line Number
39
File Path
frontend/src/app/last-login-ip/last-login-ip.component.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 20 - Users.ps.semgrep-official.generic.secrets.security.detected-google-oauth-url

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3872

Location

Line Number
60
File Path
frontend/src/app/login/login.component.ts

Description

Result message: Google OAuth url detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Medium

Finding 21 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	3873

Location

Line Number
17
File Path
frontend/src/app/navbar/navbar.component.html

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss

Images

No images found.

Low

Finding 22 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3874

Location

Line Number
91
File Path
frontend/src/app/oauth/oauth.component.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 23 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3875

Location

Line Number
98
File Path
frontend/src/app/oauth/oauth.component.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 24 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	3876

Location

Line Number
15
File Path
frontend/src/app/purchase-basket/purchase-basket.component.html

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

<https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss>

Images

No images found.

Finding 25 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3877

Location

Line Number
48
File Path
frontend/src/app/track-result/track-result.component.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 26 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3878

Location

Line Number
76
File Path
frontend/src/app/web3-sandbox/web3-sandbox.component.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 27 - Users.ps.semgrep-official.javascript.lang.security.audit.unsafe-dynamic-method						
---	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	94	3879

Location

Line Number
242
File Path
frontend/src/app/web3-sandbox/web3-sandbox.component.ts

Description

Result message: Using non-static data to retrieve and run functions from the object is dangerous. If the data is user-controlled, it may allow executing arbitrary code.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 28 - Users.ps.semgrep-official.javascript.lang.security.audit.prototype-pollution.prototype-pollution-loop

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	915	3880

Location

Line Number
49

File Path
frontend/src/hacking-instructor/helpers/helpers.ts

Description

Result message: Possibility of prototype polluting function detected. By adding or modifying attributes of an object prototype, it is possible to create attributes that exist on every object, or replace critical attributes with malicious ones. This can be problematic if the software depends on existence or non-existence of certain attributes, or uses pre-defined attributes of object prototype (such as hasOwnProperty, toString or valueOf). Possible mitigations might be: freezing the object prototype, using an object without prototypes (via Object.create(null)), blocking modifications of attributes that resolve to object prototype, using Map instead of object.

References

https://github.com/HoLyVieR/prototype-pollution-nsec18/blob/master/paper/JavaScript_prototype_pollution_attack_in_NodeJS.pdf

Images

No images found.

Low

Finding 29 - Users.ps.semgrep-official.javascript.lang.correctness.useless-assignment

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3881

Location

Line Number
153

File Path
frontend/src/hacking-instructor/helpers/helpers.ts

Description

Result message: delay is assigned twice; the first assignment is useless

Images

No images found.

High

Finding 30 - Users.ps.semgrep-official.javascript.browser.security.insecure-document-method

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	3882

Location

Line Number
126
File Path
frontend/src/hacking-instructor/index.ts

Description

Result message: User controlled data in methods like innerHTML, outerHTML or document.write is an anti-pattern that can lead to XSS vulnerabilities

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 31 - Users.ps.semgrep-official.javascript.browser.security.insecure-innerhtml

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	3883

Location

Line Number
126
File Path
frontend/src/hacking-instructor/index.ts

Description

Result message: User controlled data in a textBox.innerHTML is an anti-pattern that can lead to XSS vulnerabilities

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 32 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3884

Location

Line Number
59
File Path
lib/codingChallenges.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 33 - Users.ps.semgrep-official.javascript.lang.security.audit.detect-non-literal-regexp

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333 3885

Location

Line Number
76
File Path
lib/codingChallenges.ts

Description

Result message: RegExp() called with a challengeKey function argument, this might allow an attacker to cause a Regular Expression Denial-of-Service (ReDoS) within your application as RegExP blocks the main thread. For this reason, it is recommended to use hardcoded regexes instead. If your regex is run on user-controlled input, consider performing input validation or use a regex checking/sanitization library such as <https://www.npmjs.com/package/recheck> to verify that the regex does not appear vulnerable to ReDoS.

References

https://owasp.org/www-community/attacks/Regular_expression_Denial_of_Service_-_ReDoS

Images

No images found.

Finding 34 - Users.ps.semgrep-official.javascript.lang.security.audit.detect-non-literal-regexp

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333 3886

Location

Line Number
78
File Path
lib/codingChallenges.ts

Description

Result message: RegExp() called with a challengeKey function argument, this might allow an attacker to cause a Regular Expression Denial-of-Service (ReDoS) within your application as RegExP blocks the main thread. For this reason, it is recommended to use hardcoded regexes instead. If your regex is run on user-controlled input, consider performing input validation or use a regex checking/sanitization library such as <https://www.npmjs.com/package/recheck> to verify that the regex does not appear vulnerable to ReDoS.

References

https://owasp.org/www-community/attacks/Regular_expression_Denial_of_Service_-_ReDoS

Images

No images found.

Low

Finding 35 - Users.ps.semgrep-official.generic.secrets.gitleaks.private-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3887

Location

Line Number
23
File Path
lib/insecurity.ts

Description

Result message: A gitleaks private-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 36 - Users.ps.semgrep-official.javascript.lang.security.audit.hardcoded-hmac-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3888

Location

Line Number
44
File Path
lib/insecurity.ts

Description

Result message: Detected a hardcoded hmac key. Avoid hardcoding secrets and consider using an alternate option such as reading the secret from a config file or using an environment variable.

References

- <https://rules.sonarsource.com/javascript/RSPEC-2068>
- https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html#key-management

Images

No images found.

Finding 37 - Users.ps.semgrep-official.javascript.jsonwebtoken.security.hardcoded-jwt-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3889

Location

Line Number
56
File Path
lib/insecurity.ts

Description

Result message: A hard-coded credential was detected. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

- https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 38 - Users.ps.semgrep-official.javascript.lang.security.audit.hardcoded-hmac-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3890

Location

Line Number
152
File Path
lib/insecurity.ts

Description

Result message: Detected a hardcoded hmac key. Avoid hardcoding secrets and consider using an alternate option such as reading the secret from a config file or using an environment variable.

References

- https://rules.sonarsource.com/javascript/RSPEC-2068
- https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html#key-management

Images

No images found.

Finding 39 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3891

Location

Line Number
84
File Path
lib/startup/customizeApplication.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

- https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 40 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3892

Location	
Line Number	
114	
File Path	
lib/startup/validateConfig.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 41 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3893

Location	
Line Number	
162	
File Path	
lib/startup/validateConfig.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 42 - Users.ps.semgrep-official.javascript.express.security.audit.express-detect-notevil-usage

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1104 3894

Location	
Line Number	
23	
File Path	
routes/b2bOrder.ts	

Description

Result message: Detected usage of the notevil package, which is unmaintained and has vulnerabilities. Using any sort of eval() functionality can be very dangerous, but if you must, the eval package is an up to date alternative. Be sure that only trusted input reaches an eval() function.

References

Images

No images found.

Finding 43 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	95	3895

Location

Line Number
22
File Path
routes/captcha.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 44 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3896

Location

Line Number
216
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 45 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3897

Location

Line Number
226
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 46 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3898

Location

Line Number
227
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 47 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3899

Location

Line Number
228
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 48 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3900

Location

Line Number
229
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 49 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3901

Location

Line Number
239
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 50 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3902

Location

Line Number
262
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

High

Finding 51 - Users.ps.semgrep-official.javascript.express.security.audit.remote-property-injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	522 3903

Location

Line Number
31
File Path
routes/currentUser.ts

Description

Result message: Bracket object notation with user input is present, this might allow an attacker to access all properties of the object and even it's prototype. Use literal values for object properties.

References

<https://github.com/nodesecurity/eslint-plugin-security/blob/3c7522ca1be800353513282867a1034c795d9eb4/docs/the-dangers-of-square-bracket-notation.md>

Images

No images found.

Medium

Finding 52 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	73 3904

Location

Line Number
33
File Path
routes/fileServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 53 - Users.ps.semgrep-official.javascript.express.security.audit.express-libxml-vm-noent

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	611	3905

Location

Line Number
83
File Path
routes/fileUpload.ts

Description

Result message: Detected use of parseXml() function with the noent field set to true. This can lead to an XML External Entities (XXE) attack if untrusted data is passed into it.

References

https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html

Images

No images found.

Finding 54 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	73	3906

Location

Line Number
14
File Path
routes/keyServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 55 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	73	3907

Location

Line Number
14
File Path
routes/logfileServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 56 - Users.ps.semgrep-official.javascript.sequelize.security.audit.sequelize-raw-query

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3908

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Avoiding SQL string concatenation: untrusted input concatenated with raw SQL query can result in SQL Injection. Data replacement or data binding should be used. See <https://sequelize.org/master/manual/raw-queries.html>

References

<https://sequelize.org/master/manual/raw-queries.html>

Images

No images found.

High

Finding 57 - Users.ps.semgrep-official.javascript.sequelize.security.audit.express-sequelize-injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3909

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Detected a sequelize statement that is tainted by user-input. This could lead to SQL injection if the variable is user-controlled and is not properly sanitized. In order to prevent SQL injection, it is recommended to use parameterized queries or prepared statements.

References

<https://sequelize.org/docs/v6/core-concepts/raw-queries/#replacements>

Images

No images found.

Finding 58 - Users.ps.semgrep-official.javascript.express.security.injection.tainted-sql-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3910

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Detected user input used to manually construct a SQL string. This is usually bad practice because manual construction could accidentally result in a SQL injection. An attacker could use a SQL injection to steal or modify contents of the database. Instead, use a parameterized query which is available by default in most database engines. Alternatively, consider using an object-relational mapper (ORM) such as Sequelize which will protect your queries.

References

https://owasp.org/www-community/attacks/SQL_Injection

Images

No images found.

Low

Finding 59 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3911

Location

Line Number
65
File Path
routes/login.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 60 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	73	3912

Location

Line Number
14
File Path
routes/quarantineServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 61 - Users.ps.semgrep-official.javascript.express.security.audit.unknown-value-in-redirect

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	601	3913

Location	
Line Number	
19	
File Path	
routes/redirect.ts	

Description

Result message: It looks like 'toUrl' is read from user input and it is used to as a redirect. Ensure 'toUrl' is not externally controlled, otherwise this is an open redirect.

References

https://owasp.org/Top10/A01_2021-Broken_Access_Control

Images

No images found.

Finding 62 - Users.ps.semgrep-official.javascript.express.security.audit.express-open-redirect

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	601	3914

Location	
Line Number	
19	
File Path	
routes/redirect.ts	

Description

Result message: The application redirects to a URL specified by user-supplied input query that is not validated. This could redirect users to malicious locations. Consider using an allow-list approach to validate URLs, or warn users they are being redirected to a third-party website.

References

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

Images

No images found.

Finding 63 - Users.ps.semgrep-official.javascript.sequelize.security.audit.sequelize-raw-query

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3915

Location	
Line Number	
23	
File Path	
routes/search.ts	

Description

Result message: Avoiding SQL string concatenation: untrusted input concatenated with raw SQL query can result in SQL Injection. Data replacement or data binding should be used. See <https://sequelize.org/master/manual/raw-queries.html>

References

<https://sequelize.org/master/manual/raw-queries.html>

Images

No images found.

High

Finding 64 - Users.ps.semgrep-official.javascript.sequelize.security.audit.express-sequelize-injection							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3916

Location	
Line Number	
23	
File Path	
routes/search.ts	

Description

Result message: Detected a sequelize statement that is tainted by user-input. This could lead to SQL injection if the variable is user-controlled and is not properly sanitized. In order to prevent SQL injection, it is recommended to use parameterized queries or prepared statements.

References

<https://sequelize.org/docs/v6/core-concepts/raw-queries/#replacements>

Images

No images found.

Finding 65 - Users.ps.semgrep-official.javascript.express.security.injection.tainted-sql-string							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89	3917

Location

Line Number
23
File Path
routes/search.ts

Description

Result message: Detected user input used to manually construct a SQL string. This is usually bad practice because manual construction could accidentally result in a SQL injection. An attacker could use a SQL injection to steal or modify contents of the database. Instead, use a parameterized query which is available by default in most database engines. Alternatively, consider using an object-relational mapper (ORM) such as Sequelize which will protect your queries.

References

https://owasp.org/www-community/attacks/SQL_Injection

Images

No images found.

Medium

Finding 66 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	95 3918

Location

Line Number
61
File Path
routes/userProfile.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 67 - Users.ps.semgrep-official.javascript.lang.security.audit.code-string-concat

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	95 3919

Location	
Line Number	
61	
File Path	
routes/userProfile.ts	

Description

Result message: Found data from an Express or Next web request flowing to eval. If this data is user-controllable this can lead to execution of arbitrary system commands in the context of your application process. Avoid eval whenever possible.

References

- https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference/Global_Objects/eval
- https://nodejs.org/api/child_process.html#child_processexeccommand-options-callback
- <https://www.stackhawk.com/blog/nodejs-command-injection-examples-and-prevention/>
- https://ckarande.gitbooks.io/owasp-nodegoat-tutorial/content/tutorial/a1_-_server_side_js_injection.html

Images

No images found.

Medium

Finding 68 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116 3920

Location	
Line Number	
213	
File Path	
routes/verify.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

- https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 69 - Users.ps.semgrep-official.javascript.lang.security.audit.unknown-value-with-script-tag

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79 3921

Location

Line Number
57
File Path
routes/videoHandler.ts

Description

Result message: Cannot determine what 'subs' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'subs' is not externally controlled, or sanitize this data.

References

- <https://www.developsec.com/2017/11/09/xss-in-a-script-tag/>
- <https://github.com/juice-shop/juice-shop/blob/1ceb8751e986dacd3214a618c37e7411be6bc11a/routes/videoHandler.ts#L68>

Images

No images found.

Finding 70 - Users.ps.semgrep-official.javascript.lang.security.audit.unknown-value-with-script-tag

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	3922

Location

Line Number
71
File Path
routes/videoHandler.ts

Description

Result message: Cannot determine what 'subs' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'subs' is not externally controlled, or sanitize this data.

References

- <https://www.developsec.com/2017/11/09/xss-in-a-script-tag/>
- <https://github.com/juice-shop/juice-shop/blob/1ceb8751e986dacd3214a618c37e7411be6bc11a/routes/videoHandler.ts#L68>

Images

No images found.

Low

Finding 71 - Users.ps.semgrep-official.javascript.lang.security.audit.unsafe-formatstring

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	134	3923

Location

Line Number
157
File Path
server.ts

Description

Result message: Detected string concatenation with a non-literal variable in a util.format / console.log function. If an attacker injects a format specifier in the string, it will forge the log message. Try to use constant values for the format string.

References

<https://cwe.mitre.org/data/definitions/134.html>

Images

No images found.

Medium

Finding 72 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	548 3924

Location

Line Number
269
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

<https://www.npmjs.com/package/serve-index>

<https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 73 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	548 3925

Location

Line Number
273
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 74 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	548	3926

Location

Line Number
277
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 75 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	548	3927

Location

Line Number
281
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

High

Finding 76 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3928

Location

Line Number
42
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

- https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 77 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3929

Location	
Line Number	
42	
File Path	
test/api/2fa.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 78 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3930

Location	
Line Number	
66	
File Path	
test/api/2fa.test.ts	

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 79 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3931

Location

Line Number
66
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 80 - Users.ps.semgrep-official.javascript.jsonwebtoken.security.hardcoded-jwt-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3932

Location

Line Number
83
File Path
test/api/2fa.test.ts

Description

Result message: A hard-coded credential was detected. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 81 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3933

Location

Line Number
85
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 82 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3934

Location

Line Number
85
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 83 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3935

Location

Line Number
104
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 84 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3936

Location

Line Number
104
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 85 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3937

Location

Line Number
144
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 86 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3938

Location

Line Number
144
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 87 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3939

Location

Line Number
176
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 88 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3940

Location

Line Number
176
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 89 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3941

Location

Line Number
202
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 90 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3942

Location

Line Number
202
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 91 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3943

Location

Line Number
219
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 92 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3944

Location

Line Number
219
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Critical

Finding 93 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret falls

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Date Mitigated	Mitigated By	CWE	Dojo ID
Critical	N.A. / N.A.	Inactive, Mitigated, False Positive	June 7, 2026	0 days	Admin User (admin)	June 7, 2026, 1:02 p.m.	Admin User (admin)	798	3945

Location

Line Number
228
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 94 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3946

Location

Line Number
228
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 95 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3947

Location

Line Number
254
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 96 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3948

Location

Line Number
254
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Critical

Finding 97 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret falls

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Date Mitigated	Mitigated By	CWE	Dojo ID
Critical	N.A. / N.A.	Inactive, Mitigated, False Positive	June 7, 2026	0 days	Admin User (admin)	June 7, 2026, 1:02 p.m.	Admin User (admin)	798	3949

Location

Line Number
281
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 98 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3950

Location

Line Number
281
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 99 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3951

Location

Line Number
308
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 100 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3952

Location

Line Number
308
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 101 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3953

Location

Line Number
16
File Path
test/api/authenticated-users.test.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 102 - Users.ps.semgrep-official.javascript.lang.correctness.no-stringify-keys

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3954

Location

Line Number
67
File Path
test/api/basket.test.ts

Description

Result message: JSON stringify does not produce a stable key ordering, and should not be relied on for producing object keys. Consider using json-stable-stringify instead.

References

- <https://www.npmjs.com/package/json-stable-stringify>
- <https://stackoverflow.com/a/16168003>

Images

No images found.

Low

Finding 103 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3955

Location

Line Number
110
File Path
test/api/basket.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 104 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3956

Location

Line Number
24
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 105 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3957

Location

Line Number
41
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 106 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3958

Location

Line Number
61
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 107 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3959

Location

Line Number
34
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 108 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3960

Location

Line Number
53
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 109 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3961

Location

Line Number
66
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 110 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3962

Location

Line Number
80
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 111 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3963

Location

Line Number
91
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 112 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3964

Location

Line Number
103
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 113 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3965

Location

Line Number
117
File Path
test/api/feedback.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 114 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3966

Location

Line Number
143
File Path
test/api/feedback.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 115 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3967

Location	
Line Number	
147	
File Path	
test/api/login.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 116 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3968

Location	
Line Number	
245	
File Path	
test/api/login.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 117 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3969

Location

Line Number
267
File Path
test/api/login.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 118 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3970

Location

Line Number
101
File Path
test/api/product-review.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 119 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3971

Location	
Line Number	
115	
File Path	
test/api/product-review.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 120 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116 3972

Location	
Line Number	
75	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 121 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116 3973

Location	
Line Number	
86	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 122 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3974

Location	
Line Number	
97	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 123 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3975

Location	
Line Number	
47	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 124 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3976

Location	
Line Number	
56	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 125 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3977

Location

Line Number
65
File Path
test/api/search.test.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 126 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3978

Location

Line Number
74
File Path
test/api/search.test.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 127 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3979

Location	
Line Number	
31	
File Path	
test/api/user-profile.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 128 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3980

Location	
Line Number	
240	
File Path	
test/api/user.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 129 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token lang-pkgs								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Date Mitigated	Mitigated By	CWE Dojo ID
High	N.A. / N.A.	Inactive, Mitigated	June 7, 2026	0 days	Admin User (admin)	June 7, 2026, 1:02 p.m.	Admin User (admin)	321 3981

Location

Line Number
280
File Path
test/api/user.test.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 130 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3982

Location

Line Number
280
File Path
test/api/user.test.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 131 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3983

Location

Line Number
289
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 132 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3984

Location

Line Number
304
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 133 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3985

Location

Line Number
318
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 134 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	95 3986

Location

Line Number
258
File Path
test/cypress/e2e/contact.spec.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 135 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321 3987

Location

Line Number
7
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 136 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3988

Location

Line Number
7
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 137 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	3989

Location

Line Number
22
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 138 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	3990

Location

Line Number
22
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 139 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	3991

Location

Line Number
62
File Path
test/cypress/e2e/restApi.spec.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 140 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3992

Location

Line Number
7
File Path
test/cypress/e2e/totpSetup.spec.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 141 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798 3993

Location

Line Number
7
File Path
test/cypress/e2e/totpSetup.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 142 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3994

Location

Line Number
8
File Path
test/files/decrypt.py

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

<https://www.python.org/dev/peps/pep-0597/>

<https://docs.python.org/3/library/functions.html#open>

Images

No images found.

Finding 143 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3995

Location	
Line Number	
14	
File Path	
test/files/decrypt_bruteforce.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- https://www.python.org/dev/peps/pep-0597/
- https://docs.python.org/3/library/functions.html#open

Images

No images found.

High

Finding 144 - Users.ps.semgrep-official.python.lang.best-practice.open-never-closed

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3996

Location	
Line Number	
1	
File Path	
test/files/encrypt.py	

Description

Result message: file object opened without corresponding close

Images

No images found.

Medium

Finding 145 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3997

Location	
Line Number	
1	
File Path	
test/files/encrypt.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- <https://www.python.org/dev/peps/pep-0597/>
- <https://docs.python.org/3/library/functions.html#open>

Images

No images found.

Finding 146 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	3998

Location	
Line Number	
10	
File Path	
test/files/encrypt.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- <https://www.python.org/dev/peps/pep-0597/>
- <https://docs.python.org/3/library/functions.html#open>

Images

No images found.

High

Finding 147 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321 3999

Location

Line Number
33
File Path
test/server/currentUserSpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 148 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4000

Location

Line Number
33
File Path
test/server/currentUserSpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 149 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	4001

Location

Line Number
36
File Path
test/server/currentUserSpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 150 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4002

Location

Line Number
36
File Path
test/server/currentUserSpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 151 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	4003

Location

Line Number
220
File Path
test/server/verifySpec.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 152 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	116	4004

Location

Line Number
243
File Path
test/server/verifySpec.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 153 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	4005

Location

Line Number
263
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 154 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4006

Location

Line Number
263
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 155 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	4007

Location

Line Number
275
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 156 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4008

Location

Line Number
275
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 157 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	4009

Location

Line Number
297
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 158 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4010

Location

Line Number
297
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 159 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	321	4011

Location

Line Number
309
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 160 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	798	4012

Location

Line Number
309
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 161 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	4013

Location

Line Number
38
File Path
views/dataErasureForm.hbs

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss

Images

No images found.

Finding 162 - Users.ps.semgrep-official.javascript.express.security.audit.xss.pug.template-explicit-unescape

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79 4014

Location

Line Number
75
File Path
views/promotionVideo.pug

Description

Result message: Detected an explicit unescape in a Pug template, using either '!= ' or '!{...}'. If external data can reach these locations, your application is exposed to a cross-site scripting (XSS) vulnerability. If you must do this, ensure no external data can reach this location.

References

https://pugjs.org/language/code.html#unescaped-buffered-code

https://pugjs.org/language/attributes.html#unescaped-attributes

Images

No images found.

High

Finding 163 - SQL Injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	89 4015

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'SQL Injection' on 'http://localhost:3000/rest/products/search'	Active	June 7, 2026	June 7, 2026

Description

SQL injection may be possible.

Mitigation

Do not trust client side input, even if there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param: q
Attack: '('
EndpointQuery: q=%27%28

Response 1

HTTP/1.1 500 Internal Server Error

References

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Images

No images found.

Medium

Finding 164 - Backup File Disclosure

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	530 4016

Vulnerable Endpoints / Systems (31)

Endpoint	Status	Date Discovered	Last Modified
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.bac'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.backup'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.bak'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.jar'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.log'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.old'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.swp'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.tar'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.zip'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.~bk'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine~'	Active	June 7, 2026	June 7, 2026

Description

A backup of the file was disclosed by the web server.

Mitigation

Do not edit files in-situ on the web server, and ensure that un-necessary

files (including hidden files) are removed from the web server.

Sample Request(s): Displaying 3 of 31

Request 1

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_amd_64.url
EndpointQuery:
EndpointFragment:

References

https://cwe.mitre.org/data/definitions/530.html

https://owasp.org/www-project-web-security-testing-

guide/v41/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/04-Review_Old_Backup_and_Unreferenced_Files_for_Sensitive_Information.html

Images

No images found.

Finding 165 - Content Security Policy (CSP) Header Not Set

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	693	4017

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/ftp/eastere.gg'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Content Security Policy (CSP) is an added layer of security that helps to

detect and mitigate certain types of attacks, including Cross Site Scripting

(XSS) and data injection attacks. These attacks are used for everything from

data theft to site defacement or distribution of malware. CSP provides a set

of standard HTTP headers that allow website owners to declare approved sources

of content that browsers should be allowed to load on that page — covered

types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects

such as Java applets, ActiveX, audio and video files.

Mitigation

Ensure that your web server, application server, load balancer, etc. is

configured to set the Content-Security-Policy header.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://www.w3.org/TR/CSP/>

<https://w3c.github.io/webappsec-csp/>

<https://web.dev/articles/csp>

<https://caniuse.com/#feat=contentsecuritypolicy>

<https://content-security-policy.com/>

Images

No images found.

Finding 166 - Cross-Domain Misconfiguration						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	264 4018

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Domain Misconfiguration' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/chunk-524KQQJQ.js'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/chunk-UNFVUBM2.js'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/robots.txt'	Active	June 7, 2026	June 7, 2026

Description

Web browser data loading may be possible, due to a Cross Origin Resource

Sharing (CORS) misconfiguration on the web server.

Mitigation

Ensure that sensitive data is not available in an unauthenticated manner

(using IP address white-listing, for instance).

Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive

set of domains, or remove all CORS headers entirely, to allow the web browser

to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

Access-Control-Allow-Origin: *

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

Access-Control-Allow-Origin: *

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

Access-Control-Allow-Origin: *

References

<https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy>

Images

No images found.

Finding 167 - HTTP Only Site

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	311 4019

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Only Site' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The site is only served under HTTP and not HTTPS.

Mitigation

Configure your web or application server to use SSL (https).

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwuLa
EndpointFragment:

References

https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html

https://letsencrypt.org/

Images

No images found.

Finding 168 - Missing Anti-Clickjacking Header

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1021 4020

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Missing Anti-Clickjacking Header' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Mitigation

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Sample Request(s): Displaying 3 of 3

Request 1

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 2

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlac&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 3

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlhE&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

References

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>

Images

No images found.

Finding 169 - Session ID in URL Rewrite						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	598 4021
Vulnerable Endpoints / Systems (1)						
Endpoint			Status	Date Discovered	Last Modified	
'Session ID in URL Rewrite' on 'http://localhost:3000/socket.io/'			Active	June 7, 2026	June 7, 2026	

Description

URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.

Mitigation

For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: sid

Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRv&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 1

nnvG-jZnYstsM_FAAAAO

Request 2

Method: GET
Param: sid
Attack:
EndpointQuery: EIO=4&transport=websocket&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 2

nnvG-jZnYstsM_FAAAAO

Request 3

Method: POST
Param: sid
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 3

nnvG-jZnYstsM_FAAAAO

References

<https://seclists.org/webappsec/2002/q4/111>

Images

No images found.

Low

Finding 170 - Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	693 4022

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

Mitigation

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents.

If possible, ensure that the end user uses a standards-compliant and modern

web browser that supports the Cross-Origin-Embedder-Policy header

(https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

References

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross->

[Origin-Embedder-Policy](#)

Images

No images found.

Finding 171 - Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	693 4023

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

Mitigation

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents.

'same-origin-allow-popups' is considered as less secured and should be avoided.

If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

Images

No images found.

Finding 172 - Dangerous JS Functions

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	749 4024

Vulnerable Endpoints / Systems (2)

Endpoint	Status	Date Discovered	Last Modified
'Dangerous JS Functions' on 'http://localhost:3000/chunk-GJJPXCX3.js'	Active	June 7, 2026	June 7, 2026
'Dangerous JS Functions' on 'http://localhost:3000/main.js'	Active	June 7, 2026	June 7, 2026

Description

A dangerous JS function seems to be in use that would leave the site vulnerable.

Mitigation

See the references for security advice on the use of these functions.

Sample Request(s): Displaying 2 of 2

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

bypassSecurityTrustHtml(

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

bypassSecurityTrustHtml(

References

<https://v17.angular.io/guide/security>

Images

No images found.

Finding 173 - Deprecated Feature Policy Header Set

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	16	4025

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Deprecated Feature Policy Header Set' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-GNBEOV4E.js'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-PX7UKXVL.js'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-SI2GTEZM.js'	Active	June 7, 2026	June 7, 2026

Description

The header has now been renamed to Permissions-Policy.

Mitigation

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

Feature-Policy

Request 2

Method: GET
Param:
Attack:
EndpointQuery:

EndpointFragment:

Response 2

Feature-Policy

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

Feature-Policy

References

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy>

<https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/>

Images

No images found.

Finding 174 - Private IP Disclosure

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	497 4026

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Private IP Disclosure' on 'http://localhost:3000/rest/admin/application-configuration'	Active	June 7, 2026	June 7, 2026

Description

A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.

Mitigation

Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

192.168.99.100:3000

References

Images

No images found.

Finding 175 - Timestamp Disclosure - Unix

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	497 4027

Vulnerable Endpoints / Systems (2)

Endpoint	Status	Date Discovered	Last Modified
'Timestamp Disclosure - Unix' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Timestamp Disclosure - Unix' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

A timestamp was disclosed by the application/web server. - Unix

Mitigation

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

1666666667

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

1839622642

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

1666666667

References

https://cwe.mitre.org/data/definitions/200.html

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	693 4028

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'X-Content-Type-Options Header Missing' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'.

This allows older versions of Internet Explorer and Chrome to perform MIME-

sniffing on the response body, potentially causing the response body to be

interpreted and displayed as a content type other than the declared content

type. Current (early 2014) and legacy versions of Firefox will use the

declared content type (if one is set), rather than performing MIME-sniffing.

Mitigation

Ensure that the application/web server sets the Content-Type header

appropriately, and that it sets the X-Content-Type-Options header to 'nosniff'

for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern

web browser that does not perform MIME-sniffing at all, or that can be

directed by the web application/web server to not perform MIME-sniffing.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRv&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 2

Method: GET
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIFv
EndpointFragment:

Request 3

Method: POST
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

References

https://learn.microsoft.com/en-us/previous-versions/windows/internet-

explorer/ie-developer/compatibility/gg622941(v=vs.85)

https://owasp.org/www-community/Security-Headers

Images

No images found.

Info

Finding 177 - Cookie Slack Detector

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	205 4029

Vulnerable Endpoints / Systems (5)

Endpoint	Status	Date Discovered	Last Modified
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/hackingInstructor.png'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/apple_juice.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/apple_pressings.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/artwork2.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

Repeated GET requests: drop a different cookie each time, followed by normal request with all cookies to stabilize session, compare responses against original baseline GET. This can reveal areas where cookie based authentication/attributes are not actually enforced.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

<https://cwe.mitre.org/data/definitions/205.html>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4030

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Modern Web Application' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/juice-shop/node_modules/express/lib/router/styles.css'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

Mitigation

This is an informational alert and so no changes are required.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

```
<script>
  window.addEventListener('load', function(){
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)', 'text': 'var(--theme-text)' },
        'button': { 'background': 'var(--theme-accent)', 'text': 'var(--theme-text)' }
      },
      'theme': 'classic',
      'position': 'bottom-right',
      'content': { 'message': 'This website uses fruit cookies to ensure you get the juiciest tracking experience.',
'dismiss': 'Me want it!', 'link': 'But me wait!', 'href': 'https://www.youtube.com/watch?v=9PnbKL3wuH4' }
    });
  });
</script>
```

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

```
<script>
  window.addEventListener('load', function(){
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)', 'text': 'var(--theme-text)' },
        'button': { 'background': 'var(--theme-accent)', 'text': 'var(--theme-text)' }
      },
      'theme': 'classic',
      'position': 'bottom-right',
      'content': { 'message': 'This website uses fruit cookies to ensure you get the juiciest tracking experience.',
'dismiss': 'Me want it!', 'link': 'But me wait!', 'href': 'https://www.youtube.com/watch?v=9PnbKL3wuH4' }
    });
  });
</script>
```

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

```
<script>
  window.addEventListener("load",, function(){
    window.cookieconsent.initialise({
      "palette": {
        "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
        "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
      },
      "theme": "classic",
      "position": "bottom-right",
      "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.",
        "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" }
    }));
  </script>
```

References

Images

No images found.

Finding 179 - Session Management Response Identified						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4031
Vulnerable Endpoints / Systems (1)						
			Endpoint	Status	Date Discovered	Last Modified
			'Session Management Response Identified' on 'http://localhost:3000/rest/continue-code'	Active	June 7, 2026	June 7, 2026

Description

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Mitigation

This is an informational alert rather than a vulnerability and so there is nothing to fix.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param: continueCode
Attack:
EndpointQuery:
EndpointFragment:

Response 1

continueCode

References

https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Images

No images found.

Finding 180 - Storable and Cacheable Content

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	524 4032

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Storable and Cacheable Content' on 'http://localhost:3000/robots.txt'	Active	June 7, 2026	June 7, 2026

Description

The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Mitigation

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

https://datatracker.ietf.org/doc/html/rfc7234

https://datatracker.ietf.org/doc/html/rfc7231

https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

Images

No images found.

Finding 181 - Storable but Non-Cacheable Content

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	524 4033

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Storable but Non-Cacheable Content' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/assets/public/favicon_js.ico'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/chunk-GNBEOV4E.js'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/chunk-SI2GTEZM.js'	Active	June 7, 2026	June 7, 2026

Description

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

max-age=0

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

max-age=0

Request 3

Method: GET

Param:

Attack:

EndpointQuery:

EndpointFragment:

Response 3

max-age=0

References

- <https://datatracker.ietf.org/doc/html/rfc7234>
- <https://datatracker.ietf.org/doc/html/rfc7231>
- <https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html>

Images

No images found.

Finding 182 - User Agent Fuzzer

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4034

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'User Agent Fuzzer' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET

Param: Header User-Agent

Attack: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

EndpointQuery: EIO=4&transport=polling&t=PwSwuYN&sid=lgwqBbriKyjtpqgVAAAn

EndpointFragment:

Request 2

Method: GET

Param: Header User-Agent

Attack: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)

EndpointQuery: EIO=4&transport=websocket&sid=lgwqBbriKyjtpqgVAAAn

EndpointFragment:

Request 3

Method: GET

Param: Header User-Agent

Attack: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

EndpointQuery: EIO=4&transport=websocket&sid=lgwqBbriKyjtpqgVAAAn

EndpointFragment:

References

Images

No images found.

Medium

Finding 183 - CVE-2026-4046 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	617	['CVE-2026-4046']	4035

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

glibc: glibc: Denial of Service via iconv() function with specific character sets

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

The iconv() function in the GNU C Library versions 2.43 and earlier may crash due to an assertion failure when converting inputs from the IBM1390 or IBM1399 character sets, which may be used to remotely crash an application.

This vulnerability can be trivially mitigated by removing the IBM1390 and IBM1399 character sets from systems that do not need them.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2026:20587

https://access.redhat.com/security/cve/CVE-2026-4046

https://bugzilla.redhat.com/2453117

https://bugzilla.redhat.com/show_bug.cgi?id=2449777

https://bugzilla.redhat.com/show_bug.cgi?id=2449783

https://bugzilla.redhat.com/show_bug.cgi?id=2453117

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438

https://errata.almalinux.org/8/ALSA-2026-20587.html

https://errata.rockylinux.org/RLSA-2026:20597

https://inbox.sourceware.org/libc-announce/76814edf-cf7f-47ec-979d-2dce0a2c76bf@gotpl.org/T/#u

https://linux.oracle.com/cve/CVE-2026-4046.html

https://linux.oracle.com/errata/ELSA-2026-50291.html

https://nvd.nist.gov/vuln/detail/CVE-2026-4046

https://packages.fedoraproject.org/pkgs/glibc/glibc-gconv-extra/

https://sourceware.org/bugzilla/show_bug.cgi?id=33980

https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007

https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007;hb=HEAD

https://www.cve.org/CVERecord?id=CVE-2026-4046

Images

No images found.

Finding 184 - CVE-2026-4437 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	125	['CVE-2026-4437']	4036

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

glibc: glibc: Incorrect DNS response parsing via crafted DNS server response

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C Library version 2.34 to version 2.43 could, with a crafted response from the configured DNS server, result in a violation of the DNS specification that causes the application to treat a non-answer section of the DNS response as a valid answer.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

- https://access.redhat.com/errata/RHSA-2026:19061
- https://access.redhat.com/security/cve/CVE-2026-4437
- https://bugzilla.redhat.com/2449777
- https://bugzilla.redhat.com/2449783
- https://bugzilla.redhat.com/show_bug.cgi?id=2449777
- https://bugzilla.redhat.com/show_bug.cgi?id=2449783
- https://bugzilla.redhat.com/show_bug.cgi?id=2453117
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438
- https://errata.almalinux.org/10/ALSA-2026-19061.html
- https://errata.rockylinux.org/RLSA-2026:20597
- https://nvd.nist.gov/vuln/detail/CVE-2026-4437
- https://sourceware.org/bugzilla/show_bug.cgi?id=34014
- https://www.cve.org/CVERecord?id=CVE-2026-4437
- https://www.openwall.com/lists/oss-security/2026/03/23/2

Images

No images found.

Finding 185 - CVE-2026-5435 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-5435']	4037

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:H

Description

glibc: glibc: Out-of-bounds write via TSIG record processing

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to enforce the caller-supplied buffer length, and can result in an out-of-bounds write when printing TSIG records.

Impact

affected

References

- https://access.redhat.com/security/cve/CVE-2026-5435
- https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/
- https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u
- https://nvd.nist.gov/vuln/detail/CVE-2026-5435
- https://sourceware.org/bugzilla/show_bug.cgi?id=34033
- https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0011
- https://www.cve.org/CVERecord?id=CVE-2026-5435

Images

No images found.

Finding 186 - CVE-2026-5450 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	122	['CVE-2026-5450']	4038

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:H

Description

glibc: glibc: Heap Buffer Overflow in scanf with %mc format specifier and large width

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

Calling the scanf family of functions with a %mc (malloc'd character match) in the GNU C Library version 2.7 to version 2.43 with a format width specifier with an explicit width greater than 1024 could result in a one byte heap buffer overflow.

Impact

affected

References

- https://access.redhat.com/security/cve/CVE-2026-5450
- https://inbox.sourceware.org/libc-announce/b11f0003-6ec1-4bd6-b9de-9e38a4efeca3@redhat.com/T/#u
- https://nvd.nist.gov/vuln/detail/CVE-2026-5450
- https://nvd.nist.gov/vuln/detail/CVE-2026-5450#range-21286997

https://sourceware.org/bugzilla/show_bug.cgi?id=CVE-2026-5450

https://www.cve.org/CVERecord?id=CVE-2026-5450

Images

No images found.

Finding 187 - CVE-2026-5928 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	127	['CVE-2026-5928']	4039

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:N/A:H

Description

glibc: glibc: Information disclosure or denial of service via ungetwc function with specific wide character encodings

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

Calling the ungetwc function on a FILE stream with wide characters encoded in a character set that has overlaps between its single byte and multi-byte character encodings, in the GNU C Library version 2.43 or earlier, may result in an attempt to read bytes before an allocated buffer, potentially resulting in unintentional disclosure of neighboring data in the heap, or a program crash.

A bug in the wide character pushback implementation (_IO_wdefault_pbackfail in libio/wgenops.c) causes ungetwc() to operate on the regular character buffer (fp->_IO_read_ptr) instead of the actual wide-stream read pointer (fp->_wide_data->_IO_read_ptr). The program crash may happen in cases where fp->_IO_read_ptr is not initialized and hence points to NULL. The buffer under-read requires a special situation where the input character encoding is such that there are overlaps between single byte representations and multibyte representations in that encoding, resulting in spurious matches. The spurious match case is not possible in the standard Unicode character sets.

Impact

affected

References

https://access.redhat.com/security/cve/CVE-2026-5928

https://nvd.nist.gov/vuln/detail/CVE-2026-5928

https://sourceware.org/bugzilla/show_bug.cgi?id=33998

https://www.cve.org/CVERecord?id=CVE-2026-5928

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	126	['CVE-2026-6238']	4040

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:H

Description

glibc: glibc: Application crash or uninitialized memory read via crafted DNS response

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to validate the RDATA content against the RDATA length in a DNS response when processing LOC, CERT, TKEY or TSIG records, which may allow an attacker to craft a DNS response, causing a target application to crash or read uninitialized memory.

These functions are for application debugging only and hence not in the path of code executed by the DNS resolver. Further, they have been deprecated since version 2.34 and should not be used by any new applications. Applications should consider porting away from these interfaces since they may be removed in future versions.

Impact

affected

References

- https://access.redhat.com/security/cve/CVE-2026-6238
- https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/
- https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u
- https://nvd.nist.gov/vuln/detail/CVE-2026-6238
- https://sourceware.org/bugzilla/show_bug.cgi?id=34069
- https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0012
- https://www.cve.org/CVERecord?id=CVE-2026-6238

Images

No images found.

Low

Finding 189 - CVE-2010-4756 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	399	['CVE-2010-4756']	4041

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

Description

glibc: glob implementation can cause excessive CPU and memory consumption due to crafted glob expressions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The glob implementation in the GNU C Library (aka glibc or libc6) allows remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in STAT commands to an FTP daemon, a different vulnerability than CVE-2010-2632.

Impact

affected

References

- http://cxib.net/stuff/glob-0day.c
- http://securityreason.com/achievement_securityalert/89
- http://securityreason.com/exploitalert/9223
- https://access.redhat.com/security/cve/CVE-2010-4756
- https://bugzilla.redhat.com/show_bug.cgi?id=681681
- https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2010-4756
- https://nvd.nist.gov/vuln/detail/CVE-2010-4756
- https://security.netapp.com/advisory/ntap-20241108-0002/
- https://www.cve.org/CVERecord?id=CVE-2010-4756

Images

No images found.

Finding 190 - CVE-2018-20796 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2018-20796']	4042

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

glibc: uncontrolled recursion in function check_dst_limits_calc_pos_1 in posix/regexec.c

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by `'(\227l)(\1\1t\1\\2537)+'` in grep.

Impact

affected

References

- <http://www.securityfocus.com/bid/107160>
- <https://access.redhat.com/security/cve/CVE-2018-20796>
- <https://debbugs.gnu.org/cgi/bugreport.cgi?bug=34141>
- <https://lists.gnu.org/archive/html/bug-gnulib/2019-01/msg00108.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2018-20796>
- <https://security.netapp.com/advisory/ntap-20190315-0002/>
- https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS
- <https://www.cve.org/CVERecord?id=CVE-2018-20796>

Images

No images found.

Finding 191 - CVE-2019-1010022 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (9.8)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	119	['CVE-2019-1010022']	4043

Location	
Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

glibc: stack guard protection bypass

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat."

Impact

affected

References

- <https://access.redhat.com/security/cve/CVE-2019-1010022>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010022>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010022>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22850
- https://sourceware.org/bugzilla/show_bug.cgi?id=22850#c3
- <https://ubuntu.com/security/CVE-2019-1010022>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010022>

Images

No images found.

Finding 192 - CVE-2019-1010023 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Low (8.8)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['CVE-2019-1010023']	4044

Location	
Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

glibc: running ldd on malicious ELF leads to code execution because of wrong size computation

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Re-mapping current loaded library with malicious ELF file. The impact is: In worst case attacker may evaluate privileges. The component is: libld. The attack vector is: Attacker sends 2 ELF files to victim and asks to run ldd on it. ldd execute code. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Impact

affected

References

- <http://www.securityfocus.com/bid/109167>
- <https://access.redhat.com/security/cve/CVE-2019-1010023>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010023>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010023>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22851
- https://support.f5.com/csp/article/K11932200?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010023>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010023>

Images

No images found.

Finding 193 - CVE-2019-1010024 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	200	[CVE-2019-1010024]	4045

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

glibc: ASLR bypass using cache of thread stack and heap

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass ASLR using cache of thread stack and heap. The component is: glibc. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Impact

affected

References

- <http://www.securityfocus.com/bid/109162>
- <https://access.redhat.com/security/cve/CVE-2019-1010024>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010024>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010024>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22852
- <https://support.f5.com/csp/article/K06046097>
- https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010024>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010024>

Images

No images found.

Finding 194 - CVE-2019-1010025 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	330	['CVE-2019-1010025']	4046

Location

Component	Version
libc6	2.41-12+deb13u2

File Path
bkimminich/juice-shop (debian 13.4)

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

glibc: information disclosure of heap addresses of pthread_created thread

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may guess the heap addresses of pthread_created thread. The component is: glibc. NOTE: the vendor's position is "ASLR bypass itself is not a vulnerability."

Impact

affected

References

- <https://access.redhat.com/security/cve/CVE-2019-1010025>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010025>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010025>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22853

https://support.f5.com/csp/article/K06046097

https://support.f5.com/csp/article/K06046097?utm_source=f5support&%3Butm_medium=RSS

https://ubuntu.com/security/CVE-2019-1010025

https://www.cve.org/CVERecord?id=CVE-2019-1010025

Images

No images found.

Finding 195 - CVE-2019-9192 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2019-9192']	4047

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

glibc: uncontrolled recursion in function check_dst_limits_calc_pos_1 in posix/regexec.c

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '()
(\1\1)*' in grep, a different issue than CVE-2018-20796. NOTE: the software maintainer disputes that this is a vulnerability because the behavior occurs only with a crafted pattern

Impact

affected

References

https://access.redhat.com/security/cve/CVE-2019-9192

https://nvd.nist.gov/vuln/detail/CVE-2019-9192

https://sourceware.org/bugzilla/show_bug.cgi?id=24269

https://support.f5.com/csp/article/K26346590?utm_source=f5support&%3Butm_medium=RSS

https://www.cve.org/CVERecord?id=CVE-2019-9192

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (4.0)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-4438']	4048

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

glibc: glibc: Invalid DNS hostname returned via gethostbyaddr functions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C library version 2.34 to version 2.43 could result in an invalid DNS hostname being returned to the caller in violation of the DNS specification.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026:19061>

<https://access.redhat.com/security/cve/CVE-2026-4438>

<https://bugzilla.redhat.com/2449777>

<https://bugzilla.redhat.com/2449783>

https://bugzilla.redhat.com/show_bug.cgi?id=2449777

https://bugzilla.redhat.com/show_bug.cgi?id=2449783

https://bugzilla.redhat.com/show_bug.cgi?id=2453117

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438>

<https://errata.almalinux.org/10/ALSA-2026-19061.html>

<https://errata.rockylinux.org/RLSA-2026:20597>

<https://nvd.nist.gov/vuln/detail/CVE-2026-4438>

https://sourceware.org/bugzilla/show_bug.cgi?id=34015

Images

No images found.

Medium

Finding 197 - CVE-2026-27171 Zlib1g 1:1.3.dfsg+really1.3.1-1+b1 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1284	['CVE-2026-27171']	4049

Location

Component	Version
zlib1g	1:1.3.dfsg+really1.3.1-1+b1
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

zlib: zlib: Denial of Service via infinite loop in CRC32 combine functions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

zlib before 1.3.2 allows CPU consumption via crc32_combine64 and crc32_combine_gen64 because x2nmodp can do right shifts within a loop that has no termination condition.

Impact

affected

References

https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit

https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit/

https://7asecurity.com/reports/pentest-report-zlib-RC1.1.pdf

https://access.redhat.com/security/cve/CVE-2026-27171

https://github.com/advisories/GHSA-h858-mf2m-8jf4

https://github.com/madler/zlib/issues/904

https://github.com/madler/zlib/releases/tag/v1.3.2

https://nvd.nist.gov/vuln/detail/CVE-2026-27171

https://ostif.org/zlib-audit-complete

https://ostif.org/zlib-audit-complete/

https://www.cve.org/CVERecord?id=CVE-2026-27171

Images

No images found.

Low

Finding 198 - CVE-2026-3449 @Tootallnate/Once 1.1.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	705	[CVE-2026-3449]	4050

Location

Component	Version
@tootallnate/once	1.1.2
File Path	
juice-shop/node_modules/@tootallnate/once/package.json	

Description

@tootallnate/once: @tootallnate/once: Denial of Service due to incorrect control flow scoping with AbortSignal

Target: Node.js

Type: node-pkg

Fixed version: 3.0.1, 2.0.1

Versions of the package @tootallnate/once before 3.0.1 are vulnerable to Incorrect Control Flow Scoping in promise resolving when AbortSignal option is used. The Promise remains in a permanently pending state after the signal is aborted, causing any await or .then() usage to hang indefinitely. This can cause a control-flow leak that can lead to stalled requests, blocked workers, or degraded application availability.

Mitigation

3.0.1, 2.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-3449
- https://github.com/TooTallNate/once
- https://github.com/TooTallNate/once/commit/b9f43cc5259bee2952d91ad3cdbd201a82df448a
- https://github.com/TooTallNate/once/issues/8
- https://github.com/TooTallNate/once/releases/tag/v2.0.1
- https://nvd.nist.gov/vuln/detail/CVE-2026-3449
- https://security.snyk.io/vuln/SNYK-JS-TOOTALLNATEONCE-15250612
- https://www.cve.org/CVERecord?id=CVE-2026-3449

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-428']	4051

Location

Component	Version
base64url	0.0.6
File Path	
juice-shop/node_modules/base64url/package.json	

Description

Out-of-bounds Read

Target: Node.js

Type: node-pkg

Fixed version: >=3.0.0

base64url allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below

Mitigation

=3.0.0

Impact

fixed

References

https://github.com/brianloveswords/base64url/pull/25

https://hackerone.com/reports/321687

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['GHSA-rvg8-pwq2-xj7q']	4052

Location

Component	Version
base64url	0.0.6
File Path	
juice-shop/node_modules/base64url/package.json	

Description

Out-of-bounds Read in base64url

Target: Node.js

Type: node-pkg

Fixed version: 3.0.0

Versions of base64url before 3.0.0 are vulnerable to to out-of-bounds reads as it allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below.

Recommendation

Update to version 3.0.0 or later.

Mitigation

3.0.0

Impact

fixed

References

https://github.com/brianloveswords/base64url

https://github.com/brianloveswords/base64url/commit/4fbd954a0a69e9d898de2146557cc6e893e79542

https://github.com/brianloveswords/base64url/pull/25

https://hackerone.com/reports/321687

Images

No images found.

Low

Finding 201 - CVE-2024-47764 Cookie 0.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.7)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	74	['CVE-2024-47764']	4053

Location

Component	Version
cookie	0.4.2

File Path
juice-shop/node_modules/engine.io/node_modules/cookie/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

cookie: cookie accepts cookie name, path, and domain with out of bounds characters

Target: Node.js

Type: node-pkg

Fixed version: 0.7.0

cookie is a basic HTTP cookie parser and serializer for HTTP servers. The cookie name could be used to set other fields of the cookie, resulting in an unexpected cookie value. A similar escape can be used for path and domain, which could be abused to alter other fields of the cookie. Upgrade to 0.7.0, which updates the validation for name, path, and domain.

Mitigation

0.7.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2024-47764
- https://github.com/jshttp/cookie
- https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c
- https://github.com/jshttp/cookie/pull/167
- https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x
- https://nvd.nist.gov/vuln/detail/CVE-2024-47764
- https://www.cve.org/CVERecord?id=CVE-2024-47764

Images

No images found.

Critical

Finding 202 - CVE-2023-46233 Crypto-Js 3.3.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	328	['CVE-2023-46233']	4054

Location

Component	Version
crypto-js	3.3.0
File Path	
juice-shop/node_modules/crypto-js/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

crypto-js: PBKDF2 1,000 times weaker than specified in 1993 and 1.3M times weaker than current standard

Target: Node.js

Type: node-pkg

Fixed version: 4.2.0

crypto-js is a JavaScript library of crypto standards. Prior to version 4.2.0, crypto-js PBKDF2 is 1,000 times weaker than originally specified in 1993, and at

least 1,300,000 times weaker than current industry standard. This is because it both defaults to SHA1, a cryptographic hash algorithm considered insecure since at least 2005, and defaults to one single iteration, a 'strength' or 'difficulty' value specified at 1,000 when specified in 1993. PBKDF2 relies on iteration count as a countermeasure to preimage and collision attacks. If used to protect passwords, the impact is high. If used to generate signatures, the impact is high. Version 4.2.0 contains a patch for this issue. As a workaround, configure crypto-js to use SHA256 with at least 250,000 iterations.

Mitigation

4.2.0

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2023-46233>
- <https://github.com/brix/crypto-js>
- <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>
- <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>
- <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>
- <https://ubuntu.com/security/notices/USN-6753-1>
- <https://www.cve.org/CVERecord?id=CVE-2023-46233>

Images

No images found.

Medium

Finding 203 - CVE-2022-41940 engine.io 4.1.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2022-41940']	4055

Location

Component	Version
engine.io	4.1.2
File Path	
juice-shop/node_modules/engine.io/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

engine.io: Specially crafted HTTP request can trigger an uncaught exception

Target: Node.js

Type: node-pkg

Fixed version: 3.6.1, 6.2.1

Engine.IO is the implementation of transport-based cross-browser/cross-device bi-directional communication layer for Socket.IO. A specially crafted HTTP request can trigger an uncaught exception on the Engine.IO server, thus killing the Node.js process. This impacts all the users of the engine.io package, including those who uses depending packages like socket.io. There is no known workaround except upgrading to a safe version. There are patches for this

Mitigation

3.6.1, 6.2.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-41940
- https://github.com/socketio/engine.io
- https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6
- https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085
- https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w
- https://nvd.nist.gov/vuln/detail/CVE-2022-41940
- https://www.cve.org/CVERecord?id=CVE-2022-41940

Images

No images found.

High

Finding 204 - CVE-2020-15084 Express-JWT 0.1.3 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.7)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	285	['CVE-2020-15084']	4056

Location

Component	Version
express-jwt	0.1.3
File Path	
juice-shop/node_modules/express-jwt/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Description

Authorization bypass in express-jwt

Target: Node.js

Type: node-pkg

Fixed version: 6.0.0

In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration is not being enforced. When algorithms is not specified in the configuration, with the combination of jwks-rsa, it may lead to authorization bypass. You are affected by this vulnerability if all of the following conditions apply: - You are using express-jwt - You do not have **algorithms** configured in your express-jwt configuration. - You are using libraries such as jwks-rsa as the **secret**. You can fix this by specifying **algorithms** in the express-jwt configuration. See linked GHSA for example. This is also fixed in version 6.0.0.

Mitigation

Impact

fixed

References

https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef

https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf

https://nvd.nist.gov/vuln/detail/CVE-2020-15084

Images

No images found.

Medium

Finding 205 - CVE-2026-31808 File-Type 16.5.4 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	835	['CVE-2026-31808']	4057

Location

Component	Version
file-type	16.5.4
File Path	
juice-shop/node_modules/file-type/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

file-type: file-type: Denial of Service due to infinite loop in ASF file parsing

Target: Node.js

Type: node-pkg

Fixed version: 21.3.1

file-type detects the file type of a file, stream, or data. Prior to 21.3.1, a denial of service vulnerability exists in the ASF (WMV/WMA) file type detection parser. When parsing a crafted input where an ASF sub-header has a size field of zero, the parser enters an infinite loop. The payload value becomes negative (-24), causing tokenizer.ignore(payload) to move the read position backwards, so the same sub-header is read repeatedly forever. Any application that uses file-type to detect the type of untrusted/attacker-controlled input is affected. An attacker can stall the Node.js event loop with a 55-byte payload. Fixed in version 21.3.1.

Mitigation

21.3.1

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2026-31808

https://github.com/sindresorhus/file-type

https://github.com/sindresorhus/file-type/commit/319abf871b50ba2fa221b4a7050059f1ae096f4f

https://github.com/sindresorhus/file-type/security/advisories/GHSA-5v7r-6r5c-r473

https://nvd.nist.gov/vuln/detail/CVE-2026-31808

https://www.cve.org/CVERecord?id=CVE-2026-31808

Images

No images found.

Finding 206 - CVE-2022-33987 Got 8.3.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	[CVE-2022-33987]	4058

Location

Component	Version
got	8.3.2

File Path
juice-shop/node_modules/got/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

nodejs-got: missing verification of requested URLs allows redirects to UNIX sockets

Target: Node.js

Type: node-pkg

Fixed version: 12.1.0, 11.8.5

The got package before 12.1.0 (also fixed in 11.8.5) for Node.js allows a redirect to a UNIX socket.

Mitigation

12.1.0, 11.8.5

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2022:6595

https://access.redhat.com/security/cve/CVE-2022-33987

https://bugzilla.redhat.com/1907444

https://bugzilla.redhat.com/1945459

https://bugzilla.redhat.com/1964461

https://bugzilla.redhat.com/2007557

https://bugzilla.redhat.com/2098556

https://bugzilla.redhat.com/2102001

<https://bugzilla.redhat.com/2105422>

<https://bugzilla.redhat.com/2105426>

<https://bugzilla.redhat.com/2105428>

<https://bugzilla.redhat.com/2105430>

https://bugzilla.redhat.com/show_bug.cgi?id=1907444

https://bugzilla.redhat.com/show_bug.cgi?id=1945459

https://bugzilla.redhat.com/show_bug.cgi?id=1964461

https://bugzilla.redhat.com/show_bug.cgi?id=2007557

https://bugzilla.redhat.com/show_bug.cgi?id=2098556

https://bugzilla.redhat.com/show_bug.cgi?id=2102001

https://bugzilla.redhat.com/show_bug.cgi?id=2105422

https://bugzilla.redhat.com/show_bug.cgi?id=2105426

https://bugzilla.redhat.com/show_bug.cgi?id=2105428

https://bugzilla.redhat.com/show_bug.cgi?id=2105430

https://bugzilla.redhat.com/show_bug.cgi?id=2121019

https://bugzilla.redhat.com/show_bug.cgi?id=2124299

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-28469>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-7788>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-33502>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-3807>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-29244>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32212>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32213>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32214>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32215>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-33987>

<https://errata.almalinux.org/9/ALSA-2022-6595.html>

<https://errata.rockylinux.org/RLSA-2022:6595>

<https://github.com/sindresorhus/got>

<https://github.com/sindresorhus/got/commit/861ccd9ac2237df762a9e2beed7edd88c60782dc>

<https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0>

<https://github.com/sindresorhus/got/pull/2047>

<https://github.com/sindresorhus/got/releases/tag/v11.8.5>

<https://github.com/sindresorhus/got/releases/tag/v12.1.0>

<https://linux.oracle.com/cve/CVE-2022-33987.html>

<https://linux.oracle.com/errata/ELSA-2022-6595.html>

<https://nvd.nist.gov/vuln/detail/CVE-2022-33987>

<https://www.cve.org/CVERecord?id=CVE-2022-33987>

Images

No images found.

High

Finding 207 - CVE-2022-25881 HTTP-Cache-Semantics 3.8.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1333	[CVE-2022-25881]	4059

Location

Component	Version
http-cache-semantics	3.8.1
File Path	
juice-shop/node_modules/http-cache-semantics/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

http-cache-semantics: Regular Expression Denial of Service (ReDoS) vulnerability

Target: Node.js

Type: node-pkg

Fixed version: 4.1.1

This affects versions of the package http-cache-semantics before 4.1.1. The issue can be exploited via malicious request header values sent to a server, when that server reads the cache policy from the request using this library.

Mitigation

4.1.1

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2023:2655

https://access.redhat.com/security/cve/CVE-2022-25881

https://bugzilla.redhat.com/2165824

https://bugzilla.redhat.com/2168631

https://bugzilla.redhat.com/2171935

https://bugzilla.redhat.com/2172190

https://bugzilla.redhat.com/2172204

https://bugzilla.redhat.com/2172217

https://bugzilla.redhat.com/show_bug.cgi?id=2165824

https://bugzilla.redhat.com/show_bug.cgi?id=2168631

https://bugzilla.redhat.com/show_bug.cgi?id=2171935

https://bugzilla.redhat.com/show_bug.cgi?id=2172190

https://bugzilla.redhat.com/show_bug.cgi?id=2172204

https://bugzilla.redhat.com/show_bug.cgi?id=2172217

https://bugzilla.redhat.com/show_bug.cgi?id=2178076

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-25881

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-4904

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23918

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23920

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23936

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-24807

https://errata.almalinux.org/9/ALSA-2023-2655.html

https://errata.rockylinux.org/RLSA-2023:2655

https://github.com/kornelski/http-cache-semantics

https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83

https://github.com/kornelski/http-cache-semantics/commit/560b2d8ef452bbba20ffed69dc155d63ac757b74

https://linux.oracle.com/cve/CVE-2022-25881.html

https://linux.oracle.com/errata/ELSA-2023-2655.html

https://nvd.nist.gov/vuln/detail/CVE-2022-25881

https://security.netapp.com/advisory/ntap-20230622-0008

https://security.netapp.com/advisory/ntap-20230622-0008/

https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332

https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783

https://www.cve.org/CVERecord?id=CVE-2022-25881

Images

No images found.

Finding 208 - CVE-2015-9235 Jsonwebtoken 0.1.0 jar lang-pkgs node-pkg xsss

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.8)	N.A. / N.A.	Inactive, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4060

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-jsonwebtoken: verification step bypass with an altered token

Target: Node.js

Type: node-pkg

Fixed version: 4.2.2

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

4.2.2

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2015-9235>
- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>
- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>
- <https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>
- <https://nodesecurity.io/advisories/17>
- <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>
- <https://www.cve.org/CVERecord?id=CVE-2015-9235>
- <https://www.npmjs.com/advisories/17>
- <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Finding 209 - CVE-2022-23539 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	327	[CVE-2022-23539]	4061

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

jsonwebtoken: Unrestricted key type could lead to legacy keys usagen

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

9.0.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-23539

https://github.com/auth0/node-jwebtoken

https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33

https://nvd.nist.gov/vuln/detail/CVE-2022-23539

https://security.netapp.com/advisory/ntap-20240621-0007

https://security.netapp.com/advisory/ntap-20240621-0007/

https://www.cve.org/CVERecord?id=CVE-2022-23539

Images

No images found.

Finding 210 - NSWG-ECO-17 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17'] 4062

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

Description

Verification Bypass

Target: Node.js

Type: node-pkg

Fixed version: >=4.2.2

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the

attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

=4.2.2

Impact

fixed

References

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/
https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687
https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

Medium

Finding 211 - CVE-2022-23540 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	287	[CVE-2022-23540]	4063

Location

Component	Version
jsonwebtoken	0.1.0
File Path	
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

jsonwebtoken: Insecure default algorithm in jwt.verify() could lead to signature validation bypass

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

9.0.0

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2022-23540>
- <https://github.com/auth0/node-jsonwebtoken>
- <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-qwph-4952-7xr6>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>
- <https://security.netapp.com/advisory/ntap-20240621-0007>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>
- <https://www.cve.org/CVERecord?id=CVE-2022-23540>

Images

No images found.

Finding 212 - CVE-2022-23541 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4064

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken: Insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

9.0.0

Impact

fixed

References

<https://access.redhat.com/security/cve/CVE-2022-23541>

https://github.com/auth0/node-jsonwebtoken

https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0

https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959

https://nvd.nist.gov/vuln/detail/CVE-2022-23541

https://security.netapp.com/advisory/ntap-20240621-0007

https://security.netapp.com/advisory/ntap-20240621-0007/

https://www.cve.org/CVERecord?id=CVE-2022-23541

Images

No images found.

Critical

Finding 213 - CVE-2015-9235 Jwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.8)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4065

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-jsonwebtoken: verification step bypass with an altered token

Target: Node.js

Type: node-pkg

Fixed version: 4.2.2

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

4.2.2

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2015-9235

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/

https://github.com/advisories/GHSA-c7hr-j4mj-j2w6

https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687

https://nodesecurity.io/advisories/17

https://nvd.nist.gov/vuln/detail/CVE-2015-9235

https://www.cve.org/CVERecord?id=CVE-2015-9235

https://www.npmjs.com/advisories/17

https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

High

Finding 214 - CVE-2022-23539 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	327	['CVE-2022-23539']	4066

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

jsonwebtoken: Unrestricted key type could lead to legacy keys usagen

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

9.0.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-23539

https://github.com/auth0/node-jsonwebtoken

https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-8cf7-32gw-wr33

https://nvd.nist.gov/vuln/detail/CVE-2022-23539

https://security.netapp.com/advisory/ntap-20240621-0007

https://security.netapp.com/advisory/ntap-20240621-0007/

https://www.cve.org/CVERecord?id=CVE-2022-23539

Images

No images found.

Finding 215 - NSWG-ECO-17 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4067

Location	
Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

Description

Verification Bypass

Target: Node.js

Type: node-pkg

Fixed version: >=4.2.2

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

>=4.2.2

Impact

fixed

References

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/

https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687

https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

Medium

Finding 216 - CVE-2022-23540 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4068

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

jsonwebtoken: Insecure default algorithm in jwt.verify() could lead to signature validation bypass

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

9.0.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-23540
- https://github.com/auth0/node-jwebtoken
- https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3
- https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6
- https://nvd.nist.gov/vuln/detail/CVE-2022-23540
- https://security.netapp.com/advisory/ntap-20240621-0007
- https://security.netapp.com/advisory/ntap-20240621-0007/
- https://www.cve.org/CVERecord?id=CVE-2022-23540

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4069

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken: Insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

9.0.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-23541

https://github.com/auth0/node-jwebtoken

https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

https://github.com/auth0/node-jwebtoken/releases/tag/v9.0.0

https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-hjrf-2m68-5959

https://nvd.nist.gov/vuln/detail/CVE-2022-23541

https://security.netapp.com/advisory/ntap-20240621-0007

https://security.netapp.com/advisory/ntap-20240621-0007/

https://www.cve.org/CVERecord?id=CVE-2022-23541

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High (8.7)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	[CVE-2016-1000223]	4070

Location

Component	Version
jws	0.2.6
File Path	
juice-shop/node_modules/jws/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Description

Forgeable Public/Private Tokens

Target: Node.js

Type: node-pkg

Fixed version: >=3.0.0

Since "algorithm" isn't enforced in jws.verify(), a malicious user could choose what algorithm is sent to the server. If the server is expecting RSA but is sent HMAC-SHA with RSA's public key, the server will think the public key is actually an HMAC private key. This could be used to forge any data an attacker wants.

In addition, there is the none algorithm to be concerned about. In versions prior to 3.0.0, verification of the token could be bypassed when the alg field is set to none.

Edit (7/29/16): A previous version of this advisory incorrectly stated that the vulnerability was patched in version 2.0.0 instead of 3.0.0. The advisory has been updated to reflect this new information. Thanks to Fabien Catteau for reporting the error.

Mitigation

=3.0.0

Impact

fixed

References

<https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

<https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

<https://github.com/brianloveswords/node-jws>

<https://github.com/brianloveswords/node-jws/commit/585d0e1e97b6747c10cf5b7689ccc5618a89b299#diff-4ac32a78649ca5bdd8e0ba38b7006a1e>

<https://nvd.nist.gov/vuln/detail/CVE-2016-1000223>

<https://snyk.io/vuln/npm:jws:20160726>

<https://www.npmjs.com/advisories/88>

Images

No images found.

Finding 219 - CVE-2025-65945 JWS 0.2.6 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	347	['CVE-2025-65945']	4071

Location

Component	Version
jws	0.2.6
File Path	
juice-shop/node_modules/jws/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-jws: auth0/node-jws: Improper signature verification in HS256 algorithm

Target: Node.js

Type: node-pkg

Fixed version: 3.2.3, 4.0.1

auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the jws.createVerify() function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Mitigation

3.2.3, 4.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-65945
- https://github.com/auth0/node-jws
- https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e
- https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6
- https://github.com/auth0/node-jws/releases/tag/v3.2.3
- https://github.com/auth0/node-jws/releases/tag/v4.0.1
- https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x
- https://nvd.nist.gov/vuln/detail/CVE-2025-65945
- https://www.cve.org/CVERecord?id=CVE-2025-65945

Images

No images found.

Finding 220 - CVE-2019-10744 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)		1321 [CVE-2019-10744]	4072

Location

Component	Version
lodash	2.4.2
File Path	
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

nodejs-lodash: prototype pollution in defaultsDeep function leading to modifying properties

Target: Node.js

Type: node-pkg

Fixed version: 4.17.12

Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked into adding or modifying properties of Object.prototype using a constructor payload.

Mitigation

4.17.12

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2019:3024>

<https://access.redhat.com/security/cve/CVE-2019-10744>

<https://github.com/advisories/GHSA-jf85-cpcp-j695>

<https://github.com/lodash/lodash/pull/4336>

<https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2019-10744.yml>

<https://nvd.nist.gov/vuln/detail/CVE-2019-10744>

<https://security.netapp.com/advisory/ntap-20191004-0005>

<https://security.netapp.com/advisory/ntap-20191004-0005/>

<https://snyk.io/vuln/SNYK-JS-LODASH-450202>

<https://support.f5.com/csp/article/K47105354>

https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS

https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS

<https://www.cve.org/CVERecord?id=CVE-2019-10744>

Images

No images found.

High

Finding 221 - CVE-2018-16487 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (5.6)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	400	[CVE-2018-16487]	4073

Location

Component	Version
lodash	2.4.2

File Path
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

lodash: Prototype pollution in utilities function

Target: Node.js

Type: node-pkg

Fixed version: >=4.17.11

A prototype pollution vulnerability was found in lodash <4.17.11 where the functions merge, mergeWith, and defaultsDeep can be tricked into adding or modifying properties of Object.prototype.

Mitigation

=4.17.11

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2018-16487

https://github.com/advisories/GHSA-4xc9-xhrj-v574

https://github.com/lodash/lodash/commit/90e6199a161b6445b01454517b40ef65eabcd2ad

https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-16487.yml

https://hackerone.com/reports/380873

https://nvd.nist.gov/vuln/detail/CVE-2018-16487

https://security.netapp.com/advisory/ntap-20190919-0004

https://security.netapp.com/advisory/ntap-20190919-0004/

https://www.cve.org/CVERecord?id=CVE-2018-16487

https://www.npmjs.com/advisories/782

Images

No images found.

Finding 222 - CVE-2021-23337 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.2)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	94	[CVE-2021-23337]	4074

Location

Component	Version
lodash	2.4.2
File Path	
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-lodash: command injection via template

Target: Node.js

Type: node-pkg

Fixed version: 4.17.21

Lodash versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Mitigation

4.17.21

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2021-23337

https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf

https://github.com/advisories/GHSA-35jh-r3h4-6jhm

https://github.com/lodash/lodash

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js#L14851

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js%23L14851

https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b5a91dde28ba4b1c

https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2021-23337.yml

- https://nvd.nist.gov/vuln/detail/CVE-2021-23337
- https://security.netapp.com/advisory/ntap-20210312-0006
- https://security.netapp.com/advisory/ntap-20210312-0006/
- https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLDASH-1074931
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929
- https://snyk.io/vuln/SNYK-JS-LODASH-1040724
- https://www.cve.org/CVERecord?id=CVE-2021-23337
- https://www.oracle.com//security-alerts/cpujul2021.html
- https://www.oracle.com/security-alerts/cpujan2022.html
- https://www.oracle.com/security-alerts/cpujul2022.html
- https://www.oracle.com/security-alerts/cpuoct2021.html

Images

No images found.

Medium

Finding 223 - CVE-2026-2950 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1321 ['CVE-2026-2950'] 4075

Location

Component	Version
lodash	2.4.2

File Path
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

lodash: Lodash: Prototype pollution allows deletion of built-in prototype properties via array path bypass

Target: Node.js

Type: node-pkg

Fixed version: 4.18.0

Impact:

Lodash versions 4.17.23 and earlier are vulnerable to prototype pollution in the .unset and .omit functions. The fix for (CVE-2025-13465: https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg) only guards against string key members, so an attacker can bypass the check

by passing array-wrapped path segments. This allows deletion of properties from built-in prototypes such as Object.prototype, Number.prototype, and String.prototype.

The issue permits deletion of prototype properties but does not allow overwriting their original behavior.

Patches:

This issue is patched in 4.18.0.

Workarounds:

None. Upgrade to the patched version.

Mitigation

4.18.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-2950
- https://github.com/lodash/lodash
- https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh
- https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg
- https://nvd.nist.gov/vuln/detail/CVE-2026-2950
- https://www.cve.org/CVERecord?id=CVE-2026-2950

Images

No images found.

Low

Finding 224 - CVE-2018-3721 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	471	['CVE-2018-3721']	4076

Location

Component	Version
lodash	2.4.2
File Path	
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Description

lodash: Prototype pollution in utilities function

Type: node-pkg

Description

nodejs-lodash: prototype pollution in zipObjectDeep function

Target: Node.js

Type: node-pkg

Fixed version:

Prototype pollution attack when using `_zipObjectDeep` in `lodash` before 4.17.20.

Impact

affected

References

<https://access.redhat.com/security/cve/CVE-2020-8203>

<https://github.com/advisories/GHSA-p6mc-m468-83gw>

<https://github.com/github/advisory-database/pull/2884>

<https://github.com/lodash/lodash>

<https://github.com/lodash/lodash/commit/c84fe82760fb2d3e03a63379b297a1cc1a2fce12>

<https://github.com/lodash/lodash/issues/4744>

<https://github.com/lodash/lodash/issues/4874>

<https://github.com/lodash/lodash/wiki/Changelog#v41719>

<https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2020-8203.yml>

<https://hackerone.com/reports/712065>

<https://hackerone.com/reports/864701>

<https://nvd.nist.gov/vuln/detail/CVE-2020-8203>

<https://security.netapp.com/advisory/ntap-20200724-0006>

<https://security.netapp.com/advisory/ntap-20200724-0006/>

<https://web.archive.org/web/20210914001339/https://github.com/lodash/lodash/issues/4744>

<https://www.cve.org/CVERecord?id=CVE-2020-8203>

<https://www.npmjs.com/advisories/1523>

<https://www.oracle.com//security-alerts/cpujul2021.html>

<https://www.oracle.com/security-alerts/cpuApr2021.html>

<https://www.oracle.com/security-alerts/cpuapr2022.html>

<https://www.oracle.com/security-alerts/cpujan2022.html>

<https://www.oracle.com/security-alerts/cpuoct2021.html>

Images

No images found.

Critical

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Date Mitigated	Mitigated By	Vulnerability IDs	Dojo ID
Critical	N.A. / N.A.	Inactive, Mitigated	June 7, 2026	0 days	Admin User (admin)	June 7, 2026, 1:02 p.m.	Admin User (admin)	['GHSA-5mrr-rgp6-x4gr']	4078

Location

Component	Version
marsdb	0.6.11
File Path	
juice-shop/node_modules/marsdb/package.json	

Description

Command Injection in marsdb

Target: Node.js

Type: node-pkg

Fixed version:

All versions of marsdb are vulnerable to Command Injection. In the DocumentMatcher class, selectors on \$where clauses are passed to a Function constructor unsanitized. This allows attackers to run arbitrary commands in the system when the function is executed.

Recommendation

No fix is currently available. Consider using an alternative package until a fix is made available.

Impact

affected

References

https://github.com/bkimminich/juice-shop/issues/1173

https://www.npmjs.com/advisories/1122

Images

No images found.

Low

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2025-57349']	4079

Location

Component	Version
messageformat	2.3.0
File Path	
juice-shop/node_modules/messageformat/package.json	

Description

messageformat has a prototype pollution vulnerability

Target: Node.js

Type: node-pkg

Fixed version: 3.0.0-beta.0

The messageformat package, an implementation of the Unicode MessageFormat 2 specification for JavaScript, is vulnerable to prototype pollution due to improper handling of message key paths in versions prior to 2.3.0. The flaw arises when processing nested message keys containing special characters (e.g., **proto**), which can lead to unintended modification of the JavaScript Object prototype. This vulnerability may allow a remote attacker to inject properties into the global object prototype via specially crafted message input, potentially causing denial of service or other undefined behaviors in applications using the affected component.

Mitigation

3.0.0-beta.0

Impact

fixed

References

<https://github.com/messageformat/messageformat>

<https://github.com/messageformat/messageformat/issues/452>

<https://nvd.nist.gov/vuln/detail/CVE-2025-57349>

Images

No images found.

High

Finding 228 - CVE-2026-26996 Minimatch 3.0.5 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-26996']	4080

Location

Component	Version
minimatch	3.0.5

File Path
juice-shop/node_modules/replace/node_modules/minimatch/package.json

Description

minimatch: minimatch: Denial of Service via specially crafted glob patterns

Target: Node.js

Type: node-pkg

Fixed version: 10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate [^/?]* regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is O(4^N) where N is the number of * characters. With N=15, a single minimatch() call takes ~2 seconds. With N=34, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.

Mitigation

10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2026:7896>
- <https://access.redhat.com/security/cve/CVE-2026-26996>
- <https://bugzilla.redhat.com/2441268>
- <https://bugzilla.redhat.com/2442922>
- <https://bugzilla.redhat.com/2448754>
- <https://bugzilla.redhat.com/2453151>
- https://bugzilla.redhat.com/show_bug.cgi?id=2441268
- https://bugzilla.redhat.com/show_bug.cgi?id=2442922
- https://bugzilla.redhat.com/show_bug.cgi?id=2448754
- https://bugzilla.redhat.com/show_bug.cgi?id=2453151
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904>
- <https://errata.almalinux.org/9/ALSA-2026-7896.html>
- <https://errata.rockylinux.org/RLSA-2026:7896>
- <https://github.com/isaacs/minimatch>
- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://linux.oracle.com/cve/CVE-2026-26996.html>
- <https://linux.oracle.com/errata/ELSA-2026-8339.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>
- <https://www.cve.org/CVERecord?id=CVE-2026-26996>

Images

No images found.

Finding 229 - CVE-2026-27903 Minimatch 3.0.5 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	407	[CVE-2026-27903]	4081

Location

Component	Version
minimatch	3.0.5

File Path
juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch: minimatch: Denial of Service due to unbounded recursive backtracking via crafted glob patterns

Target: Node.js

Type: node-pkg

Fixed version: 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, `matchOne()` performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent `**` (GLOBSTAR) segments and the input path does not match. The time complexity is $O(C(n, k))$ -- binomial -- where n is the number of path segments and k is the number of globstars. With $k=11$ and $n=30$, a call to the default `minimatch()` API stalls for roughly 5 seconds. With $k=13$, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to `minimatch()` is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Mitigation

10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-27903>
- <https://github.com/isaacs/minimatch>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://www.cve.org/CVERecord?id=CVE-2026-27903>

Images

No images found.

Finding 230 - CVE-2026-27904 Minimatch 3.0.5 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-27904']	4082

Location

Component	Version
minimatch	3.0.5

File Path
juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch: Minimatch: Denial of Service via catastrophic backtracking in glob expressions

Target: Node.js

Type: node-pkg

Fixed version: 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested `*`() extglobs produce regexps with nested unbounded quantifiers (e.g. `?(?:a|b)*`), which exhibit catastrophic backtracking in V8. With a 12-byte pattern `*(*(a|b))` and an 18-byte non-matching input, `minimatch()` stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default `minimatch()` API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects `+`() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Mitigation

10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026:7896>

<https://access.redhat.com/security/cve/CVE-2026-27904>

<https://bugzilla.redhat.com/2441268>

<https://bugzilla.redhat.com/2442922>

<https://bugzilla.redhat.com/2448754>

<https://bugzilla.redhat.com/2453151>

https://bugzilla.redhat.com/show_bug.cgi?id=2441268

https://bugzilla.redhat.com/show_bug.cgi?id=2442922

https://bugzilla.redhat.com/show_bug.cgi?id=2448754

https://bugzilla.redhat.com/show_bug.cgi?id=2453151

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904>

<https://errata.almalinux.org/9/ALSA-2026-7896.html>

<https://errata.rockylinux.org/RLSA-2026:7896>

https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce

https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74

https://linux.oracle.com/cve/CVE-2026-27904.html

https://linux.oracle.com/errata/ELSA-2026-8339.html

https://nvd.nist.gov/vuln/detail/CVE-2026-27904

https://www.cve.org/CVERecord?id=CVE-2026-27904

Images

No images found.

Finding 231 - CVE-2017-18214 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2017-18214']	4083

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

nodejs-moment: Regular expression denial of service

Target: Node.js

Type: node-pkg

Fixed version: 2.19.3

The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.

Mitigation

2.19.3

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2017-18214

https://github.com/advisories/GHSA-446m-mv8f-q348

https://github.com/moment/moment

https://github.com/moment/moment/commit/69ed9d44957fa6ab12b73d2ae29d286a857b80eb

https://github.com/moment/moment/issues/4163

https://github.com/moment/moment/pull/4326

https://nodesecurity.io/advisories/532

https://nvd.nist.gov/vuln/detail/CVE-2017-18214

https://ubuntu.com/security/notices/USN-4786-1

https://www.cve.org/CVERecord?id=CVE-2017-18214

https://www.npmjs.com/advisories/532

https://www.tenable.com/security/tns-2019-02

Images

No images found.

Finding 232 - CVE-2022-24785 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2022-24785]	4084

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Moment.js: Path traversal in moment.locale

Target: Node.js

Type: node-pkg

Fixed version: 2.29.2

Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

Mitigation

2.29.2

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-24785

https://github.com/moment/moment

https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5

https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4

https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q/

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5/

https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

https://nvd.nist.gov/vuln/detail/CVE-2022-24785

https://security.netapp.com/advisory/ntap-20220513-0006

https://security.netapp.com/advisory/ntap-20220513-0006/

https://security.netapp.com/advisory/ntap-20241108-0002

https://security.netapp.com/advisory/ntap-20241108-0002/

https://ubuntu.com/security/notices/USN-5559-1

https://www.cve.org/CVERecord?id=CVE-2022-24785

https://www.tenable.com/security/tns-2022-09

Images

No images found.

Medium

Finding 233 - CVE-2016-4055 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	400 ['CVE-2016-4055']	4085

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

moment.js: regular expression denial of service

Target: Node.js

Type: node-pkg

Fixed version: >=2.11.2

The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."

Mitigation

Impact

fixed

References

<http://www.openwall.com/lists/oss-security/2016/04/20/11>

<http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>

<http://www.securityfocus.com/bid/95849>

<https://access.redhat.com/security/cve/CVE-2016-4055>

<https://github.com/advisories/GHSA-87vv-r9j6-g5qv>

<https://github.com/moment/moment>

<https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731%40%3Cdev.flink.apache.org%3E>

<https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731@%3Cdev.flink.apache.org%3E>

<https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49@%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2@%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854@%3Cuser.flink.apache.org%3E>

<https://nodesecurity.io/advisories/55>

<https://nvd.nist.gov/vuln/detail/CVE-2016-4055>

<https://ubuntu.com/security/notices/USN-4786-1>

<https://www.cve.org/CVERecord?id=CVE-2016-4055>

<https://www.npmjs.com/advisories/55>

https://www.owasp.org/index.php/Regular_expression_Denial_of_Service_-_ReDoS

<https://www.tenable.com/security/tns-2019-02>

Images

No images found.

High

Finding 234 - CVE-2025-47935 Multer 1.4.5-lts.2 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	401	[CVE-2025-47935]	4086

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer vulnerable to Denial of Service via memory leaks from unclosed streams

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0

Multer is a node.js middleware for handling multipart/form-data. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal busboy stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

2.0.0

Impact

fixed

References

- <https://github.com/expressjs/multer>
- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>
- <https://github.com/expressjs/multer/pull/1120>
- <https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-47935>

Images

No images found.

Finding 235 - CVE-2025-47944 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	248	[CVE-2025-47944]	4087

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer vulnerable to Denial of Service from maliciously crafted requests

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

2.0.0

Impact

fixed

References

- <https://github.com/expressjs/multer>
- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>
- <https://github.com/expressjs/multer/issues/1176>
- <https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-47944>

Images

No images found.

Finding 236 - CVE-2025-48997 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-48997']	4088

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer vulnerable to Denial of Service via unhandled exception

Target: Node.js

Type: node-pkg

Fixed version: 2.0.1

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to 2.0.1 to receive a patch. No known workarounds are available.

Mitigation

2.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-48997
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9
- https://github.com/expressjs/multer/issues/1233
- https://github.com/expressjs/multer/pull/1256
- https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qg
- https://nvd.nist.gov/vuln/detail/CVE-2025-48997
- https://www.cve.org/CVERecord?id=CVE-2025-48997

Images

No images found.

Finding 237 - CVE-2025-7338 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	248	[CVE-2025-7338]	4089

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

multer: Multer Denial of Service

Target: Node.js

Type: node-pkg

Fixed version: 2.0.2

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Mitigation

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-7338
- https://cna.openjsf.org/security-advisories.html
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b
- https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p
- https://nvd.nist.gov/vuln/detail/CVE-2025-7338
- https://www.cve.org/CVERecord?id=CVE-2025-7338

Images

No images found.

Finding 238 - CVE-2026-2359 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	772 ['CVE-2026-2359']	4090

Location

Component	Version
multer	1.4.5-lts.2

File Path
juice-shop/node_modules/multer/package.json

Description

multer: Multer: Denial of Service via dropped file upload connections

Target: Node.js

Type: node-pkg

Fixed version: 2.1.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by dropping connection during file upload, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

2.1.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-2359
- https://cna.openjsf.org/security-advisories.html

https://github.com/expressjs/multer

https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab

https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc

https://nvd.nist.gov/vuln/detail/CVE-2026-2359

https://www.cve.org/CVERecord?id=CVE-2026-2359

Images

No images found.

Finding 239 - CVE-2026-3304 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	459	['CVE-2026-3304']	4091

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer: Denial of Service via malformed requests

Target: Node.js

Type: node-pkg

Fixed version: 2.1.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

2.1.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2026-3304

https://cna.openjsf.org/security-advisories.html

https://github.com/expressjs/multer

https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee

https://github.com/expressjs/multer/security/advisories/GHSA-xf7r-hgr6-v32p

https://nvd.nist.gov/vuln/detail/CVE-2026-3304

https://www.cve.org/CVERecord?id=CVE-2026-3304

Images

No images found.

Finding 240 - CVE-2026-3520 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	674 ['CVE-2026-3520']	4092

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer: Denial of Service via malformed requests

Target: Node.js

Type: node-pkg

Fixed version: 2.1.1

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.1 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing stack overflow. Users should upgrade to version 2.1.1 to receive a patch. No known workarounds are available.

Mitigation

2.1.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-3520
- https://cna.openjsf.org/security-advisories.html
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752
- https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2
- https://nvd.nist.gov/vuln/detail/CVE-2026-3520
- https://www.cve.org/CVERecord?id=CVE-2026-3520

Images

No images found.

Medium

Finding 241 - CVE-2021-23771 Notevil 1.3.3 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1321 ['CVE-2021-23771']	4093

Location	
Component	Version
notevil	1.3.3
File Path	
juice-shop/node_modules/notevil/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

Sandbox escape in notevil and argencoders-notevil

Target: Node.js

Type: node-pkg

Fixed version:

This affects all versions of package notevil; all versions of package argencoders-notevil. It is vulnerable to Sandbox Escape leading to Prototype pollution. The package fails to restrict access to the main context, allowing an attacker to add or modify an object's prototype. **Note:** This vulnerability derives from an incomplete fix in [SNYK-JS-NOTEVIL-608878](#).

Impact

affected

References

- <https://github.com/mmckegg/notevil>
- <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>
- <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>
- <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Images

No images found.

Finding 242 - CVE-2026-8723 Qs 6.15.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2026-8723']	4094

Location	
Component	Version
qs	6.15.1
File Path	
juice-shop/node_modules/qs/package.json	

Description

Summary qs.stringify throws TypeError when called with `arr ...

Target: Node.js

Type: node-pkg

Fixed version: 6.15.2

Summary

qs.stringify throws `TypeError` when called with `arrayFormat: 'comma'` and `encodeValuesOnly: true` on an array containing null or undefined. The throw is synchronous and not handled by any of qs's null-related options (`skipNulls`, `strictNullHandling`).

Details

In the comma + `encodeValuesOnly` branch, `lib/stringify.js:145` mapped the array through the raw encoder before joining:

```
obj = utils.maybeMap(obj, encoder);
```

`utils.encode` (`lib/utils.js:195`) reads `str.length` with no null guard, so a null or undefined element throws `TypeError`. `skipNulls` and `strictNullHandling` are both checked in the per-element loop below this line and never get a chance to run.

Same class of bug as the filter-array path fixed in `0c180a4`. The vulnerable shape of the comma + `encodeValuesOnly` branch was introduced in `4c4b23d` ("encode comma values more consistently", PR #463, 2023-01-19), first released in v6.11.1.

PoC

```
const qs = require('qs');
```

```
qs.stringify({ a: [null, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [undefined, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [null] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
// TypeError: Cannot read properties of null (reading 'length')
```

```
//   at encode (lib/utils.js:195:13)
```

```
//   at Object.maybeMap (lib/utils.js:322:37)
```

```
//   at stringify (lib/stringify.js:145:25)
```

Fix

`lib/stringify.js:145`, applied in `21f80b3` on main and released as v6.15.2:

```
- obj = utils.maybeMap(obj, encoder);
```

```
+ obj = utils.maybeMap(obj, function (v) {
```

```
+   return v == null ? v : encoder(v);
```

```
+ });
```

null and undefined now pass through maybeMap unchanged and reach the join(',') step as-is. For { a: [null, 'b'] } this produces a=,b, matching the non-encodeValuesOnly comma path (which already joins before encoding and produces a=%2Cb for the same input). Single-element [null] arrays still collapse via the existing obj.join(',') || null and remain subject to skipNulls / strictNullHandling in the main loop.

Affected versions

>=6.11.1 <6.15.2 – fixed in v6.15.2.

The vulnerable code shape was introduced in 4c4b23d and first shipped in v6.11.1. Earlier versions – including all of 6.7.x, 6.8.x, 6.9.x, 6.10.x, and 6.11.0 – implemented the comma + encodeValuesOnly path differently (joining before encoding) and are not affected. Empirically verified across released versions.

Impact

Application code that calls qs.stringify with both arrayFormat: 'comma' and encodeValuesOnly: true (both non-default) on input that may contain a null or undefined array element will throw synchronously instead of producing a query string. In a typical Node.js HTTP framework (Express, Fastify, Koa, hapi) the sync throw is caught by the framework's error boundary and the affected request returns a 500; the worker process does not exit and subsequent requests are unaffected. The "kills the worker process" framing applies only to call sites outside a request-handler error boundary (background jobs, startup paths, stream pipelines) or to deployments with framework error handling explicitly disabled.

The vulnerable input is a null or undefined entry inside an array; this is reachable from JSON request bodies or from application code constructing arrays from user input, but not from standard HTML form submissions (which produce strings or omitted fields, not literal null).

Mitigation

6.15.2

Impact

fixed

References

<https://github.com/ljharb/qs>

<https://github.com/ljharb/qs/commit/21f80b33e5c8b3f7eba1034fff0da4a4a37a1d41>

<https://github.com/ljharb/qs/security/advisories/GHSA-q8mj-m7cp-5q26>

<https://nvd.nist.gov/vuln/detail/CVE-2026-8723>

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25887']	4095

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

sanitize-html: insecure global regular expression replacement logic may lead to ReDoS

Target: Node.js

Type: node-pkg

Fixed version: 2.7.1

The package sanitize-html before 2.7.1 are vulnerable to Regular Expression Denial of Service (ReDoS) due to insecure global regular expression replacement logic of HTML comment removal.

Mitigation

2.7.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-25887
- https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c
- https://github.com/apostrophecms/sanitize-html/pull/557
- https://nvd.nist.gov/vuln/detail/CVE-2022-25887
- https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3008102
- https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-2957526
- https://ubuntu.com/security/notices/USN-7464-1
- https://www.cve.org/CVERecord?id=CVE-2022-25887

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2016-1000237']	4096

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

XSS - Sanitization not applied recursively

Target: Node.js

Type: node-pkg

Fixed version: >=1.4.3

sanitize-html before 1.4.3 has XSS.

Mitigation

>=1.4.3

Impact

fixed

References

- https://github.com/apostrophecms/sanitize-html/commit/762fbc7bba389f3f789cc291c1eb2b64f60f2caf
- https://github.com/apostrophecms/sanitize-html/issues/29
- https://github.com/punkave/sanitize-html/issues/29
- https://nodesecurity.io/advisories/135
- https://nvd.nist.gov/vuln/detail/CVE-2016-1000237
- https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json
- https://www.npmjs.com/advisories/135

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2017-16016']	4097

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Cross-Site Scripting in sanitize-html

Target: Node.js

Type: node-pkg

Fixed version: 1.11.4

Sanitize-html is a library for scrubbing html input of malicious values. Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios: If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

Mitigation

1.11.4

Impact

fixed

References

- https://github.com/advisories/GHSA-xc6g-ggrc-qq4r
- https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403
- https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403)))
- https://github.com/punkave/sanitize-html/issues/100
- https://nodesecurity.io/advisories/154
- https://npmjs.com/package/sanitize-html#discarding-the-entire-contents-of-a-disallowed-tag
- https://nvd.nist.gov/vuln/detail/CVE-2017-16016
- https://www.npmjs.com/advisories/154

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2019-25225']	4098

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html: sanitize-html cross site scripting

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0-beta

sanitize-html prior to version 2.0.0-beta is vulnerable to Cross-site Scripting (XSS). The sanitizeHtml() function in index.js does not sanitize content when using the custom transformTags option, which is intended to convert attribute values into text. As a result, malicious input can be transformed into executable code.

Mitigation

2.0.0-beta

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2019-25225
- https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225
- https://github.com/apostrophecms/sanitize-html
- https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3
- https://github.com/apostrophecms/sanitize-html/issues/293
- https://github.com/apostrophecms/sanitize-html/pull/156
- https://nvd.nist.gov/vuln/detail/CVE-2019-25225
- https://www.cve.org/CVERecord?id=CVE-2019-25225

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['CVE-2021-26539']	4099

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

sanitize-html: improper handling of internationalized domain name (IDN) can lead to bypass hostname whitelist validation

Target: Node.js

Type: node-pkg

Fixed version: 2.3.1

Apostrophe Technologies sanitize-html before 2.3.1 does not properly handle internationalized domain name (IDN) which could allow an attacker to bypass hostname whitelist validation set by the "allowedIframeHostnames" option.

Mitigation

2.3.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2021-26539
- https://advisory.checkmarx.net/advisory/CX-2021-4308
- https://github.com/apostrophecms/sanitize-html
- https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22
- https://github.com/apostrophecms/sanitize-html/commit/bdf7836ef8f0e5b21f9a1aab0623ae8fcd09c1da
- https://github.com/apostrophecms/sanitize-html/pull/458
- https://nvd.nist.gov/vuln/detail/CVE-2021-26539
- https://www.cve.org/CVERecord?id=CVE-2021-26539

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['CVE-2021-26540']	4100

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

sanitize-html: improper validation of hostnames set by the "allowedIframeHostnames" option can lead to bypass hostname whitelist for iframe element

Target: Node.js

Type: node-pkg

Fixed version: 2.3.2

Apostrophe Technologies sanitize-html before 2.3.2 does not properly validate the hostnames set by the "allowedIframeHostnames" option when the "allowIframeRelativeUrls" is set to true, which allows attackers to bypass hostname whitelist for iframe element, related using an src value that starts with "/\example.com".

Mitigation

2.3.2

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2021-26540>
- <https://advisory.checkmarx.net/advisory/CX-2021-4309>
- <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26>
- <https://github.com/apostrophecms/sanitize-html/pull/460>
- <https://nvd.nist.gov/vuln/detail/CVE-2021-26540>
- <https://www.cve.org/CVERecord?id=CVE-2021-26540>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	200	['CVE-2024-21501']	4101

Location

Component	Version
sanitize-html	1.4.2

File Path
juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

sanitize-html: Information Exposure when used on the backend

Target: Node.js

Type: node-pkg

Fixed version: 2.12.1

Versions of the package sanitize-html before 2.12.1 are vulnerable to Information Exposure when used on the backend and with the style attribute allowed, allowing enumeration of files in the system (including project dependencies). An attacker could exploit this vulnerability to gather details about the file system structure and dependencies of the targeted server.

Mitigation

2.12.1

Impact

fixed

References

<https://access.redhat.com/security/cve/CVE-2024-21501>

<https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf>

<https://github.com/apostrophecms/apostrophe/discussions/4436>

<https://github.com/apostrophecms/sanitize-html>

<https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4>

<https://github.com/apostrophecms/sanitize-html/pull/650>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7/>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S/>

<https://nvd.nist.gov/vuln/detail/CVE-2024-21501>

<https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>

<https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>

<https://www.cve.org/CVERecord?id=CVE-2024-21501>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-154'] 4102

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

Description

Cross Site Scripting

Target: Node.js

Type: node-pkg

Fixed version: >=1.11.4

Sanitize-html is a library for scrubbing html input of malicious values.

Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios:

If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

PoC:

```
var sanitizeHtml = require('sanitize-html');

var dirty = '<textarea>&lt;/textarea><svg/onload=prompt`xs`&gt;</textarea>!';
var clean = sanitizeHtml(dirty, {
  allowedTags: [ 'textarea' ]
});

console.log(clean);

// <textarea></textarea><svg/onload=prompt`xs`></textarea>!
```

Mitigation

>=1.11.4

Impact

fixed

References

https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403

https://github.com/punkave/sanitize-html/issues/100

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2024-38355']	4103

Location

Component	Version
socket.io	3.1.2
File Path	
juice-shop/node_modules/socket.io/package.json	

Description

socket.io: Unhandled 'error' event

Target: Node.js

Type: node-pkg

Fixed version: 2.5.1, 4.6.2

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. This issue is fixed by commit 15af22fc22 which has been included in socket.io@4.6.2 (released in May 2023). The fix was backported in the 2.x branch as well with commit d30630ba10. Users are advised to upgrade. Users unable to upgrade may attach a listener for the "error" event to catch these errors.

Mitigation

2.5.1, 4.6.2

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2024-38355
- https://github.com/socketio/socket.io
- https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115
- https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c
- https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj
- https://nvd.nist.gov/vuln/detail/CVE-2024-38355
- https://www.cve.org/CVERecord?id=CVE-2024-38355
- https://www.vicarius.io/vsociety/posts/unhandled-exception-in-socketio-cve-2024-38355

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-33151']	4104

Location

Component	Version
socket.io-parser	4.0.5

File Path
juice-shop/node_modules/socket.io-parser/package.json

Description

socket.io: Socket.IO: Denial of Service due to excessive buffering of specially crafted packets

Target: Node.js

Type: node-pkg

Fixed version: 3.3.5, 3.4.4, 4.2.6

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. Prior to versions 3.3.5, 3.4.4, and 4.2.6, a specially crafted Socket.IO packet can make the server wait for a large number of binary attachments and buffer them, which can be exploited to make the server run out of memory. This issue has been patched in versions 3.3.5, 3.4.4, and 4.2.6.

Mitigation

3.3.5, 3.4.4, 4.2.6

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-33151>
- <https://github.com/socketio/socket.io>
- <https://github.com/socketio/socket.io/commit/719f9ebab0772ffb882bd614b387e585c1aa75d4>
- <https://github.com/socketio/socket.io/commit/9d39f1f080510f036782f2177fac701cc041faaf>
- <https://github.com/socketio/socket.io/commit/b25738c416c4e32fbff62ee182afa8f6d0dacf78>
- <https://github.com/socketio/socket.io/security/advisories/GHSA-677m-j7p3-52f9>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-33151>
- <https://www.cve.org/CVERecord?id=CVE-2026-33151>

Images

No images found.

Medium

Finding 253 - CVE-2023-32695 socket.io-parser 4.0.5 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2023-32695']	4105

Location

Component	Version
socket.io-parser	4.0.5
File Path	
juice-shop/node_modules/socket.io-parser/package.json	

Description

socket.io parser is a socket.io encoder and decoder written in JavaScr ...

Target: Node.js

Type: node-pkg

Fixed version: 4.2.3, 3.4.3, 3.3.4

socket.io parser is a socket.io encoder and decoder written in JavaScript complying with version 5 of socket.io-protocol. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. A patch has been released in version 4.2.3.

Mitigation

4.2.3, 3.4.3, 3.3.4

Impact

fixed

References

- https://github.com/socketio/socket.io-parser
- https://github.com/socketio/socket.io-parser/commit/1c220ddbf45ea4b44bc8dbf6f9ae245f672ba1b9
- https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23bled46b02ced
- https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3
- https://github.com/socketio/socket.io-parser/commit/ee006607495eca4ec7262ad080dd3a91439a5ba4
- https://github.com/socketio/socket.io-parser/releases/tag/4.2.3
- https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9
- https://nvd.nist.gov/vuln/detail/CVE-2023-32695

Images

No images found.

High

Finding 254 - CVE-2026-23745 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-23745]	4106

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description
node-tar: tar: node-tar: Arbitrary file overwrite and symlink poisoning via unsanitized linkpaths in archives
Target: Node.js
Type: node-pkg
Fixed version: 7.5.3
node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.
Mitigation
7.5.3
Impact
fixed
References
https://access.redhat.com/errata/RHSA-2026:18868
https://access.redhat.com/security/cve/CVE-2026-23745
https://bugzilla.redhat.com/2425946
https://bugzilla.redhat.com/2430538
https://bugzilla.redhat.com/2431036
https://bugzilla.redhat.com/2431740
https://bugzilla.redhat.com/2433645
https://bugzilla.redhat.com/show_bug.cgi?id=2425946
https://bugzilla.redhat.com/show_bug.cgi?id=2430538
https://bugzilla.redhat.com/show_bug.cgi?id=2431036
https://bugzilla.redhat.com/show_bug.cgi?id=2431740
https://bugzilla.redhat.com/show_bug.cgi?id=2433645
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842
https://errata.almalinux.org/9/ALSA-2026-18868.html
https://errata.rockylinux.org/RLSA-2026:18868
https://github.com/isaacs/node-tar
https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e
https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97
https://nvd.nist.gov/vuln/detail/CVE-2026-23745
https://www.cve.org/CVERecord?id=CVE-2026-23745
Images

Finding 255 - CVE-2026-23950 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	176	[CVE-2026-23950]	4107

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar: tar: node-tar: Arbitrary file overwrite via Unicode path collision race condition

Target: Node.js

Type: node-pkg

Fixed version: 7.5.4

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

7.5.4

Impact

fixed

References

- https://access.redhat.com/errata/RHSA-2026:18868
- https://access.redhat.com/security/cve/CVE-2026-23950
- https://bugzilla.redhat.com/2425946
- https://bugzilla.redhat.com/2430538
- https://bugzilla.redhat.com/2431036
- https://bugzilla.redhat.com/2431740
- https://bugzilla.redhat.com/2433645
- https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

https://errata.almalinux.org/9/ALSA-2026-18868.html

https://errata.rockylinux.org/RLSA-2026:18868

https://github.com/isaacs/node-tar

https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6

https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

https://nvd.nist.gov/vuln/detail/CVE-2026-23950

https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 256 - CVE-2026-24842 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-24842]	4108

Location

Component	Version
tar	4.4.19

File Path
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar: tar: node-tar: Arbitrary file creation via path traversal bypass in hardlink security check

Target: Node.js

Type: node-pkg

Fixed version: 7.5.7

node-tar, a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2026:18868>
- <https://access.redhat.com/security/cve/CVE-2026-24842>
- <https://bugzilla.redhat.com/2425946>
- <https://bugzilla.redhat.com/2430538>
- <https://bugzilla.redhat.com/2431036>
- <https://bugzilla.redhat.com/2431740>
- <https://bugzilla.redhat.com/2433645>
- https://bugzilla.redhat.com/show_bug.cgi?id=2425946
- https://bugzilla.redhat.com/show_bug.cgi?id=2430538
- https://bugzilla.redhat.com/show_bug.cgi?id=2431036
- https://bugzilla.redhat.com/show_bug.cgi?id=2431740
- https://bugzilla.redhat.com/show_bug.cgi?id=2433645
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>
- <https://errata.almalinux.org/9/ALSA-2026-18868.html>
- <https://errata.rockylinux.org/RLSA-2026:18868>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
- <https://www.cve.org/CVERecord?id=CVE-2026-24842>

Images

No images found.

Finding 257 - CVE-2026-26960 Tar 4.4.19 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4109

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar: node-tar: Arbitrary file read/write via malicious archive hardlink creation

Target: Node.js

Type: node-pkg

Fixed version: 7.5.8

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

7.5.8

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-26960>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4ddddc153b0f536a19c050e7499f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>
- <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 258 - CVE-2026-29786 Tar 4.4.19 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4110

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description

node-tar: hardlink path traversal via drive-relative linkpath

Target: Node.js

Type: node-pkg

Fixed version: 7.5.10

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

7.5.10

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-29786
- https://github.com/isaacs/node-tar
- https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f
- https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96
- https://nvd.nist.gov/vuln/detail/CVE-2026-29786
- https://www.cve.org/CVERecord?id=CVE-2026-29786

Images

No images found.

Finding 259 - CVE-2026-31802 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-31802]	4111

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description

tar: tar: File overwrite via drive-relative symlink traversal

Target: Node.js

Type: node-pkg

Fixed version: 7.5.11

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:/.././target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

7.5.11

Impact

fixed

References

<https://access.redhat.com/security/cve/CVE-2026-31802>

<https://github.com/isaacs/node-tar>

<https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>

<https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>

<https://nvd.nist.gov/vuln/detail/CVE-2026-31802>

<https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Medium

Finding 260 - CVE-2024-28863 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2024-28863']	4112

Location

Component	Version
tar	4.4.19

File Path
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

node-tar: denial of service while parsing a tar file due to lack of folders depth validation

Target: Node.js

Type: node-pkg

Fixed version: 6.2.1

node-tar is a Tar for Node.js. node-tar prior to version 6.2.1 has no limit on the number of sub-folders created in the folder creation process. An attacker who generates a large number of sub-folders can consume memory on the system running node-tar and even crash the Node.js client within few seconds of running it using a path with too many sub-folders inside. Version 6.2.1 fixes this issue by preventing extraction in excessively deep sub-folders.

Mitigation

6.2.1

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2024:6147>
- <https://access.redhat.com/security/cve/CVE-2024-28863>
- <https://bugzilla.redhat.com/2293200>
- <https://bugzilla.redhat.com/2296417>
- https://bugzilla.redhat.com/show_bug.cgi?id=2293200
- https://bugzilla.redhat.com/show_bug.cgi?id=2296417
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-22020>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-28863>
- <https://errata.almalinux.org/9/ALSA-2024-6147.html>
- <https://errata.rockylinux.org/RLSA-2024:6147>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7>
- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7> (v6.2.1)
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36>
- <https://linux.oracle.com/cve/CVE-2024-28863.html>
- <https://linux.oracle.com/errata/ELSA-2024-6148.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-28863>
- <https://security.netapp.com/advisory/ntap-20240524-0005>
- <https://security.netapp.com/advisory/ntap-20240524-0005/>
- <https://www.cve.org/CVERecord?id=CVE-2024-28863>

Images

No images found.

High

Finding 261 - CVE-2026-23745 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745']	4113

Location

Component	Version
tar	6.2.1

File Path
juice-shop/node_modules/sqlite3/node_modules/tar/package.json

Description

node-tar: tar: node-tar: Arbitrary file overwrite and symlink poisoning via unsanitized linkpaths in archives

Target: Node.js

Type: node-pkg

Fixed version: 7.5.3

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

7.5.3

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026:18868>

<https://access.redhat.com/security/cve/CVE-2026-23745>

<https://bugzilla.redhat.com/2425946>

<https://bugzilla.redhat.com/2430538>

<https://bugzilla.redhat.com/2431036>

<https://bugzilla.redhat.com/2431740>

<https://bugzilla.redhat.com/2433645>

https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

<https://errata.almalinux.org/9/ALSA-2026-18868.html>

<https://errata.rockylinux.org/RLSA-2026:18868>

<https://github.com/isaacs/node-tar>

https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e

https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97

https://nvd.nist.gov/vuln/detail/CVE-2026-23745

https://www.cve.org/CVERecord?id=CVE-2026-23745

Images

No images found.

Finding 262 - CVE-2026-23950 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	176	['CVE-2026-23950']	4114

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar: tar: node-tar: Arbitrary file overwrite via Unicode path collision race condition

Target: Node.js

Type: node-pkg

Fixed version: 7.5.4

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

7.5.4

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2026:18868

https://access.redhat.com/security/cve/CVE-2026-23950

https://bugzilla.redhat.com/2425946

https://bugzilla.redhat.com/2430538

https://bugzilla.redhat.com/2431036

https://bugzilla.redhat.com/2431740

https://bugzilla.redhat.com/2433645

https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

https://errata.almalinux.org/9/ALSA-2026-18868.html

https://errata.rockylinux.org/RLSA-2026:18868

https://github.com/isaacs/node-tar

https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6

https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

https://nvd.nist.gov/vuln/detail/CVE-2026-23950

https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 263 - CVE-2026-24842 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-24842']	4115

Location

Component	Version
tar	6.2.1

File Path
juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar: tar: node-tar: Arbitrary file creation via path traversal bypass in hardlink security check

Target: Node.js

Type: node-pkg

Fixed version: 7.5.7

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

7.5.7

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2026:18868>
- <https://access.redhat.com/security/cve/CVE-2026-24842>
- <https://bugzilla.redhat.com/2425946>
- <https://bugzilla.redhat.com/2430538>
- <https://bugzilla.redhat.com/2431036>
- <https://bugzilla.redhat.com/2431740>
- <https://bugzilla.redhat.com/2433645>
- https://bugzilla.redhat.com/show_bug.cgi?id=2425946
- https://bugzilla.redhat.com/show_bug.cgi?id=2430538
- https://bugzilla.redhat.com/show_bug.cgi?id=2431036
- https://bugzilla.redhat.com/show_bug.cgi?id=2431740
- https://bugzilla.redhat.com/show_bug.cgi?id=2433645
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>
- <https://errata.almalinux.org/9/ALSA-2026-18868.html>
- <https://errata.rockylinux.org/RLSA-2026:18868>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
- <https://www.cve.org/CVERecord?id=CVE-2026-24842>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.1)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4116

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar: node-tar: Arbitrary file read/write via malicious archive hardlink creation

Target: Node.js

Type: node-pkg

Fixed version: 7.5.8

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

7.5.8

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-26960
- https://github.com/isaacs/node-tar
- https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384
- https://github.com/isaacs/node-tar/commit/d18e4e1f846f4ddddc153b0f536a19c050e7499f
- https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx
- https://nvd.nist.gov/vuln/detail/CVE-2026-26960
- https://www.cve.org/CVERecord?id=CVE-2026-26960

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4117

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

Description

node-tar: hardlink path traversal via drive-relative linkpath

Target: Node.js

Type: node-pkg

Fixed version: 7.5.10

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

7.5.10

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-29786
- https://github.com/isaacs/node-tar
- https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f
- https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96
- https://nvd.nist.gov/vuln/detail/CVE-2026-29786
- https://www.cve.org/CVERecord?id=CVE-2026-29786

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4118

Location	
Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

Description

tar: tar: File overwrite via drive-relative symlink traversal

Target: Node.js

Type: node-pkg

Fixed version: 7.5.11

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:...\../target.txt, which enables file overwrite outside cwd during normal tar x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

7.5.11

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-31802>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-31802>
- <https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Medium

Finding 267 - CVE-2026-41907 Uuid 8.3.2 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-41907']	4119

Location	
Component	Version
uuid	8.3.2
File Path	
juice-shop/node_modules/uuid/package.json	

Description

uuid: uuid: Out-of-bounds write vulnerability impacts data integrity and confidentiality

Target: Node.js

Type: node-pkg

Fixed version: 11.1.1, 12.0.1, 13.0.1

uuid is for the creation of RFC9562 (formerly RFC4122) UUIDs. Prior to 14.0.0, v3, v5, and v6 accept external output buffers but do not reject out-of-range writes (small buf or large offset). This allows silent partial writes into caller-provided buffers. This vulnerability is fixed in 14.0.0.

Mitigation

11.1.1, 12.0.1, 13.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-41907
- https://github.com/uuidjs/uuid
- https://github.com/uuidjs/uuid/commit/32389c887c9e75f90442ee4cc95bbab0c4e8346e
- https://github.com/uuidjs/uuid/commit/3d2c5b0342f0fcb52a5ac681c3d47c13e7444b34
- https://github.com/uuidjs/uuid/commit/3d61d6ac1f782cf6b1dd8661c60f11722cd49a0d
- https://github.com/uuidjs/uuid/commit/9d27ddf7046ce496ef39569ff84d948eeff9cb2a
- https://github.com/uuidjs/uuid/releases/tag/v11.1.1
- https://github.com/uuidjs/uuid/releases/tag/v12.0.1
- https://github.com/uuidjs/uuid/releases/tag/v13.0.1
- https://github.com/uuidjs/uuid/releases/tag/v14.0.0
- https://github.com/uuidjs/uuid/security/advisories/GHSA-w5hq-g745-h8pq
- https://nvd.nist.gov/vuln/detail/CVE-2026-41907
- https://www.cve.org/CVERecord?id=CVE-2026-41907

Images

No images found.

High

Finding 268 - CVE-2024-37890 Ws 7.4.6 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2024-37890']	4120

Location

Component	Version
ws	7.4.6
File Path	
juice-shop/node_modules/engine.io/node_modules/ws/package.json	

Description

nodejs-ws: denial of service when handling a request with many HTTP headers

Target: Node.js

Type: node-pkg

Fixed version: 5.2.4, 6.2.3, 7.5.10, 8.17.1

ws is an open source WebSocket client and server for Node.js. A request with a number of headers exceeding theserver.maxHeadersCount threshold could be used to crash a ws server. The vulnerability was fixed in ws@8.17.1 (e55e510) and backported to ws@7.5.10 (22c2876), ws@6.2.3 (eeb76d3), and ws@5.2.4 (4abd8f6). In vulnerable versions of ws, the issue can be mitigated in the following ways: 1. Reduce the maximum allowed length of the request headers using the --max-http-header-size=size and/or the maxHeaderSize options so that no more headers than the server.maxHeadersCount limit can be sent. 2. Set server.maxHeadersCount to 0 so that no limit is applied.

Mitigation

5.2.4, 6.2.3, 7.5.10, 8.17.1

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2024-37890>
- <https://github.com/websockets/ws>
- <https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f>
- <https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e>
- <https://github.com/websockets/ws/commit/e55e5106f10fcbaac37cfa89759e4cc0d073a52c>
- <https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63>
- <https://github.com/websockets/ws/issues/2230>
- <https://github.com/websockets/ws/pull/2231>
- <https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q>
- <https://nodejs.org/api/http.html#servermaxheaderscount>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-37890>
- <https://www.cve.org/CVERecord?id=CVE-2024-37890>

Images

No images found.

Medium

Finding 269 - CVE-2026-45736 Ws 8.17.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.4)	N.A. / N.A.	Active, Verified	June 7, 2026	0 days	Admin User (admin)	908	['CVE-2026-45736']	4121

Location

Component	Version
ws	8.17.1
File Path	
juice-shop/node_modules/ws/package.json	

CVSS v3

Description

ws is an open source WebSocket client and server for Node.js. Prior to ...

Target: Node.js

Type: node-pkg

Fixed version: 8.20.1

ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.

Mitigation

8.20.1

Impact

fixed

References

- https://github.com/websockets/ws
- https://github.com/websockets/ws/commit/c0327ec15a54d701eb6ccefaa8bef328cfc03086
- https://github.com/websockets/ws/security/advisories/GHSA-58qx-3vcg-4xpx
- https://nvd.nist.gov/vuln/detail/CVE-2026-45736

Images

No images found.

High

Finding 270 - Secret Detected in /juice-shop/build/lib/insecurity.js - Asymmetric Private Key ^{secret}

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4122

Location

Line Number
46
File Path
/juice-shop/build/lib/insecurity.js

Description

Asymmetric Private Key

Category: AsymmetricPrivateKey

Match: ----BEGIN RSA PRIVATE KEY----
_ *****-----END RSA PRIVATE

Images

No images found.

Medium

Finding 271 - Secret Detected in /juice-shop/frontend/src/app/app.guard.spec.ts - JWT Token secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4123

Location

Line Number
46
File Path
/juice-shop/frontend/src/app/app.guard.spec.ts

Description

JWT token

Category: JWT

Match: ocalStorage.setItem('token', '*****')

Images

No images found.

Finding 272 - Secret Detected in /juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts - JWT Token secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4124

Location

Line Number
72
File Path
/juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

JWT token

Category: JWT

Match: ocalStorage.setItem('token', '*****')

Images

No images found.

High

Finding 273 - Secret Detected in /juice-shop/lib/insecurity.ts - Asymmetric Private Key secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	4125

Location

Line Number
23
File Path
/juice-shop/lib/insecurity.ts

Description

Asymmetric Private Key

Category: AsymmetricPrivateKey

Match: ---BEGIN RSA PRIVATE KEY---
_*****-----END RSA PRIVATE

Images

No images found.

Low

Finding 274 - libc6:2.41-12+deb13u2 | CVE-2010-4756

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	399	[CVE-2010-4756]	4126

Description

The glob implementation in the GNU C Library (aka glibc or libc6) allows remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in STAT commands to an FTP daemon, a different vulnerability than CVE-2010-2632.

References

URL: https://avd.aquasec.com/nvd/cve-2010-4756

URL: http://cxib.net/stuff/glob-0day.c

URL: http://securityreason.com/achievement_securityalert/89

URL: http://securityreason.com/exploitalert/9223

URL: https://access.redhat.com/security/cve/CVE-2010-4756

URL: https://bugzilla.redhat.com/show_bug.cgi?id=681681

URL: https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2010-4756

URL: https://nvd.nist.gov/vuln/detail/CVE-2010-4756

URL: https://security.netapp.com/advisory/ntap-20241108-0002/

Images

No images found.

High

Finding 275 - jsonwebtoken:0.1.0 | CVE-2015-9235

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4127

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

Upgrade jsonwebtoken to version 4.2.2

References

URL: <https://avd.aquasec.com/nvd/cve-2015-9235>

URL: <https://access.redhat.com/security/cve/CVE-2015-9235>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>

URL: <https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>

URL: <https://nodesecurity.io/advisories/17>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>

URL: <https://www.cve.org/CVERecord?id=CVE-2015-9235>

URL: <https://www.npmjs.com/advisories/17>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4128

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

Upgrade jsonwebtoken to version 4.2.2

References

URL: <https://avd.aquasec.com/nvd/cve-2015-9235>

URL: <https://access.redhat.com/security/cve/CVE-2015-9235>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>

URL: <https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>

URL: <https://nodesecurity.io/advisories/17>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>

URL: <https://www.cve.org/CVERecord?id=CVE-2015-9235>

URL: <https://www.npmjs.com/advisories/17>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High (8.7)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['CVE-2016-1000223']	4129

CVSS v3

Description

Since "algorithm" isn't enforced in `jws.verify()`, a malicious user could choose what algorithm is sent to the server. If the server is expecting RSA but is sent HMAC-SHA with RSA's public key, the server will think the public key is actually an HMAC private key. This could be used to forge any data an attacker wants.

In addition, there is the none algorithm to be concerned about. In versions prior to 3.0.0, verification of the token could be bypassed when the `alg` field is set to none.

Edit (7/29/16): A previous version of this advisory incorrectly stated that the vulnerability was patched in version 2.0.0 instead of 3.0.0. The advisory has been updated to reflect this new information. Thanks to Fabien Catteau for reporting the error.

Mitigation

Upgrade jws to version >=3.0.0

References

- URL: <https://avd.aquasec.com/nvd/cve-2016-1000223>
- URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>
- URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- URL: <https://github.com/brianloveswords/node-jws>
- URL: <https://github.com/brianloveswords/node-jws/commit/585d0e1e97b6747c10cf5b7689ccc5618a89b299#diff-4ac32a78649ca5bdd8e0ba38b7006a1e>
- URL: <https://nvd.nist.gov/vuln/detail/CVE-2016-1000223>
- URL: <https://snyk.io/vuln/npm:jws:20160726>
- URL: <https://www.npmjs.com/advisories/88>

Images

No images found.

Medium

Finding 278 - sanitize-html:1.4.2 CVE-2016-1000237									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2016-1000237']	4130	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html before 1.4.3 has XSS.

Mitigation

Upgrade sanitize-html to version >=1.4.3

References

URL: <https://avd.aquasec.com/nvd/cve-2016-1000237>

URL: <https://github.com/apostrophecms/sanitize-html/commit/762fbc7bba389f3f789cc291c1eb2b64f60f2caf>

URL: <https://github.com/apostrophecms/sanitize-html/issues/29>

URL: <https://github.com/punkave/sanitize-html/issues/29>

URL: <https://nodesecurity.io/advisories/135>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2016-1000237>

URL: <https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json>

URL: <https://www.npmjs.com/advisories/135>

Images

No images found.

Finding 279 - moment:2.0.0 | CVE-2016-4055

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	400 ['CVE-2016-4055']	4131

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."

Mitigation

Upgrade moment to version >=2.11.2

References

URL: <https://avd.aquasec.com/nvd/cve-2016-4055>

URL: <http://www.openwall.com/lists/oss-security/2016/04/20/11>

URL: <http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>

URL: <http://www.securityfocus.com/bid/95849>

URL: <https://access.redhat.com/security/cve/CVE-2016-4055>

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Sanitize-html is a library for scrubbing html input of malicious values. Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios: If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

Mitigation

Upgrade sanitize-html to version 1.11.4

References

URL: <https://avd.aquasec.com/nvd/cve-2017-16016>

URL: <https://github.com/advisories/GHSA-xc6g-ggrc-qq4r>

URL: <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>

URL: [https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403\)\)\)](https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403))))

URL: <https://github.com/punkave/sanitize-html/issues/100>

URL: <https://nodesecurity.io/advisories/154>

URL: <https://npmjs.com/package/sanitize-html#discarding-the-entire-contents-of-a-disallowed-tag>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2017-16016>

URL: <https://www.npmjs.com/advisories/154>

Images

No images found.

Finding 281 - moment:2.0.0 CVE-2017-18214									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2017-18214']	4133	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.

Mitigation

Upgrade moment to version 2.19.3

References

URL: <https://avd.aquasec.com/nvd/cve-2017-18214>

URL: <https://access.redhat.com/security/cve/CVE-2017-18214>

URL: <https://github.com/advisories/GHSA-446m-mv8f-q348>

URL: <https://github.com/moment/moment>

URL: <https://github.com/moment/moment/commit/69ed9d44957fa6ab12b73d2ae29d286a857b80eb>

URL: <https://github.com/moment/moment/issues/4163>

URL: <https://github.com/moment/moment/pull/4326>

URL: <https://nodesecurity.io/advisories/532>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2017-18214>

URL: <https://ubuntu.com/security/notices/USN-4786-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2017-18214>

URL: <https://www.npmjs.com/advisories/532>

URL: <https://www.tenable.com/security/tns-2019-02>

Images

No images found.

Finding 282 - lodash:2.4.2 CVE-2018-16487									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.6)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2018-16487']	4134	

CVSS v3

CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

A prototype pollution vulnerability was found in lodash <4.17.11 where the functions merge, mergeWith, and defaultsDeep can be tricked into adding or modifying properties of Object.prototype.

Mitigation

Upgrade lodash to version >=4.17.11

References

URL: <https://avd.aquasec.com/nvd/cve-2018-16487>

URL: <https://access.redhat.com/security/cve/CVE-2018-16487>

URL: <https://github.com/advisories/GHSA-4xc9-xhrj-v574>

URL: <https://github.com/lodash/lodash/commit/90e6199a161b6445b01454517b40ef65ebecd2ad>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-16487.yml>

URL: <https://hackerone.com/reports/380873>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2018-16487>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004/>

URL: <https://www.cve.org/CVERecord?id=CVE-2018-16487>

URL: <https://www.npmjs.com/advisories/782>

Images

No images found.

Finding 283 - libc6:2.41-12+deb13u2 CVE-2018-20796									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	674	[CVE-2018-20796]	4135	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '(\227l)(\1\1t\1|\2537)+' in grep.

References

URL: <https://avd.aquasec.com/nvd/cve-2018-20796>

URL: <http://www.securityfocus.com/bid/107160>

URL: <https://access.redhat.com/security/cve/CVE-2018-20796>

URL: <https://debbugs.gnu.org/cgi/bugreport.cgi?bug=34141>

URL: <https://lists.gnu.org/archive/html/bug-gnulib/2019-01/msg00108.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2018-20796>

URL: <https://security.netapp.com/advisory/ntap-20190315-0002/>

URL: https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS

URL: https://www.cve.org/CVERecord?id=CVE-2018-20796

Images

No images found.

Low

Finding 284 - lodash:2.4.2 | CVE-2018-3721

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.9)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	471	['CVE-2018-3721']	4136

CVSS v3

CVSS:3.0/AV:L/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

lodash node module before 4.17.5 suffers from a Modification of Assumed-Immutable Data (MAID) vulnerability via defaultsDeep, merge, and mergeWith functions, which allows a malicious user to modify the prototype of "Object" via **proto**, causing the addition or modification of an existing property that will exist on all objects.

Mitigation

Upgrade lodash to version >=4.17.5

References

URL: https://avd.aquasec.com/nvd/cve-2018-3721

URL: https://access.redhat.com/security/cve/CVE-2018-3721

URL: https://github.com/advisories/GHSA-fvqr-27wr-82fm

URL: https://github.com/lodash/lodash/commit/d8e069cc3410082e44eb18fcf8e7f3d08ebe1d4a

URL: https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-3721.yml

URL: https://hackerone.com/reports/310443

URL: https://nvd.nist.gov/vuln/detail/CVE-2018-3721

URL: https://security.netapp.com/advisory/ntap-20190919-0004

URL: https://security.netapp.com/advisory/ntap-20190919-0004/

URL: https://snyk.io/vuln/npm:lodash:20180130

URL: https://www.cve.org/CVERecord?id=CVE-2018-3721

URL: https://www.npmjs.com/advisories/577

Images

No images found.

Critical

Finding 285 - libc6:2.41-12+deb13u2 CVE-2019-1010022 falls										
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Date Mitigated	Mitigated By	CWE	Vulnerability IDs	Dojo ID
Critical (9.8)	N.A. / N.A.	Inactive, Mitigated, False Positive	June 7, 2026	0 days	Admin User (admin)	June 7, 2026, 1:02 p.m.	Admin User (admin)	119	[CVE-2019-1010022]	4137

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: https://avd.aquasec.com/nvd/cve-2019-1010022

URL: https://access.redhat.com/security/cve/CVE-2019-1010022

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010022

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010022

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22850

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22850#c3

URL: https://ubuntu.com/security/CVE-2019-1010022

URL: https://www.cve.org/CVERecord?id=CVE-2019-1010022

Images

No images found.

Low

Finding 286 - libc6:2.41-12+deb13u2 CVE-2019-1010023										
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs		Dojo ID		
Low (7.8)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	[CVE-2019-1010023]		4138		

CVSS v3

CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

GNU Libc current is affected by: Re-mapping current loaded library with malicious ELF file. The impact is: In worst case attacker may evaluate privileges. The component is: libld. The attack vector is: Attacker sends 2 ELF files to victim and asks to run ldd on it. ldd execute code. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: <https://avd.aquasec.com/nvd/cve-2019-1010023>

URL: <http://www.securityfocus.com/bid/109167>

URL: <https://access.redhat.com/security/cve/CVE-2019-1010023>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2019-1010023>

URL: <https://security-tracker.debian.org/tracker/CVE-2019-1010023>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22851

URL: https://support.f5.com/csp/article/K11932200?utm_source=f5support&utm_medium=RSS

URL: <https://ubuntu.com/security/CVE-2019-1010023>

URL: <https://www.cve.org/CVERecord?id=CVE-2019-1010023>

Images

No images found.

Medium

Finding 287 - libc6:2.41-12+deb13u2 CVE-2019-1010024									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	200	['CVE-2019-1010024']	4139	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass ASLR using cache of thread stack and heap. The component is: glibc. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: <https://avd.aquasec.com/nvd/cve-2019-1010024>

URL: <http://www.securityfocus.com/bid/109162>

URL: <https://access.redhat.com/security/cve/CVE-2019-1010024>

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010024

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010024

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22852

URL: https://support.f5.com/csp/article/K06046097

URL: https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS

URL: https://ubuntu.com/security/CVE-2019-1010024

URL: https://www.cve.org/CVERecord?id=CVE-2019-1010024

Images

No images found.

Low

Finding 288 - libc6:2.41-12+deb13u2 | CVE-2019-1010025

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.9)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	330	['CVE-2019-1010025']	4140

CVSS v3

CVSS:3.0/AV:L/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may guess the heap addresses of pthread_created thread. The component is: glibc. NOTE: the vendor's position is "ASLR bypass itself is not a vulnerability."

References

URL: https://avd.aquasec.com/nvd/cve-2019-1010025

URL: https://access.redhat.com/security/cve/CVE-2019-1010025

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010025

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010025

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22853

URL: https://support.f5.com/csp/article/K06046097

URL: https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS

URL: https://ubuntu.com/security/CVE-2019-1010025

URL: <https://www.cve.org/CVERecord?id=CVE-2019-1010025>

Images

No images found.

High

Finding 289 - lodash:2.4.2 | CVE-2019-10744

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2019-10744']	4141

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked into adding or modifying properties of Object.prototype using a constructor payload.

Mitigation

Upgrade lodash to version 4.17.12

References

URL: <https://avd.aquasec.com/nvd/cve-2019-10744>

URL: <https://access.redhat.com/errata/RHSA-2019:3024>

URL: <https://access.redhat.com/security/cve/CVE-2019-10744>

URL: <https://github.com/advisories/GHSA-jf85-cpcp-j695>

URL: <https://github.com/lodash/lodash/pull/4336>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2019-10744.yml>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2019-10744>

URL: <https://security.netapp.com/advisory/ntap-20191004-0005>

URL: <https://security.netapp.com/advisory/ntap-20191004-0005/>

URL: <https://snyk.io/vuln/SNYK-JS-LODASH-450202>

URL: <https://support.f5.com/csp/article/K47105354>

URL: https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS

URL: https://www.cve.org/CVERecord?id=CVE-2019-10744

URL: https://www.npmjs.com/advisories/1065

URL: https://www.oracle.com/security-alerts/cpujan2021.html

URL: https://www.oracle.com/security-alerts/cpuoct2020.html

Images

No images found.

Medium

Finding 290 - sanitize-html:1.4.2 | CVE-2019-25225

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2019-25225']	4142

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html prior to version 2.0.0-beta is vulnerable to Cross-site Scripting (XSS). The sanitizeHtml() function in index.js does not sanitize content when using the custom transformTags option, which is intended to convert attribute values into text. As a result, malicious input can be transformed into executable code.

Mitigation

Upgrade sanitize-html to version 2.0.0-beta

References

URL: https://avd.aquasec.com/nvd/cve-2019-25225

URL: https://access.redhat.com/security/cve/CVE-2019-25225

URL: https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225

URL: https://github.com/apostrophecms/sanitize-html

URL: https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3

URL: https://github.com/apostrophecms/sanitize-html/issues/293

URL: https://github.com/apostrophecms/sanitize-html/pull/156

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-25225

Images

No images found.

Low

Finding 291 - libc6:2.41-12+deb13u2 | CVE-2019-9192

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.8)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2019-9192']	4143

CVSS v3

CVSS:3.0/AV:L/AC:L/PR:L/UI:R/S:U/C:N/I:N/A:L

Description

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '(\\|\\1)*' in grep, a different issue than CVE-2018-20796. NOTE: the software maintainer disputes that this is a vulnerability because the behavior occurs only with a crafted pattern

References

URL: https://avd.aquasec.com/nvd/cve-2019-9192

URL: https://access.redhat.com/security/cve/CVE-2019-9192

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-9192

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=24269

URL: https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS

URL: https://www.cve.org/CVERecord?id=CVE-2019-9192

Images

No images found.

High

Finding 292 - express-jwt:0.1.3 | CVE-2020-15084 jar xsss

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.1)	N.A. / N.A.	Inactive, Verified	June 7, 2026	0 days	Admin User (admin)	285	['CVE-2020-15084']	4144

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration is not being enforced. When algorithms is not specified in the configuration, with the combination of jwks-rsa, it may lead to authorization bypass. You are affected by this vulnerability if all of the following conditions apply: - You are using express-jwt - You do not have **algorithms** configured in your express-jwt configuration. - You are using libraries such as jwks-rsa as the **secret**. You can fix this by specifying **algorithms** in the express-jwt configuration. See linked GHSA for example. This is also fixed in version 6.0.0.

Mitigation

Upgrade express-jwt to version 6.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2020-15084>

URL: <https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef>

URL: <https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2020-15084>

Images

No images found.

Medium

Finding 293 - lodash.set:4.3.2 CVE-2020-8203								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.4)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	770	['CVE-2020-8203']	4145

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Prototype pollution attack when using _.zipObjectDeep in lodash before 4.17.20.

References

URL: <https://avd.aquasec.com/nvd/cve-2020-8203>

URL: <https://access.redhat.com/security/cve/CVE-2020-8203>

URL: <https://github.com/advisories/GHSA-p6mc-m468-83gw>

URL: <https://github.com/github/advisory-database/pull/2884>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/commit/c84fe82760fb2d3e03a63379b297a1cc1a2fce12>

URL: <https://github.com/lodash/lodash/issues/4744>

URL: <https://github.com/lodash/lodash/issues/4874>

URL: <https://github.com/lodash/lodash/wiki/Changelog#v41719>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2020-8203.yml>

URL: <https://hackerone.com/reports/712065>

URL: <https://hackerone.com/reports/864701>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2020-8203>

URL: <https://security.netapp.com/advisory/ntap-20200724-0006>

URL: <https://security.netapp.com/advisory/ntap-20200724-0006/>

URL: <https://web.archive.org/web/20210914001339/https://github.com/lodash/lodash/issues/4744>

URL: <https://www.cve.org/CVERecord?id=CVE-2020-8203>

URL: <https://www.npmjs.com/advisories/1523>

URL: <https://www.oracle.com//security-alerts/cpujul2021.html>

URL: <https://www.oracle.com/security-alerts/cpuApr2021.html>

URL: <https://www.oracle.com/security-alerts/cpuapr2022.html>

URL: <https://www.oracle.com/security-alerts/cpujan2022.html>

URL: <https://www.oracle.com/security-alerts/cpuoct2021.html>

Images

No images found.

Finding 294 - lodash:2.4.2 | CVE-2021-23337

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.2)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	94	['CVE-2021-23337']	4146

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Description

Lodash versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Mitigation

Upgrade lodash to version 4.17.21

References

URL: <https://avd.aquasec.com/nvd/cve-2021-23337>

URL: <https://access.redhat.com/security/cve/CVE-2021-23337>

URL: <https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf>

URL: <https://github.com/advisories/GHSA-35jh-r3h4-6jhm>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js#L14851>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js%23L14851>

URL: <https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b5a91dde28ba4b1c>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2021-23337.yml>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-23337>

URL: <https://security.netapp.com/advisory/ntap-20210312-0006>

URL: <https://security.netapp.com/advisory/ntap-20210312-0006/>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929>

URL: <https://snyk.io/vuln/SNYK-JS-LODASH-1040724>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-23337>

URL: <https://www.oracle.com//security-alerts/cpujul2021.html>

URL: <https://www.oracle.com/security-alerts/cpujan2022.html>

Images

No images found.

Finding 295 - notevil:1.3.3 CVE-2021-23771								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2021-23771']	4147

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

This affects all versions of package notevil; all versions of package argencoders-notevil. It is vulnerable to Sandbox Escape leading to Prototype pollution. The package fails to restrict access to the main context, allowing an attacker to add or modify an object's prototype. **Note:** This vulnerability derives from an incomplete fix in [SNYK-JS-NOTEVIL-608878](#).

References

URL: <https://avd.aquasec.com/nvd/cve-2021-23771>

URL: <https://github.com/mmckegg/notevil>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>

URL: <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>

URL: <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Images

No images found.

Finding 296 - sanitize-html:1.4.2 CVE-2021-26539								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)		['CVE-2021-26539']	4148

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Apostrophe Technologies sanitize-html before 2.3.1 does not properly handle internationalized domain name (IDN) which could allow an attacker to bypass hostname whitelist validation set by the "allowedIframeHostnames" option.

Mitigation

Upgrade sanitize-html to version 2.3.1

References

URL: <https://avd.aquasec.com/nvd/cve-2021-26539>

URL: <https://access.redhat.com/security/cve/CVE-2021-26539>

URL: <https://advisory.checkmarx.net/advisory/CX-2021-4308>

URL: <https://github.com/apostrophecms/sanitize-html>

URL: <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22>

URL: <https://github.com/apostrophecms/sanitize-html/commit/bdf7836ef8f0e5b21f9a1aab0623ae8fcd09c1da>

URL: <https://github.com/apostrophecms/sanitize-html/pull/458>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-26539>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-26539>

Images

No images found.

Finding 297 - sanitize-html:1.4.2 | CVE-2021-26540

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['CVE-2021-26540']	4149

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Apostrophe Technologies sanitize-html before 2.3.2 does not properly validate the hostnames set by the "allowedIframeHostnames" option when the "allowIframeRelativeUrls" is set to true, which allows attackers to bypass hostname whitelist for iframe element, related using an src value that starts with "\example.com".

Mitigation

Upgrade sanitize-html to version 2.3.2

References

URL: <https://avd.aquasec.com/nvd/cve-2021-26540>

URL: <https://access.redhat.com/security/cve/CVE-2021-26540>

URL: <https://advisory.checkmarx.net/advisory/CX-2021-4309>

URL: <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26>

URL: <https://github.com/apostrophecms/sanitize-html/pull/460>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-26540>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-26540>

Images

No images found.

Finding 298 - jsonwebtoken:0.1.0 | CVE-2022-23539

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (8.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	327	[CVE-2022-23539]	4150

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23539>

URL: <https://access.redhat.com/security/cve/CVE-2022-23539>

URL: <https://github.com/auth0/node-jwebtoken>

URL: <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3>

URL: <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23539>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (8.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	327	['CVE-2022-23539']	4151

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

- URL: <https://avd.aquasec.com/nvd/cve-2022-23539>
- URL: <https://access.redhat.com/security/cve/CVE-2022-23539>
- URL: <https://github.com/auth0/node-jwebtoken>
- URL: <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3>
- URL: <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>
- URL: <https://security.netapp.com/advisory/ntap-20240621-0007>
- URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>
- URL: <https://www.cve.org/CVERecord?id=CVE-2022-23539>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4152

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23540>

URL: <https://access.redhat.com/security/cve/CVE-2022-23540>

URL: <https://github.com/auth0/node-jwebtoken>

URL: <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3>

URL: <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23540>

Images

No images found.

Finding 301 - jsonwebtoken:0.4.0 CVE-2022-23540									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.4)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4153	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2022-23540

URL: https://access.redhat.com/security/cve/CVE-2022-23540

URL: https://github.com/auth0/node-jsonwebtoken

URL: https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

URL: https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-qwph-4952-7xr6

URL: https://nvd.nist.gov/vuln/detail/CVE-2022-23540

URL: https://security.netapp.com/advisory/ntap-20240621-0007

URL: https://security.netapp.com/advisory/ntap-20240621-0007/

URL: https://www.cve.org/CVERecord?id=CVE-2022-23540

Images

No images found.

Finding 302 - jsonwebtoken:0.1.0 | CVE-2022-23541

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4154

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2022-23541

URL: https://access.redhat.com/security/cve/CVE-2022-23541

URL: https://github.com/auth0/node-jsonwebtoken

URL: https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

URL: <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>

URL: <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23541>

Images

No images found.

Finding 303 - jsonwebtoken:0.4.0 | CVE-2022-23541

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4155

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23541>

URL: <https://access.redhat.com/security/cve/CVE-2022-23541>

URL: <https://github.com/auth0/node-jsonwebtoken>

URL: <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>

URL: <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>

URL: <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

URL: https://security.netapp.com/advisory/ntap-20240621-0007

URL: https://security.netapp.com/advisory/ntap-20240621-0007/

URL: https://www.cve.org/CVERecord?id=CVE-2022-23541

Images

No images found.

Finding 304 - moment:2.0.0 | CVE-2022-24785

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2022-24785']	4156

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

Mitigation

Upgrade moment to version 2.29.2

References

URL: https://avd.aquasec.com/nvd/cve-2022-24785

URL: https://access.redhat.com/security/cve/CVE-2022-24785

URL: https://github.com/moment/moment

URL: https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5

URL: https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4

URL: https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q/

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5/

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

URL: <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-24785>

URL: <https://security.netapp.com/advisory/ntap-20220513-0006>

URL: <https://security.netapp.com/advisory/ntap-20220513-0006/>

URL: <https://security.netapp.com/advisory/ntap-20241108-0002>

URL: <https://security.netapp.com/advisory/ntap-20241108-0002/>

URL: <https://ubuntu.com/security/notices/USN-5559-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-24785>

URL: <https://www.tenable.com/security/tns-2022-09>

Images

No images found.

Finding 305 - http-cache-semantics:3.8.1 | CVE-2022-25881

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333	[CVE-2022-25881]	4157

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

This affects versions of the package http-cache-semantics before 4.1.1. The issue can be exploited via malicious request header values sent to a server, when that server reads the cache policy from the request using this library.

Mitigation

Upgrade http-cache-semantics to version 4.1.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-25881>

URL: <https://access.redhat.com/errata/RHSA-2023:2655>

URL: <https://access.redhat.com/security/cve/CVE-2022-25881>

URL: <https://bugzilla.redhat.com/2165824>

URL: <https://bugzilla.redhat.com/2168631>

URL: <https://bugzilla.redhat.com/2171935>

URL: <https://bugzilla.redhat.com/2172190>

URL: <https://bugzilla.redhat.com/2172204>

URL: <https://bugzilla.redhat.com/2172217>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2165824

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2168631

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2171935

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172190

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172204

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172217

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2178076

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-25881>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-4904>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23918>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23920>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23936>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-24807>

URL: <https://errata.almalinux.org/9/ALSA-2023-2655.html>

URL: <https://errata.rockylinux.org/RLSA-2023:2655>

URL: <https://github.com/kornelski/http-cache-semantics>

URL: <https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83>

URL: <https://github.com/kornelski/http-cache-semantics/commit/560b2d8ef452bbba20ffed69dc155d63ac757b74>

URL: <https://linux.oracle.com/cve/CVE-2022-25881.html>

URL: <https://linux.oracle.com/errata/ELSA-2023-2655.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-25881>

URL: <https://security.netapp.com/advisory/ntap-20230622-0008>

URL: <https://security.netapp.com/advisory/ntap-20230622-0008/>

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332>

URL: <https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-25881>

Images

No images found.

Low

Finding 306 - sanitize-html:1.4.2 CVE-2022-25887									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Low (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25887']	4158	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The package sanitize-html before 2.7.1 are vulnerable to Regular Expression Denial of Service (ReDoS) due to insecure global regular expression replacement logic of HTML comment removal.

Mitigation

Upgrade sanitize-html to version 2.7.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-25887>

URL: <https://access.redhat.com/security/cve/CVE-2022-25887>

URL: <https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c>

URL: <https://github.com/apostrophecms/sanitize-html/pull/557>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-25887>

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3008102>

URL: <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-2957526>

URL: <https://ubuntu.com/security/notices/USN-7464-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-25887>

Images

No images found.

Medium

Finding 307 - got:8.3.2 | CVE-2022-33987

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['CVE-2022-33987']	4159

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/IL:A/N

Description

The got package before 12.1.0 (also fixed in 11.8.5) for Node.js allows a redirect to a UNIX socket.

Mitigation

Upgrade got to version 12.1.0, 11.8.5

References

URL: <https://avd.aquasec.com/nvd/cve-2022-33987>

URL: <https://access.redhat.com/errata/RHSA-2022:6595>

URL: <https://access.redhat.com/security/cve/CVE-2022-33987>

URL: <https://bugzilla.redhat.com/1907444>

URL: <https://bugzilla.redhat.com/1945459>

URL: <https://bugzilla.redhat.com/1964461>

URL: <https://bugzilla.redhat.com/2007557>

URL: <https://bugzilla.redhat.com/2098556>

URL: <https://bugzilla.redhat.com/2102001>

URL: <https://bugzilla.redhat.com/2105422>

URL: <https://bugzilla.redhat.com/2105426>

URL: <https://bugzilla.redhat.com/2105428>

URL: <https://bugzilla.redhat.com/2105430>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1907444

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1945459

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1964461

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2007557

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2098556

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2102001

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105422

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105426

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105428

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105430

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2121019

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2124299

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-28469>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-7788>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-33502>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-3807>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-29244>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32212>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32213>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32214>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32215>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-33987>

URL: <https://errata.almalinux.org/9/ALSA-2022-6595.html>

URL: <https://errata.rockylinux.org/RLSA-2022:6595>

URL: <https://github.com/sindresorhus/got>

URL: <https://github.com/sindresorhus/got/commit/861ccd9ac2237df762a9e2beed7edd88c60782dc>

URL: <https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0>

URL: <https://github.com/sindresorhus/got/pull/2047>

URL: <https://github.com/sindresorhus/got/releases/tag/v11.8.5>

URL: <https://github.com/sindresorhus/got/releases/tag/v12.1.0>

URL: <https://linux.oracle.com/cve/CVE-2022-33987.html>

URL: <https://linux.oracle.com/errata/ELSA-2022-6595.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-33987>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-33987>

Images

No images found.

Finding 308 - engine.io:4.1.2 | CVE-2022-41940

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2022-41940']	4160

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

Engine.IO is the implementation of transport-based cross-browser/cross-device bi-directional communication layer for Socket.IO. A specially crafted HTTP request can trigger an uncaught exception on the Engine.IO server, thus killing the Node.js process. This impacts all the users of the engine.io package, including those who uses depending packages like socket.io. There is no known workaround except upgrading to a safe version. There are patches for this issue released in versions 3.6.1 and 6.2.1.

Mitigation

Upgrade engine.io to version 3.6.1, 6.2.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-41940>

URL: <https://access.redhat.com/security/cve/CVE-2022-41940>

URL: <https://github.com/socketio/engine.io>

URL: <https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6>

URL: <https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085>

URL: <https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-41940>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-41940>

Images

No images found.

High

Finding 309 - socket.io-parser:4.0.5 CVE-2023-32695									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2023-32695']	4161	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

socket.io parser is a socket.io encoder and decoder written in JavaScript complying with version 5 of socket.io-protocol. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. A patch has been released in version 4.2.3.

Mitigation

Upgrade socket.io-parser to version 4.2.3, 3.4.3, 3.3.4

References

URL: <https://avd.aquasec.com/nvd/cve-2023-32695>

URL: <https://github.com/socketio/socket.io-parser>

URL: <https://github.com/socketio/socket.io-parser/commit/1c220ddbf45ea4b44bc8dbf6f9ae245f672ba1b9>

URL: <https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23b1ed46b02ced>

URL: <https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3>

URL: <https://github.com/socketio/socket.io-parser/commit/ee006607495eca4ec7262ad080dd3a91439a5ba4>

URL: <https://github.com/socketio/socket.io-parser/releases/tag/4.2.3>

URL: <https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2023-32695>

Images

No images found.

Finding 310 - crypto-js:3.3.0 | CVE-2023-46233

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	328	['CVE-2023-46233']	4162

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

crypto-js is a JavaScript library of crypto standards. Prior to version 4.2.0, crypto-js PBKDF2 is 1,000 times weaker than originally specified in 1993, and at least 1,300,000 times weaker than current industry standard. This is because it both defaults to SHA1, a cryptographic hash algorithm considered insecure since at least 2005, and defaults to one single iteration, a 'strength' or 'difficulty' value specified at 1,000 when specified in 1993. PBKDF2 relies on iteration count as a countermeasure to preimage and collision attacks. If used to protect passwords, the impact is high. If used to generate signatures, the impact is high. Version 4.2.0 contains a patch for this issue. As a workaround, configure crypto-js to use SHA256 with at least 250,000 iterations.

Mitigation

Upgrade crypto-js to version 4.2.0

References

URL: <https://avd.aquasec.com/nvd/cve-2023-46233>

URL: <https://access.redhat.com/security/cve/CVE-2023-46233>

URL: <https://github.com/brix/crypto-js>

URL: <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>

URL: <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>

URL: <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>

URL: <https://ubuntu.com/security/notices/USN-6753-1>

URL: https://www.cve.org/CVERecord?id=CVE-2023-46233

Images

No images found.

Medium

Finding 311 - sanitize-html:1.4.2 | CVE-2024-21501

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	200	['CVE-2024-21501']	4163

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Versions of the package sanitize-html before 2.12.1 are vulnerable to Information Exposure when used on the backend and with the style attribute allowed, allowing enumeration of files in the system (including project dependencies). An attacker could exploit this vulnerability to gather details about the file system structure and dependencies of the targeted server.

Mitigation

Upgrade sanitize-html to version 2.12.1

References

URL: https://avd.aquasec.com/nvd/cve-2024-21501

URL: https://access.redhat.com/security/cve/CVE-2024-21501

URL: https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf

URL: https://github.com/apostrophecms/apostrophe/discussions/4436

URL: https://github.com/apostrophecms/sanitize-html

URL: https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4

URL: https://github.com/apostrophecms/sanitize-html/pull/650

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7/

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S/

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-21501

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>

URL: <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>

URL: <https://www.cve.org/CVERecord?id=CVE-2024-21501>

Images

No images found.

Finding 312 - tar:4.4.19 | CVE-2024-28863

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	400	[CVE-2024-28863]	4164

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

node-tar is a Tar for Node.js. node-tar prior to version 6.2.1 has no limit on the number of sub-folders created in the folder creation process. An attacker who generates a large number of sub-folders can consume memory on the system running node-tar and even crash the Node.js client within few seconds of running it using a path with too many sub-folders inside. Version 6.2.1 fixes this issue by preventing extraction in excessively deep sub-folders.

Mitigation

Upgrade tar to version 6.2.1

References

URL: <https://avd.aquasec.com/nvd/cve-2024-28863>

URL: <https://access.redhat.com/errata/RHSA-2024:6147>

URL: <https://access.redhat.com/security/cve/CVE-2024-28863>

URL: <https://bugzilla.redhat.com/2293200>

URL: <https://bugzilla.redhat.com/2296417>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2293200

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2296417

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-22020>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-28863>

URL: <https://errata.almalinux.org/9/ALSA-2024-6147.html>

URL: https://errata.rockylinux.org/RLSA-2024:6147

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7

URL: https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36

URL: https://linux.oracle.com/cve/CVE-2024-28863.html

URL: https://linux.oracle.com/errata/ELSA-2024-6148.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-28863

URL: https://security.netapp.com/advisory/ntap-20240524-0005

URL: https://security.netapp.com/advisory/ntap-20240524-0005/

URL: https://www.cve.org/CVERecord?id=CVE-2024-28863

Images

No images found.

Finding 313 - ws:7.4.6 | CVE-2024-37890

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2024-37890']	4165

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

ws is an open source WebSocket client and server for Node.js. A request with a number of headers exceeding theserver.maxHeadersCount threshold could be used to crash a ws server. The vulnerability was fixed in ws@8.17.1 (e55e510) and backported to ws@7.5.10 (22c2876), ws@6.2.3 (eeb76d3), and ws@5.2.4 (4abd8f6). In vulnerable versions of ws, the issue can be mitigated in the following ways: 1. Reduce the maximum allowed length of the request headers using the --max-http-header-size=size and/or the maxHeaderSize options so that no more headers than the server.maxHeadersCount limit can be sent. 2. Set server.maxHeadersCount to 0 so that no limit is applied.

Mitigation

Upgrade ws to version 5.2.4, 6.2.3, 7.5.10, 8.17.1

References

URL: https://avd.aquasec.com/nvd/cve-2024-37890

URL: https://access.redhat.com/security/cve/CVE-2024-37890

URL: https://github.com/websockets/ws

URL: https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f

URL: https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e

URL: https://github.com/websockets/ws/commit/e55e5106f10fcbaac37cfa89759e4cc0d073a52c

URL: https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63

URL: https://github.com/websockets/ws/issues/2230

URL: https://github.com/websockets/ws/pull/2231

URL: https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q

URL: https://nodejs.org/api/http.html#servermaxheaderscount

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-37890

URL: https://www.cve.org/CVERecord?id=CVE-2024-37890

Images

No images found.

High

Finding 314 - socket.io:3.1.2 | CVE-2024-38355

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2024-38355']	4166

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. This issue is fixed by commit 15af22fc22 which has been included in socket.io@4.6.2 (released in May 2023). The fix was backported in the 2.x branch as well with commit d30630ba10. Users are advised to upgrade. Users unable to upgrade may attach a listener for the "error" event to catch these errors.

Mitigation

Upgrade socket.io to version 2.5.1, 4.6.2

References

URL: https://avd.aquasec.com/nvd/cve-2024-38355

URL: https://access.redhat.com/security/cve/CVE-2024-38355

URL: <https://github.com/socketio/socket.io>

URL: <https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115>

URL: <https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c>

URL: <https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2024-38355>

URL: <https://www.cve.org/CVERecord?id=CVE-2024-38355>

URL: <https://www.vicarius.io/vsociety/posts/unhandled-exception-in-socketio-cve-2024-38355>

Images

No images found.

Low

Finding 315 - cookie:0.4.2 | CVE-2024-47764

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.7)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	74	['CVE-2024-47764']	4167

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

cookie is a basic HTTP cookie parser and serializer for HTTP servers. The cookie name could be used to set other fields of the cookie, resulting in an unexpected cookie value. A similar escape can be used for path and domain, which could be abused to alter other fields of the cookie. Upgrade to 0.7.0, which updates the validation for name, path, and domain.

Mitigation

Upgrade cookie to version 0.7.0

References

URL: <https://avd.aquasec.com/nvd/cve-2024-47764>

URL: <https://access.redhat.com/security/cve/CVE-2024-47764>

URL: <https://github.com/jshttp/cookie>

URL: <https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c>

URL: <https://github.com/jshttp/cookie/pull/167>

URL: <https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x>

Images

No images found.

High

Finding 316 - multer:1.4.5-lts.2 | CVE-2025-47935

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	401	['CVE-2025-47935']	4168

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal busboy stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2025-47935

URL: https://github.com/expressjs/multer

URL: https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665

URL: https://github.com/expressjs/multer/pull/1120

URL: https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5

URL: https://nvd.nist.gov/vuln/detail/CVE-2025-47935

Images

No images found.

Finding 317 - multer:1.4.5-lts.2 | CVE-2025-47944

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-47944']	4169

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2025-47944>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>

URL: <https://github.com/expressjs/multer/issues/1176>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-47944>

Images

No images found.

Medium

Finding 318 - multer:1.4.5-lts.2 CVE-2025-48997									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	248	[CVE-2025-48997]	4170	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to 2.0.1 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.1

References

URL: <https://avd.aquasec.com/nvd/cve-2025-48997>

URL: <https://access.redhat.com/security/cve/CVE-2025-48997>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9>

URL: https://github.com/expressjs/multer/issues/1233

URL: https://github.com/expressjs/multer/pull/1256

URL: https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qq

URL: https://nvd.nist.gov/vuln/detail/CVE-2025-48997

URL: https://www.cve.org/CVERecord?id=CVE-2025-48997

Images

No images found.

Low

Finding 319 - messageformat:2.3.0 | CVE-2025-57349

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1321	[CVE-2025-57349]	4171

Description

The messageformat package, an implementation of the Unicode MessageFormat 2 specification for JavaScript, is vulnerable to prototype pollution due to improper handling of message key paths in versions prior to 2.3.0. The flaw arises when processing nested message keys containing special characters (e.g., **proto**), which can lead to unintended modification of the JavaScript Object prototype. This vulnerability may allow a remote attacker to inject properties into the global object prototype via specially crafted message input, potentially causing denial of service or other undefined behaviors in applications using the affected component.

Mitigation

Upgrade messageformat to version 3.0.0-beta.0

References

URL: https://avd.aquasec.com/nvd/cve-2025-57349

URL: https://github.com/messageformat/messageformat

URL: https://github.com/messageformat/messageformat/issues/452

URL: https://nvd.nist.gov/vuln/detail/CVE-2025-57349

Images

No images found.

High

Finding 320 - jws:0.2.6 | CVE-2025-65945

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	347	[CVE-2025-65945]	4172

CVSS v3

Description

auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the jws.createVerify() function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Mitigation

Upgrade jws to version 3.2.3, 4.0.1

References

- URL: <https://avd.aquasec.com/nvd/cve-2025-65945>
- URL: <https://access.redhat.com/security/cve/CVE-2025-65945>
- URL: <https://github.com/auth0/node-jws>
- URL: <https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e>
- URL: <https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6>
- URL: <https://github.com/auth0/node-jws/releases/tag/v3.2.3>
- URL: <https://github.com/auth0/node-jws/releases/tag/v4.0.1>
- URL: <https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x>
- URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-65945>
- URL: <https://www.cve.org/CVERecord?id=CVE-2025-65945>

Images

No images found.

Medium

Finding 321 - multer:1.4.5-lts.2 | CVE-2025-7338

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-7338']	4173

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.2

References

URL: <https://avd.aquasec.com/nvd/cve-2025-7338>

URL: <https://access.redhat.com/security/cve/CVE-2025-7338>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-7338>

URL: <https://www.cve.org/CVERecord?id=CVE-2025-7338>

Images

No images found.

High

Finding 322 - multer:1.4.5-lts.2 | CVE-2026-2359

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	772	['CVE-2026-2359']	4174

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by dropping connection during file upload, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.0

References

URL: <https://avd.aquasec.com/nvd/cve-2026-2359>

URL: <https://access.redhat.com/security/cve/CVE-2026-2359>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-2359>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-2359>

Images

No images found.

Finding 323 - tar:4.4.19 CVE-2026-23745									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
High (8.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745']	4175	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Description

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

Upgrade tar to version 7.5.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23745>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23745>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-23745

URL: https://www.cve.org/CVERecord?id=CVE-2026-23745

Images

No images found.

Finding 324 - tar:6.2.1 | CVE-2026-23745

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745']	4176

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Description

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks

and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

Upgrade tar to version 7.5.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23745>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23745>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almalinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-23745>

Images

No images found.

Finding 325 - tar:4.4.19 | CVE-2026-23950

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	176	['CVE-2026-23950']	4177

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, In which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

Upgrade tar to version 7.5.4

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23950>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23950>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almaLinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-23950>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	176	[CVE-2026-23950]	4178

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, In which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

Upgrade tar to version 7.5.4

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23950>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23950>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-23950

URL: https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 327 - tar:4.4.19 | CVE-2026-24842

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-24842']	4179

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Upgrade tar to version 7.5.7

References

URL: https://avd.aquasec.com/nvd/cve-2026-24842

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-24842>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almalinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-24842

URL: https://www.cve.org/CVERecord?id=CVE-2026-24842

Images

No images found.

Finding 328 - tar:6.2.1 | CVE-2026-24842

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-24842]	4180

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Upgrade tar to version 7.5.7

References

URL: https://avd.aquasec.com/nvd/cve-2026-24842

URL: https://access.redhat.com/errata/RHSA-2026:18868

URL: https://access.redhat.com/security/cve/CVE-2026-24842

URL: https://bugzilla.redhat.com/2425946

URL: https://bugzilla.redhat.com/2430538

URL: https://bugzilla.redhat.com/2431036

URL: https://bugzilla.redhat.com/2431740

URL: https://bugzilla.redhat.com/2433645

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-24842

URL: https://www.cve.org/CVERecord?id=CVE-2026-24842

Images

No images found.

Medium

Finding 329 - tar:4.4.19 | CVE-2026-26960

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4181

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

Upgrade tar to version 7.5.8

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26960>

URL: <https://access.redhat.com/security/cve/CVE-2026-26960>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>

URL: <https://github.com/isaacs/node-tar/commit/d18e4elf846f4dddc153b0f536a19c050e7499f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 330 - tar:6.2.1 CVE-2026-26960									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (7.1)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4182	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

Upgrade tar to version 7.5.8

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26960>

URL: <https://access.redhat.com/security/cve/CVE-2026-26960>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>

URL: <https://github.com/isaacs/node-tar/commit/d18e4elf846f4dddc153b0f536a19c050e7499f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 331 - minimatch:3.0.5 | CVE-2026-26996

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-26996']	4183

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate [^/]*? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is O(4^N) where N is the number of * characters. With N=15, a single minimatch() call takes ~2 seconds. With N=34, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.

Mitigation

Upgrade minimatch to version 10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26996>

URL: <https://access.redhat.com/errata/RHSA-2026:7896>

URL: <https://access.redhat.com/security/cve/CVE-2026-26996>

URL: <https://bugzilla.redhat.com/2441268>

URL: <https://bugzilla.redhat.com/2442922>

URL: <https://bugzilla.redhat.com/2448754>

URL: <https://bugzilla.redhat.com/2453151>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2441268

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2442922

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2448754

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453151

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904

URL: https://errata.almalinux.org/9/ALSA-2026-7896.html

URL: https://errata.rockylinux.org/RLSA-2026:7896

URL: https://github.com/isaacs/minimatch

URL: https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5

URL: https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26

URL: https://linux.oracle.com/cve/CVE-2026-26996.html

URL: https://linux.oracle.com/errata/ELSA-2026-8339.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-26996

URL: https://www.cve.org/CVERecord?id=CVE-2026-26996

Images

No images found.

Low

Finding 332 - zlib1g:1:1.3.dfsg+really1.3.1-1+b1 | CVE-2026-27171

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1284	['CVE-2026-27171']	4184

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L

Description

zlib before 1.3.2 allows CPU consumption via crc32_combine64 and crc32_combine_gen64 because x2nmodp can do right shifts within a loop that has no termination condition.

References

URL: https://avd.aquasec.com/nvd/cve-2026-27171

URL: https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit

URL: https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit/

URL: https://7asecurity.com/reports/pentest-report-zlib-RC1.1.pdf

URL: https://access.redhat.com/security/cve/CVE-2026-27171

URL: https://github.com/advisories/GHSA-h858-mf2m-8jf4

URL: https://github.com/madler/zlib/issues/904

URL: https://github.com/madler/zlib/releases/tag/v1.3.2

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-27171

URL: https://ostif.org/zlib-audit-complete

URL: https://ostif.org/zlib-audit-complete/

URL: https://www.cve.org/CVERecord?id=CVE-2026-27171

Images

No images found.

Medium

Finding 333 - minimatch:3.0.5 | CVE-2026-27903

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	407	['CVE-2026-27903']	4185

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Mitigation

Upgrade minimatch to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-27903>

URL: <https://access.redhat.com/security/cve/CVE-2026-27903>

URL: <https://github.com/isaacs/minimatch>

URL: <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-27903>

Images

No images found.

Finding 334 - minimatch:3.0.5 | CVE-2026-27904

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-27904']	4186

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested *() extglobs produce regexps with nested unbounded quantifiers (e.g. (?:a|b)**), which exhibit catastrophic backtracking in V8. With a 12-byte pattern *(?(a|b)) and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects +() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Mitigation

Upgrade minimatch to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

References

URL: <https://avd.aquasec.com/nvd/cve-2026-27904>

URL: <https://access.redhat.com/errata/RHSA-2026:7896>

URL: <https://access.redhat.com/security/cve/CVE-2026-27904>

URL: <https://bugzilla.redhat.com/2441268>

URL: <https://bugzilla.redhat.com/2442922>

URL: <https://bugzilla.redhat.com/2448754>

URL: <https://bugzilla.redhat.com/2453151>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2441268

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2442922

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2448754

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453151

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904>

URL: <https://errata.almalinux.org/9/ALSA-2026-7896.html>

URL: <https://errata.rockylinux.org/RLSA-2026:7896>

URL: <https://github.com/isaacs/minimatch>

URL: <https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>

URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>

URL: <https://linux.oracle.com/cve/CVE-2026-27904.html>

URL: <https://linux.oracle.com/errata/ELSA-2026-8339.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-27904>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-27904>

Images

No images found.

Finding 335 - lodash:2.4.2 | CVE-2026-2950

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2026-2950'] 4187

Description

Impact:

Lodash versions 4.17.23 and earlier are vulnerable to prototype pollution in the `.unset` and `.omit` functions. The fix for (CVE-2025-13465: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>) only guards against string key members, so an attacker can bypass the check by passing array-wrapped path segments. This allows deletion of properties from built-in prototypes such as `Object.prototype`, `Number.prototype`, and `String.prototype`.

The issue permits deletion of prototype properties but does not allow overwriting their original behavior.

Patches:

This issue is patched in 4.18.0.

Workarounds:

None. Upgrade to the patched version.

Mitigation

Upgrade lodash to version 4.18.0

References

URL: <https://avd.aquasec.com/nvd/cve-2026-2950>

URL: <https://access.redhat.com/security/cve/CVE-2026-2950>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh>

URL: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-2950>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-2950>

Images

No images found.

High

Finding 336 - tar:4.4.19 | CVE-2026-29786

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.6)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4188

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:/target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

Upgrade tar to version 7.5.10

References

URL: <https://avd.aquasec.com/nvd/cve-2026-29786>

URL: <https://access.redhat.com/security/cve/CVE-2026-29786>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-29786>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-29786>

Images

No images found.

Finding 337 - tar:6.2.1 | CVE-2026-29786

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.6)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-29786]	4189

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:/target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

Upgrade tar to version 7.5.10

References

URL: <https://avd.aquasec.com/nvd/cve-2026-29786>

URL: <https://access.redhat.com/security/cve/CVE-2026-29786>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-29786>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-29786>

Images

No images found.

Medium

Finding 338 - tar:4.4.19 CVE-2026-31802									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.2)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4190	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:../../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

Upgrade tar to version 7.5.11

References

URL: <https://avd.aquasec.com/nvd/cve-2026-31802>

URL: <https://access.redhat.com/security/cve/CVE-2026-31802>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-31802>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.2)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-31802]	4191

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:../../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

Upgrade tar to version 7.5.11

References

URL: https://avd.aquasec.com/nvd/cve-2026-31802

URL: https://access.redhat.com/security/cve/CVE-2026-31802

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-31802

URL: https://www.cve.org/CVERecord?id=CVE-2026-31802

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	835	[CVE-2026-31808]	4192

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

file-type detects the file type of a file, stream, or data. Prior to 21.3.1, a denial of service vulnerability exists in the ASF (WMV/WMA) file type detection parser. When parsing a crafted input where an ASF sub-header has a size field of zero, the parser enters an infinite loop. The payload value becomes negative (-24), causing tokenizer.ignore(payload) to move the read position backwards, so the same sub-header is read repeatedly forever. Any application that uses file-type to detect the type of untrusted/attacker-controlled input is affected. An attacker can stall the Node.js event loop with a 55-byte payload. Fixed in version 21.3.1.

Mitigation

References

URL: <https://avd.aquasec.com/nvd/cve-2026-31808>

URL: <https://access.redhat.com/security/cve/CVE-2026-31808>

URL: <https://github.com/sindresorhus/file-type>

URL: <https://github.com/sindresorhus/file-type/commit/319abf871b50ba2fa221b4a7050059f1ae096f4f>

URL: <https://github.com/sindresorhus/file-type/security/advisories/GHSA-5v7r-6r5c-r473>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-31808>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-31808>

Images

No images found.

High

Finding 341 - multer:1.4.5-lts.2 | CVE-2026-3304

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	459	[CVE-2026-3304]	4193

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.0

References

URL: <https://avd.aquasec.com/nvd/cve-2026-3304>

URL: <https://access.redhat.com/security/cve/CVE-2026-3304>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-3304>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-3304>

Images

No images found.

Medium

Finding 342 - socket.io-parser:4.0.5 | CVE-2026-33151

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-33151']	4194

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. Prior to versions 3.3.5, 3.4.4, and 4.2.6, a specially crafted Socket.IO packet can make the server wait for a large number of binary attachments and buffer them, which can be exploited to make the server run out of memory. This issue has been patched in versions 3.3.5, 3.4.4, and 4.2.6.

Mitigation

Upgrade socket.io-parser to version 3.3.5, 3.4.4, 4.2.6

References

URL: <https://avd.aquasec.com/nvd/cve-2026-33151>

URL: <https://access.redhat.com/security/cve/CVE-2026-33151>

URL: <https://github.com/socketio/socket.io>

URL: <https://github.com/socketio/socket.io/commit/719f9ebab0772ffb882bd614b387e585c1aa75d4>

URL: <https://github.com/socketio/socket.io/commit/9d39f1f080510f036782f2177fac701cc041faaf>

URL: <https://github.com/socketio/socket.io/commit/b25738c416c4e32fbff62ee182afa8f6d0dacf78>

URL: <https://github.com/socketio/socket.io/security/advisories/GHSA-677m-j7p3-52f9>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-33151>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-33151>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	705	[CVE-2026-3449]	4195

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Versions of the package @tootallnate/once before 3.0.1 are vulnerable to Incorrect Control Flow Scoping in promise resolving when AbortSignal option is used. The Promise remains in a permanently pending state after the signal is aborted, causing any await or .then() usage to hang indefinitely. This can cause a control-flow leak that can lead to stalled requests, blocked workers, or degraded application availability.

Mitigation

Upgrade @tootallnate/once to version 3.0.1, 2.0.1

References

URL: https://avd.aquasec.com/nvd/cve-2026-3449

URL: https://access.redhat.com/security/cve/CVE-2026-3449

URL: https://github.com/TooTallNate/once

URL: https://github.com/TooTallNate/once/commit/b9f43cc5259bee2952d91ad3cdbd201a82df448a

URL: https://github.com/TooTallNate/once/issues/8

URL: https://github.com/TooTallNate/once/releases/tag/v2.0.1

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-3449

URL: https://security.snyk.io/vuln/SNYK-JS-TOOTALLNATEONCE-15250612

URL: https://www.cve.org/CVERecord?id=CVE-2026-3449

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	674	[CVE-2026-3520]	4196

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.1 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing stack overflow. Users should upgrade to version 2.1.1 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.1

References

URL: <https://avd.aquasec.com/nvd/cve-2026-3520>

URL: <https://access.redhat.com/security/cve/CVE-2026-3520>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-3520>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-3520>

Images

No images found.

Medium

Finding 345 - libc6:2.41-12+deb13u2 | CVE-2026-4046

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	617	['CVE-2026-4046']	4197

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The iconv() function in the GNU C Library versions 2.43 and earlier may crash due to an assertion failure when converting inputs from the IBM1390 or IBM1399 character sets, which may be used to remotely crash an application.

This vulnerability can be trivially mitigated by removing the IBM1390 and IBM1399 character sets from systems that do not need them.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-4046>

URL: <https://access.redhat.com/errata/RHSA-2026:20587>

URL: <https://access.redhat.com/security/cve/CVE-2026-4046>

URL: <https://bugzilla.redhat.com/2453117>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438>

URL: <https://errata.almalinux.org/8/ALSA-2026-20587.html>

URL: <https://errata.rockylinux.org/RLSA-2026:20597>

URL: <https://inbox.sourceware.org/libc-announce/76814edf-cf7f-47ec-979d-2dce0a2c76bf@gotpl.org/T/#u>

URL: <https://linux.oracle.com/cve/CVE-2026-4046.html>

URL: <https://linux.oracle.com/errata/ELSA-2026-50291.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-4046>

URL: <https://packages.fedoraproject.org/pkgs/glibc/glibc-gconv-extra/>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=33980

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007;hb=HEAD

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4046>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.8)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	787	[CVE-2026-41907]	4198

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

uuid is for the creation of RFC9562 (formerly RFC4122) UUIDs. Prior to 14.0.0, v3, v5, and v6 accept external output buffers but do not reject out-of-range writes (small buf or large offset). This allows silent partial writes into caller-provided buffers. This vulnerability is fixed in 14.0.0.

Mitigation

Upgrade uuid to version 11.1.1, 12.0.1, 13.0.1

References

URL: https://avd.aquasec.com/nvd/cve-2026-41907

URL: https://access.redhat.com/security/cve/CVE-2026-41907

URL: https://github.com/uuidjs/uuid

URL: https://github.com/uuidjs/uuid/commit/32389c887c9e75f90442ee4cc95bbab0c4e8346e

URL: https://github.com/uuidjs/uuid/commit/3d2c5b0342f0fcb52a5ac681c3d47c13e7444b34

URL: https://github.com/uuidjs/uuid/commit/3d61d6ac1f782cf6b1dd8661c60f11722cd49a0d

URL: https://github.com/uuidjs/uuid/commit/9d27ddf7046ce496ef39569ff84d948eeff9cb2a

URL: https://github.com/uuidjs/uuid/releases/tag/v11.1.1

URL: https://github.com/uuidjs/uuid/releases/tag/v12.0.1

URL: https://github.com/uuidjs/uuid/releases/tag/v13.0.1

URL: https://github.com/uuidjs/uuid/releases/tag/v14.0.0

URL: https://github.com/uuidjs/uuid/security/advisories/GHSA-w5hq-g745-h8pq

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-41907

URL: https://www.cve.org/CVERecord?id=CVE-2026-41907

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	125	[CVE-2026-4437]	4199

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C Library version 2.34 to version 2.43 could, with a crafted response from the configured DNS server, result in a violation of the DNS specification that causes the application to treat a non-answer section of the DNS response as a valid answer.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: https://avd.aquasec.com/nvd/cve-2026-4437

URL: https://access.redhat.com/errata/RHSA-2026:19061

URL: https://access.redhat.com/security/cve/CVE-2026-4437

URL: https://bugzilla.redhat.com/2449777

URL: https://bugzilla.redhat.com/2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438

URL: https://errata.almalinux.org/10/ALSA-2026-19061.html

URL: https://errata.rockylinux.org/RLSA-2026:20597

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-4437

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34014

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4437>

URL: <https://www.openwall.com/lists/oss-security/2026/03/23/2>

Images

No images found.

Low

Finding 348 - libc6:2.41-12+deb13u2 | CVE-2026-4438

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (4.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	20	[CVE-2026-4438]	4200

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C library version 2.34 to version 2.43 could result in an invalid DNS hostname being returned to the caller in violation of the DNS specification.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-4438>

URL: <https://access.redhat.com/errata/RHSA-2026:19061>

URL: <https://access.redhat.com/security/cve/CVE-2026-4438>

URL: <https://bugzilla.redhat.com/2449777>

URL: <https://bugzilla.redhat.com/2449783>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438>

URL: <https://errata.almalinux.org/10/ALSA-2026-19061.html>

URL: <https://errata.rockylinux.org/RLSA-2026-20597>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-4438>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34015

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4438>

URL: <https://www.openwall.com/lists/oss-security/2026/03/23/2>

Images

No images found.

High

Finding 349 - ws:8.17.1 | CVE-2026-45736

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	908	['CVE-2026-45736']	4201

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Description

ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.

Mitigation

Upgrade ws to version 8.20.1

References

URL: <https://avd.aquasec.com/nvd/cve-2026-45736>

URL: <https://github.com/websockets/ws>

URL: <https://github.com/websockets/ws/commit/c0327ec15a54d701eb6ccefaa8bef328cfc03086>

URL: <https://github.com/websockets/ws/security/advisories/GHSA-58qx-3vcg-4xpx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-45736>

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-5435']	4202

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:H

Description

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to enforce the caller-supplied buffer length, and can result in an out-of-bounds write when printing TSIG records.

References

URL: https://avd.aquasec.com/nvd/cve-2026-5435

URL: https://access.redhat.com/security/cve/CVE-2026-5435

URL: https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/

URL: https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-5435

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34033

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0011

URL: https://www.cve.org/CVERecord?id=CVE-2026-5435

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	122	['CVE-2026-5450']	4203

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:H

Description

Calling the scanf family of functions with a %mc (malloc'd character match) in the GNU C Library version 2.7 to version 2.43 with a format width specifier with an explicit width greater than 1024 could result in a one byte heap buffer overflow.

References

URL: https://avd.aquasec.com/nvd/cve-2026-5450

URL: https://access.redhat.com/security/cve/CVE-2026-5450

URL: <https://inbox.sourceware.org/libc-announce/b11f0003-6ec1-4bd6-b9de-9e38a4efeca3@redhat.com/T/#u>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5450>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5450#range-21286997>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=CVE-2026-5450

URL: <https://www.cve.org/CVERecord?id=CVE-2026-5450>

Images

No images found.

Finding 352 - libc6:2.41-12+deb13u2 | CVE-2026-5928

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	127	['CVE-2026-5928']	4204

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:N/A:H

Description

Calling the ungetwc function on a FILE stream with wide characters encoded in a character set that has overlaps between its single byte and multi-byte character encodings, in the GNU C Library version 2.43 or earlier, may result in an attempt to read bytes before an allocated buffer, potentially resulting in unintentional disclosure of neighboring data in the heap, or a program crash.

A bug in the wide character pushback implementation (_IO_wdefault_pbackfail in libio/wgenops.c) causes ungetwc() to operate on the regular character buffer (fp->_IO_read_ptr) instead of the actual wide-stream read pointer (fp->_wide_data->_IO_read_ptr). The program crash may happen in cases where fp->_IO_read_ptr is not initialized and hence points to NULL. The buffer under-read requires a special situation where the input character encoding is such that there are overlaps between single byte representations and multibyte representations in that encoding, resulting in spurious matches. The spurious match case is not possible in the standard Unicode character sets.

References

URL: <https://avd.aquasec.com/nvd/cve-2026-5928>

URL: <https://access.redhat.com/security/cve/CVE-2026-5928>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5928>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=33998

URL: <https://www.cve.org/CVERecord?id=CVE-2026-5928>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	126	['CVE-2026-6238']	4205

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:H

Description

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to validate the RDATA content against the RDATA length in a DNS response when processing LOC, CERT, TKEY or TSIG records, which may allow an attacker to craft a DNS response, causing a target application to crash or read uninitialized memory.

These functions are for application debugging only and hence not in the path of code executed by the DNS resolver. Further, they have been deprecated since version 2.34 and should not be used by any new applications. Applications should consider porting away from these interfaces since they may be removed in future versions.

References

URL: https://avd.aquasec.com/nvd/cve-2026-6238

URL: https://access.redhat.com/security/cve/CVE-2026-6238

URL: https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/

URL: https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-6238

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34069

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0012

URL: https://www.cve.org/CVERecord?id=CVE-2026-6238

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2026-8723']	4206

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Summary

qs.stringify throws TypeError when called with arrayFormat: 'comma' and encodeValuesOnly: true on an array containing null or undefined. The throw is synchronous and not handled by any of qs's null-related options (skipNulls, strictNullHandling).

Details

In the comma + encodeValuesOnly branch, lib/stringify.js:145 mapped the array through the raw encoder before joining:

```
obj = utils.maybeMap(obj, encoder);
```

utils.encode (lib/utils.js:195) reads str.length with no null guard, so a null or undefined element throws TypeError. skipNulls and strictNullHandling are both checked in the per-element loop below this line and never get a chance to run.

Same class of bug as the filter-array path fixed in 0c180a4. The vulnerable shape of the comma + encodeValuesOnly branch was introduced in 4c4b23d ("encode comma values more consistently", PR #463, 2023-01-19), first released in v6.11.1.

PoC

```
const qs = require('qs');
```

```
qs.stringify({ a: [null, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [undefined, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [null] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
// TypeError: Cannot read properties of null (reading 'length')
```

```
//   at encode (lib/utils.js:195:13)
```

```
//   at Object.maybeMap (lib/utils.js:322:37)
```

```
//   at stringify (lib/stringify.js:145:25)
```

Fix

lib/stringify.js:145, applied in 21f80b3 on main and released as v6.15.2:

```
- obj = utils.maybeMap(obj, encoder);
```

```
+ obj = utils.maybeMap(obj, function (v) {
```

```
+   return v == null ? v : encoder(v);
```

+ });

null and undefined now pass through maybeMap unchanged and reach the join(',') step as-is. For { a: [null, 'b'] } this produces a=,b, matching the non-encodeValuesOnly comma path (which already joins before encoding and produces a=%2Cb for the same input). Single-element [null] arrays still collapse via the existing obj.join(',') || null and remain subject to skipNulls / strictNullHandling in the main loop.

Affected versions

>=6.11.1 <6.15.2 – fixed in v6.15.2.

The vulnerable code shape was introduced in 4c4b23d and first shipped in v6.11.1. Earlier versions – including all of 6.7.x, 6.8.x, 6.9.x, 6.10.x, and 6.11.0 – implemented the comma + encodeValuesOnly path differently (joining before encoding) and are not affected. Empirically verified across released versions.

Impact

Application code that calls qs.stringify with both arrayFormat: 'comma' and encodeValuesOnly: true (both non-default) on input that may contain a null or undefined array element will throw synchronously instead of producing a query string. In a typical Node.js HTTP framework (Express, Fastify, Koa, hapi) the sync throw is caught by the framework's error boundary and the affected request returns a 500; the worker process does not exit and subsequent requests are unaffected. The "kills the worker process" framing applies only to call sites outside a request-handler error boundary (background jobs, startup paths, stream pipelines) or to deployments with framework error handling explicitly disabled.

The vulnerable input is a null or undefined entry inside an array; this is reachable from JSON request bodies or from application code constructing arrays from user input, but not from standard HTML form submissions (which produce strings or omitted fields, not literal null).

Mitigation

Upgrade qs to version 6.15.2

References

URL: <https://avd.aquasec.com/nvd/cve-2026-8723>

URL: <https://github.com/ljharb/qs>

URL: <https://github.com/ljharb/qs/commit/21f80b33e5c8b3f7eba1034fff0da4a4a37a1d41>

URL: <https://github.com/ljharb/qs/security/advisories/GHSA-q8mj-m7cp-5q26>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-8723>

Images

No images found.

High

Finding 355 - marsdb:0.6.11 GHSA-5mrr-rgp6-x4gr jar xsss							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Verified	June 7, 2026	0 days	Admin User (admin)	['GHSA-5mrr-rgp6-x4gr']	4207

Description

All versions of marsdb are vulnerable to Command Injection. In the DocumentMatcher class, selectors on \$where clauses are passed to a Function constructor unsanitized. This allows attackers to run arbitrary commands in the system when the function is executed.

Recommendation

No fix is currently available. Consider using an alternative package until a fix is made available.

References

URL: <https://github.com/advisories/GHSA-5mrr-rgp6-x4gr>

URL: <https://github.com/bkimminich/juice-shop/issues/1173>

URL: <https://www.npmjs.com/advisories/1122>

Images

No images found.

Medium

Finding 356 - base64url:0.0.6 GHSA-rvg8-pwq2-xj7q							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['GHSA-rvg8-pwq2-xj7q']	4208

Description

Versions of base64url before 3.0.0 are vulnerable to to out-of-bounds reads as it allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below.

Recommendation

Update to version 3.0.0 or later.

Mitigation

Upgrade base64url to version 3.0.0

References

URL: <https://github.com/advisories/GHSA-rvg8-pwq2-xj7q>

URL: <https://github.com/brianloveswords/base64url>

URL: <https://github.com/brianloveswords/base64url/commit/4fbd954a0a69e9d898de2146557cc6e893e79542>

URL: <https://github.com/brianloveswords/base64url/pull/25>

URL: <https://hackerone.com/reports/321687>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-154']	4209

Description

Sanitize-html is a library for scrubbing html input of malicious values.

Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios:

If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

PoC:

```
var sanitizeHtml = require('sanitize-html');

var dirty = '<textarea>&lt;/textarea><svg/onload=prompt`xs`&gt;</textarea>!';
var clean = sanitizeHtml(dirty, {
  allowedTags: [ 'textarea' ]
});

console.log(clean);

// <textarea></textarea><svg/onload=prompt`xs`></textarea>!
```

Mitigation

Upgrade sanitize-html to version >=1.11.4

References

URL: <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>

URL: <https://github.com/punkave/sanitize-html/issues/100>

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4210

Description

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

Upgrade jsonwebtoken to version >=4.2.2

References

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Finding 359 - jsonwebtoken:0.4.0 | NSWG-ECO-17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4211

Description

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

Upgrade jsonwebtoken to version >=4.2.2

References

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Finding 360 - base64url:0.0.6 | NSWG-ECO-428

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Active	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-428']	4212

Description

base64url allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below

Mitigation

Upgrade base64url to version >=3.0.0

References

URL: <https://hackerone.com/reports/321687>

URL: <https://github.com/brianloveswords/base64url/pull/25>

Images

No images found.

Medium

Finding 361 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4213

Location

Line Number
1
File Path
.semgrepignore

Description

Result message: node_modules/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 362 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4214

Location

Line Number
2
File Path
.semgrepignore

Description

Result message: dist/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 363 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4215

Location	
Line Number	
3	
File Path	
.semgrepignore	

Description

Result message: build/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 364 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4216

Location	
Line Number	
4	
File Path	
.semgrepignore	

Description

Result message: *.min.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 365 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4217

Location	
Line Number	
5	
File Path	
.semgrepignore	

No images found.

Finding 368 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4220

Location

Line Number
8
File Path
..semgrepignore

Description

Result message: frontend/src/assets/private/OrbitControls.js has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 369 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4221

Location

Line Number
9
File Path
..semgrepignore

Description

Result message: data/static/codefixes/ has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 370 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4222

Location

Line Number
10
File Path
.semgrepignore

Description

Result message: *.json has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 371 - Users.ps.semgrep-official.generic.ci.audit.changed-semgrepignore

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4223

Location

Line Number
11
File Path
.semgrepignore

Description

Result message: *.yaml has been added to the .semgrepignore list of ignored paths. Someone from app-sec may want to audit these changes.

References

<https://semgrep.dev/docs/ignoring-files-folders-code/>

Images

No images found.

Finding 372 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116	4224

Location

Line Number
116
File Path
frontend/src/app/about/about.component.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 373 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116	4225
Location							
Line Number							
73							
File Path							
frontend/src/app/administration/administration.component.ts							

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 374 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321	4226
Location							
Line Number							
46							
File Path							
frontend/src/app/app.guard.spec.ts							

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 375 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4227

Location

Line Number
46
File Path
frontend/src/app/app.guard.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 376 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321	4228

Location

Line Number
72
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: JWT token detected

References

https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/

Images

No images found.

Low

Finding 377 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4229

Location

Line Number
72
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 378 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4230

Location

Line Number
78
File Path
frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Medium

Finding 379 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116	4231

Location

Line Number
39
File Path
frontend/src/app/last-login-ip/last-login-ip.component.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 380 - Users.ps.semgrep-official.generic.secrets.security.detected-google-oauth-url

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4232

Location

Line Number
60
File Path
frontend/src/app/login/login.component.ts

Description

Result message: Google OAuth url detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Medium

Finding 381 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	4233

Location

Line Number
17
File Path
frontend/src/app/navbar/navbar.component.html

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss

Images

No images found.

Low

Finding 382 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4234

Location

Line Number
91
File Path
frontend/src/app/oauth/oauth.component.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 383 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4235

Location

Line Number
98
File Path
frontend/src/app/oauth/oauth.component.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 384 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79 4236

Location

Line Number
15
File Path
frontend/src/app/purchase-basket/purchase-basket.component.html

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

<https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss>

Images

No images found.

Finding 385 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4237

Location

Line Number
48
File Path
frontend/src/app/track-result/track-result.component.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 386 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4238

Location

Line Number
76
File Path
frontend/src/app/web3-sandbox/web3-sandbox.component.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 387 - Users.ps.semgrep-official.javascript.lang.security.audit.unsafe-dynamic-method

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	94 4239

Location

Line Number
242
File Path
frontend/src/app/web3-sandbox/web3-sandbox.component.ts

Description

Result message: Using non-static data to retrieve and run functions from the object is dangerous. If the data is user-controlled, it may allow executing arbitrary code.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 388 - Users.ps.semgrep-official.javascript.lang.security.audit.prototype-pollution.prototype-pollution-loop						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	915 4240
Location						
Line Number						
49						
File Path						
frontend/src/hacking-instructor/helpers/helpers.ts						

Description

Result message: Possibility of prototype polluting function detected. By adding or modifying attributes of an object prototype, it is possible to create attributes that exist on every object, or replace critical attributes with malicious ones. This can be problematic if the software depends on existence or non-existence of certain attributes, or uses pre-defined attributes of object prototype (such as hasOwnProperty, toString or valueOf). Possible mitigations might be: freezing the object prototype, using an object without prototypes (via Object.create(null)), blocking modifications of attributes that resolve to object prototype, using Map instead of object.

References

https://github.com/HoLyVieR/prototype-pollution-nsec18/blob/master/paper/JavaScript_prototype_pollution_attack_in_NodeJS.pdf

Images

No images found.

Low

Finding 389 - Users.ps.semgrep-official.javascript.lang.correctness.useless-assignment						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4241
Location						
Line Number						
153						
File Path						
frontend/src/hacking-instructor/helpers/helpers.ts						

Description

Result message: delay is assigned twice; the first assignment is useless

Images

No images found.

High

Finding 390 - Users.ps.semgrep-official.javascript.browser.security.insecure-document-method

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	4242

Location	
Line Number	
126	
File Path	
frontend/src/hacking-instructor/index.ts	

Description

Result message: User controlled data in methods like innerHTML, outerHTML or document.write is an anti-pattern that can lead to XSS vulnerabilities

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 391 - Users.ps.semgrep-official.javascript.browser.security.insecure-innerhtml

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	4243

Location	
Line Number	
126	
File Path	
frontend/src/hacking-instructor/index.ts	

Description

Result message: User controlled data in a textBox.innerHTML is an anti-pattern that can lead to XSS vulnerabilities

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 392 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4244

Location

Line Number
59
File Path
lib/codingChallenges.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 393 - Users.ps.semgrep-official.javascript.lang.security.audit.detect-non-literal-regexp

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333 4245

Location

Line Number
76
File Path
lib/codingChallenges.ts

Description

Result message: RegExp() called with a challengeKey function argument, this might allow an attacker to cause a Regular Expression Denial-of-Service (ReDoS) within your application as RegExP blocks the main thread. For this reason, it is recommended to use hardcoded regexes instead. If your regex is run on user-controlled input, consider performing input validation or use a regex checking/sanitization library such as <https://www.npmjs.com/package/recheck> to verify that the regex does not appear vulnerable to ReDoS.

References

https://owasp.org/www-community/attacks/Regular_expression_Denial_of_Service_-_ReDoS

Images

No images found.

Finding 394 - Users.ps.semgrep-official.javascript.lang.security.audit.detect-non-literal-regexp

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333 4246

Location	
Line Number	
78	
File Path	
lib/codingChallenges.ts	

Description

Result message: RegExp() called with a challengeKey function argument, this might allow an attacker to cause a Regular Expression Denial-of-Service (ReDoS) within your application as RegExP blocks the main thread. For this reason, it is recommended to use hardcoded regexes instead. If your regex is run on user-controlled input, consider performing input validation or use a regex checking/sanitization library such as <https://www.npmjs.com/package/recheck> to verify that the regex does not appear vulnerable to ReDoS.

References

https://owasp.org/www-community/attacks/Regular_expression_Denial_of_Service_-_ReDoS

Images

No images found.

Low

Finding 395 - Users.ps.semgrep-official.generic.secrets.gitleaks.private-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4247

Location	
Line Number	
23	
File Path	
lib/insecurity.ts	

Description

Result message: A gitleaks private-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 396 - Users.ps.semgrep-official.javascript.lang.security.audit.hardcoded-hmac-key						
---	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4248

Location	
Line Number	
44	
File Path	
lib/insecurity.ts	

Description

Result message: Detected a hardcoded hmac key. Avoid hardcoding secrets and consider using an alternate option such as reading the secret from a config file or using an environment variable.

References

- https://rules.sonarsource.com/javascript/RSPEC-2068
- https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html#key-management

Images

No images found.

Finding 397 - Users.ps.semgrep-official.javascript.jsonwebtoken.security.hardcoded-jwt-secret						
---	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4249

Location	
Line Number	
56	
File Path	
lib/insecurity.ts	

Description

Result message: A hard-coded credential was detected. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

- https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 398 - Users.ps.semgrep-official.javascript.lang.security.audit.hardcoded-hmac-key						
---	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4250

Location

Line Number
152
File Path
lib/insecurity.ts

Description

Result message: Detected a hardcoded hmac key. Avoid hardcoding secrets and consider using an alternate option such as reading the secret from a config file or using an environment variable.

References

- <https://rules.sonarsource.com/javascript/RSPEC-2068>
- https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html#key-management

Images

No images found.

Finding 399 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4251

Location

Line Number
84
File Path
lib/startup/customizeApplication.ts

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

- https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 400 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4252

Location	
Line Number	
114	
File Path	
lib/startup/validateConfig.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 401 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4253

Location	
Line Number	
162	
File Path	
lib/startup/validateConfig.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 402 - Users.ps.semgrep-official.javascript.express.security.audit.express-detect-notevil-usage

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1104 4254

Location	
Line Number	
23	
File Path	
routes/b2bOrder.ts	

Description

Result message: Detected usage of the notevil package, which is unmaintained and has vulnerabilities. Using any sort of eval() functionality can be very dangerous, but if you must, the eval package is an up to date alternative. Be sure that only trusted input reaches an eval() function.

References

Images

No images found.

Finding 403 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	95 4255

Location

Line Number
22
File Path
routes/captcha.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 404 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4256

Location

Line Number
216
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 405 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4257

Location	
Line Number	
226	
File Path	
routes/chat.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 406 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4258

Location	
Line Number	
227	
File Path	
routes/chat.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 407 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4259

Location	
Line Number	
228	
File Path	
routes/chat.ts	

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 408 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4260

Location

Line Number
229
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 409 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4261

Location

Line Number
239
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Finding 410 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4262

Location

Line Number
262
File Path
routes/chat.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

High

Finding 411 - Users.ps.semgrep-official.javascript.express.security.audit.remote-property-injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	522	4263

Location

Line Number
31
File Path
routes/currentUser.ts

Description

Result message: Bracket object notation with user input is present, this might allow an attacker to access all properties of the object and even it's prototype. Use literal values for object properties.

References

<https://github.com/nodesecurity/eslint-plugin-security/blob/3c7522ca1be800353513282867a1034c795d9eb4/docs/the-dangers-of-square-bracket-notation.md>

Images

No images found.

Medium

Finding 412 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	73	4264

Location

Line Number
33
File Path
routes/fileServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 413 - Users.ps.semgrep-official.javascript.express.security.audit.express-libxml-vm-noent

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	611	4265

Location

Line Number
83
File Path
routes/fileUpload.ts

Description

Result message: Detected use of parseXml() function with the noent field set to true. This can lead to an XML External Entities (XXE) attack if untrusted data is passed into it.

References

https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html

Images

No images found.

Finding 414 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	73	4266

Location

Line Number
14
File Path
routes/keyServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 415 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	73	4267

Location

Line Number
14
File Path
routes/logfileServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 416 - Users.ps.semgrep-official.javascript.sequelize.security.audit.sequelize-raw-query

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89	4268

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Avoiding SQL string concatenation: untrusted input concatenated with raw SQL query can result in SQL Injection. Data replacement or data binding should be used. See <https://sequelize.org/master/manual/raw-queries.html>

References

<https://sequelize.org/master/manual/raw-queries.html>

Images

No images found.

High

Finding 417 - Users.ps.semgrep-official.javascript.sequelize.security.audit.express-sequelize-injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89	4269

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Detected a sequelize statement that is tainted by user-input. This could lead to SQL injection if the variable is user-controlled and is not properly sanitized. In order to prevent SQL injection, it is recommended to use parameterized queries or prepared statements.

References

<https://sequelize.org/docs/v6/core-concepts/raw-queries/#replacements>

Images

No images found.

Finding 418 - Users.ps.semgrep-official.javascript.express.security.injection.tainted-sql-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89 4270

Location

Line Number
34
File Path
routes/login.ts

Description

Result message: Detected user input used to manually construct a SQL string. This is usually bad practice because manual construction could accidentally result in a SQL injection. An attacker could use a SQL injection to steal or modify contents of the database. Instead, use a parameterized query which is available by default in most database engines. Alternatively, consider using an object-relational mapper (ORM) such as Sequelize which will protect your queries.

References

https://owasp.org/www-community/attacks/SQL_Injection

Images

No images found.

Low

Finding 419 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4271

Location

Line Number
65
File Path
routes/login.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 420 - Users.ps.semgrep-official.javascript.express.security.audit.express-res-sendfile

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	73 4272

Location

Line Number
14
File Path
routes/quarantineServer.ts

Description

Result message: The application processes user-input, this is passed to res.sendFile which can allow an attacker to arbitrarily read files on the system through path traversal. It is recommended to perform input validation in addition to canonicalizing the path. This allows you to validate the path against the intended directory it should be accessing.

References

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Images

No images found.

Finding 421 - Users.ps.semgrep-official.javascript.express.security.audit.unknown-value-in-redirect

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	601 4273

Location	
Line Number	
19	
File Path	
routes/redirect.ts	

Description

Result message: It looks like 'toUrl' is read from user input and it is used to as a redirect. Ensure 'toUrl' is not externally controlled, otherwise this is an open redirect.

References

https://owasp.org/Top10/A01_2021-Broken_Access_Control

Images

No images found.

Finding 422 - Users.ps.semgrep-official.javascript.express.security.audit.express-open-redirect

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	601 4274

Location	
Line Number	
19	
File Path	
routes/redirect.ts	

Description

Result message: The application redirects to a URL specified by user-supplied input query that is not validated. This could redirect users to malicious locations. Consider using an allow-list approach to validate URLs, or warn users they are being redirected to a third-party website.

References

https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

Images

No images found.

Finding 423 - Users.ps.semgrep-official.javascript.sequelize.security.audit.sequelize-raw-query

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89 4275

Location	
Line Number	
23	
File Path	
routes/search.ts	

Description

Result message: Avoiding SQL string concatenation: untrusted input concatenated with raw SQL query can result in SQL Injection. Data replacement or data binding should be used. See <https://sequelize.org/master/manual/raw-queries.html>

References

<https://sequelize.org/master/manual/raw-queries.html>

Images

No images found.

High

Finding 424 - Users.ps.semgrep-official.javascript.sequelize.security.audit.express-sequelize-injection						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89 4276

Location	
Line Number	
23	
File Path	
routes/search.ts	

Description

Result message: Detected a sequelize statement that is tainted by user-input. This could lead to SQL injection if the variable is user-controlled and is not properly sanitized. In order to prevent SQL injection, it is recommended to use parameterized queries or prepared statements.

References

<https://sequelize.org/docs/v6/core-concepts/raw-queries/#replacements>

Images

No images found.

Finding 425 - Users.ps.semgrep-official.javascript.express.security.injection.tainted-sql-string						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89 4277

Location

Line Number
23
File Path
routes/search.ts

Description

Result message: Detected user input used to manually construct a SQL string. This is usually bad practice because manual construction could accidentally result in a SQL injection. An attacker could use a SQL injection to steal or modify contents of the database. Instead, use a parameterized query which is available by default in most database engines. Alternatively, consider using an object-relational mapper (ORM) such as Sequelize which will protect your queries.

References

https://owasp.org/www-community/attacks/SQL_Injection

Images

No images found.

Medium

Finding 426 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	95 4278

Location

Line Number
61
File Path
routes/userProfile.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 427 - Users.ps.semgrep-official.javascript.lang.security.audit.code-string-concat

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	95 4279

Location	
Line Number	
61	
File Path	
routes/userProfile.ts	

Description

Result message: Found data from an Express or Next web request flowing to eval. If this data is user-controllable this can lead to execution of arbitrary system commands in the context of your application process. Avoid eval whenever possible.

References

- https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference/Global_Objects/eval
- https://nodejs.org/api/child_process.html#child_processexeccommand-options-callback
- https://www.stackhawk.com/blog/nodejs-command-injection-examples-and-prevention/
- https://ckarande.gitbooks.io/owasp-nodegoat-tutorial/content/tutorial/a1_-_server_side_js_injection.html

Images

No images found.

Medium

Finding 428 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4280

Location	
Line Number	
213	
File Path	
routes/verify.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

- https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 429 - Users.ps.semgrep-official.javascript.lang.security.audit.unknown-value-with-script-tag						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79 4281

Location

Line Number
57
File Path
routes/videoHandler.ts

Description

Result message: Cannot determine what 'subs' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'subs' is not externally controlled, or sanitize this data.

References

- <https://www.developsec.com/2017/11/09/xss-in-a-script-tag/>
- <https://github.com/juice-shop/juice-shop/blob/1ceb8751e986dacd3214a618c37e7411be6bc11a/routes/videoHandler.ts#L68>

Images

No images found.

Finding 430 - Users.ps.semgrep-official.javascript.lang.security.audit.unknown-value-with-script-tag

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79 4282

Location

Line Number
71
File Path
routes/videoHandler.ts

Description

Result message: Cannot determine what 'subs' is and it is used with a '<script>' tag. This could be susceptible to cross-site scripting (XSS). Ensure 'subs' is not externally controlled, or sanitize this data.

References

- <https://www.developsec.com/2017/11/09/xss-in-a-script-tag/>
- <https://github.com/juice-shop/juice-shop/blob/1ceb8751e986dacd3214a618c37e7411be6bc11a/routes/videoHandler.ts#L68>

Images

No images found.

Low

Finding 431 - Users.ps.semgrep-official.javascript.lang.security.audit.unsafe-formatstring

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	134 4283

Location

Line Number
157
File Path
server.ts

Description

Result message: Detected string concatenation with a non-literal variable in a util.format / console.log function. If an attacker injects a format specifier in the string, it will forge the log message. Try to use constant values for the format string.

References

<https://cwe.mitre.org/data/definitions/134.html>

Images

No images found.

Medium

Finding 432 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	548 4284

Location

Line Number
269
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

<https://www.npmjs.com/package/serve-index>

<https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 433 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	548 4285

Location

Line Number
273
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 434 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	548 4286

Location

Line Number
277
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

Finding 435 - Users.ps.semgrep-official.javascript.express.security.audit.express-check-directory-listing

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	548 4287

Location

Line Number
281
File Path
server.ts

Description

Result message: Directory listing/indexing is enabled, which may lead to disclosure of sensitive directories and files. It is recommended to disable directory listing unless it is a public resource. If you need directory listing, ensure that sensitive files are inaccessible when querying the resource.

References

- <https://www.npmjs.com/package/serve-index>
- <https://www.acunetix.com/blog/articles/directory-listing-information-disclosure/>

Images

No images found.

High

Finding 436 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4288

Location

Line Number
42
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

- https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 437 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4289

Location

Line Number
42
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 438 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4290

Location

Line Number
66
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 439 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4291

Location

Line Number
66
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 440 - Users.ps.semgrep-official.javascript.jsonwebtoken.security.hardcoded-jwt-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4292

Location

Line Number
83
File Path
test/api/2fa.test.ts

Description

Result message: A hard-coded credential was detected. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 441 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4293

Location

Line Number
85
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 442 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4294

Location

Line Number
85
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 443 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4295

Location

Line Number
104
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 444 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4296

Location

Line Number
104
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 445 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4297

Location

Line Number
144
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 446 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4298

Location

Line Number
144
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 447 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4299

Location

Line Number
176
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 448 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4300

Location

Line Number
176
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 449 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4301

Location

Line Number
202
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 450 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4302

Location

Line Number
202
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 451 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4303

Location

Line Number
219
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 452 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4304

Location

Line Number
219
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 453 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4305

Location

Line Number
228
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 454 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4306

Location

Line Number
228
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 455 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID	
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798	4307

Location

Line Number
254
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 456 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4308

Location

Line Number
254
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 457 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4309

Location

Line Number
281
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 458 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4310

Location

Line Number
281
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 459 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4311

Location

Line Number
308
File Path
test/api/2fa.test.ts

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 460 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4312

Location

Line Number
308
File Path
test/api/2fa.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 461 - Users.ps.semgrep-official.javascript.lang.correctness.missing-template-string-indicator

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4313

Location

Line Number
16
File Path
test/api/authenticated-users.test.ts

Description

Result message: This looks like a JavaScript template string. Are you missing a '\$' in front of '{...}'?

Images

No images found.

Medium

Finding 462 - Users.ps.semgrep-official.javascript.lang.correctness.no-stringify-keys

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4314

Location

Line Number
67
File Path
test/api/basket.test.ts

Description

Result message: JSON stringify does not produce a stable key ordering, and should not be relied on for producing object keys. Consider using json-stable-stringify instead.

References

- <https://www.npmjs.com/package/json-stable-stringify>
- <https://stackoverflow.com/a/16168003>

Images

No images found.

Low

Finding 463 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4315

Location

Line Number
110
File Path
test/api/basket.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 464 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4316

Location

Line Number
24
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 465 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4317

Location

Line Number
41
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 466 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4318

Location

Line Number
61
File Path
test/api/data-export.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 467 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4319

Location

Line Number
34
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 468 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4320

Location

Line Number
53
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 469 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4321

Location

Line Number
66
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 470 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4322

Location

Line Number
80
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 471 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4323

Location

Line Number
91
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 472 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4324

Location

Line Number
103
File Path
test/api/erasure-request.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 473 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4325

Location

Line Number
117
File Path
test/api/feedback.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 474 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4326

Location

Line Number
143
File Path
test/api/feedback.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 475 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4327

Location

Line Number
147
File Path
test/api/login.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 476 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4328

Location

Line Number
245
File Path
test/api/login.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 477 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4329

Location

Line Number
267
File Path
test/api/login.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 478 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4330

Location

Line Number
101
File Path
test/api/product-review.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 479 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4331

Location	
Line Number	
115	
File Path	
test/api/product-review.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 480 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4332

Location	
Line Number	
75	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 481 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4333

Location	
Line Number	
86	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 482 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4334

Location	
Line Number	
97	
File Path	
test/api/redirect.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 483 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4335

Location	
Line Number	
47	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 484 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4336

Location	
Line Number	
56	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 485 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4337

Location	
Line Number	
65	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 486 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4338

Location	
Line Number	
74	
File Path	
test/api/search.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 487 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4339

Location	
Line Number	
31	
File Path	
test/api/user-profile.test.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Low

Finding 488 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4340

Location	
Line Number	
240	
File Path	
test/api/user.test.ts	

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 489 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4341

Location

Line Number
280
File Path
test/api/user.test.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 490 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4342

Location

Line Number
280
File Path
test/api/user.test.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 491 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4343

Location

Line Number
289
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 492 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4344

Location

Line Number
304
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Finding 493 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
--	--	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4345

Location

Line Number
318
File Path
test/api/user.test.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 494 - Users.ps.semgrep-official.javascript.browser.security.eval-detected

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	95 4346

Location

Line Number
258
File Path
test/cypress/e2e/contact.spec.ts

Description

Result message: Detected the use of eval(). eval() can be dangerous if used to evaluate dynamic content. If this content can be input from outside the program, this may be a code injection vulnerability. Ensure evaluated content is not definable by external sources.

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 495 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4347

Location

Line Number
7
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 496 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4348

Location

Line Number
7
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 497 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4349

Location

Line Number
22
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 498 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4350

Location

Line Number
22
File Path
test/cypress/e2e/forgedJwt.spec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 499 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4351

Location	
Line Number	
62	
File Path	
test/cypress/e2e/restApi.spec.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 500 - Users.ps.semgrep-official.generic.secrets.security.detected-generic-secret						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4352

Location	
Line Number	
7	
File Path	
test/cypress/e2e/totpSetup.spec.ts	

Description

Result message: Generic Secret detected

References

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures

Images

No images found.

Low

Finding 501 - Users.ps.semgrep-official.generic.secrets.gitleaks.generic-api-key						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4353

Location

Line Number
7
File Path
test/cypress/e2e/totpSetup.spec.ts

Description

Result message: A gitleaks generic-api-key was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module). This rule can introduce a lot of false positives, it is not recommended to be used in PR comments.

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 502 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4354

Location

Line Number
8
File Path
test/files/decrypt.py

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

<https://www.python.org/dev/peps/pep-0597/>

<https://docs.python.org/3/library/functions.html#open>

Images

No images found.

Finding 503 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4355

Location	
Line Number	
14	
File Path	
test/files/decrypt_bruteforce.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- https://www.python.org/dev/peps/pep-0597/
- https://docs.python.org/3/library/functions.html#open

Images

No images found.

High

Finding 504 - Users.ps.semgrep-official.python.lang.best-practice.open-never-closed

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4356

Location	
Line Number	
1	
File Path	
test/files/encrypt.py	

Description

Result message: file object opened without corresponding close

Images

No images found.

Medium

Finding 505 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4357

Location	
Line Number	
1	
File Path	
test/files/encrypt.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- <https://www.python.org/dev/peps/pep-0597/>
- <https://docs.python.org/3/library/functions.html#open>

Images

No images found.

Finding 506 - Users.ps.semgrep-official.python.lang.best-practice.unspecified-open-encoding					
---	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4358

Location	
Line Number	
10	
File Path	
test/files/encrypt.py	

Description

Result message: Missing 'encoding' parameter. 'open()' uses device locale encodings by default, corrupting files with special characters. Specify the encoding to ensure cross-platform support when opening files in text mode (e.g. encoding="utf-8").

References

- <https://www.python.org/dev/peps/pep-0597/>
- <https://docs.python.org/3/library/functions.html#open>

Images

No images found.

High

Finding 507 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token					
---	--	--	--	--	--

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4359

Location

Line Number
33
File Path
test/server/currentUserSpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 508 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4360

Location

Line Number
33
File Path
test/server/currentUserSpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 509 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4361

Location

Line Number
36
File Path
test/server/currentUserSpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 510 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4362

Location

Line Number
36
File Path
test/server/currentUserSpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 511 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4363

Location	
Line Number	
220	
File Path	
test/server/verifySpec.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

Finding 512 - Users.ps.semgrep-official.javascript.lang.security.html-in-template-string

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	116 4364

Location	
Line Number	
243	
File Path	
test/server/verifySpec.ts	

Description

Result message: This template literal looks like HTML and has interpolated variables. These variables are not HTML-encoded by default. If the variables contain HTML tags, these may be interpreted by the browser, resulting in cross-site scripting (XSS).

References

https://owasp.org/Top10/A03_2021-Injection

Images

No images found.

High

Finding 513 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4365

Location

Line Number
263
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 514 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4366

Location

Line Number
263
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 515 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4367

Location

Line Number
275
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/

Images

No images found.

Low

Finding 516 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4368

Location

Line Number
275
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 517 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4369

Location

Line Number
297
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 518 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4370

Location

Line Number
297
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

High

Finding 519 - Users.ps.semgrep-official.generic.secrets.security.detected-jwt-token

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	321 4371

Location

Line Number
309
File Path
test/server/verifySpec.ts

Description

Result message: JWT token detected

References

<https://semgrep.dev/blog/2020/hardcoded-secrets-unverified-tokens-and-other-common-jwt-mistakes/>

Images

No images found.

Low

Finding 520 - Users.ps.semgrep-official.generic.secrets.gitleaks.jwt

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	798 4372

Location

Line Number
309
File Path
test/server/verifySpec.ts

Description

Result message: A gitleaks jwt was detected which attempts to identify hard-coded credentials. It is not recommended to store credentials in source-code, as this risks secrets being leaked and used by either an internal or external malicious adversary. It is recommended to use environment variables to securely provide credentials or retrieve credentials from a secure vault or HSM (Hardware Security Module).

References

https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Images

No images found.

Medium

Finding 521 - Users.ps.semgrep-official.generic.html-templates.security.unquoted-attribute-var

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79 4373

Location	
Line Number	
38	
File Path	
views/dataErasureForm.hbs	

Description

Result message: Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

References

https://flask.palletsprojects.com/en/1.1.x/security/#cross-site-scripting-xss

Images

No images found.

Finding 522 - Users.ps.semgrep-official.javascript.express.security.audit.xss.pug.template-explicit-unescape

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79 4374

Location	
Line Number	
75	
File Path	
views/promotionVideo.pug	

Description

Result message: Detected an explicit unescape in a Pug template, using either '!= ' or '!{...}'. If external data can reach these locations, your application is exposed to a cross-site scripting (XSS) vulnerability. If you must do this, ensure no external data can reach this location.

References

https://pugjs.org/language/code.html#unescaped-buffered-code

https://pugjs.org/language/attributes.html#unescaped-attributes

Images

No images found.

High

Finding 523 - SQL Injection

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	89 4375

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'SQL Injection' on 'http://localhost:3000/rest/products/search'	Active	June 7, 2026	June 7, 2026

Description

SQL injection may be possible.

Mitigation

Do not trust client side input, even if there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param: q
Attack: '('
EndpointQuery: q=%27%28

Response 1

HTTP/1.1 500 Internal Server Error

References

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Images

No images found.

Medium

Finding 524 - Backup File Disclosure

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	530 4376

Vulnerable Endpoints / Systems (31)

Endpoint	Status	Date Discovered	Last Modified
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy%20(3)/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine%20-%20Copy/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.bac'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.backup'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.bak'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.jar'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.log'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.old'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.swp'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.tar'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.zip'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine.~bk'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_linux_amd_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_linux_arm_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_macos_64.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantinebackup/juicy_malware_windows_64.exe.url'	Active	June 7, 2026	June 7, 2026
'Backup File Disclosure' on 'http://localhost:3000/ftp/quarantine~'	Active	June 7, 2026	June 7, 2026

Description

A backup of the file was disclosed by the web server.

Mitigation

Do not edit files in-situ on the web server, and ensure that un-necessary

files (including hidden files) are removed from the web server.

Sample Request(s): Displaying 3 of 31

Request 1

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack: http://localhost:3000/ftp/quarantine%20-%20Copy%20(2)/juicy_malware_linux_amd_64.url
EndpointQuery:
EndpointFragment:

References

https://cwe.mitre.org/data/definitions/530.html

https://owasp.org/www-project-web-security-testing-

guide/v41/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/04-Review_Old_Backup_and_Unreferenced_Files_for_Sensitive_Information.html

Images

No images found.

Finding 525 - Content Security Policy (CSP) Header Not Set

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	693 4377

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/ftp/eastere.gg'	Active	June 7, 2026	June 7, 2026
'Content Security Policy (CSP) Header Not Set' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Content Security Policy (CSP) is an added layer of security that helps to

detect and mitigate certain types of attacks, including Cross Site Scripting

(XSS) and data injection attacks. These attacks are used for everything from

data theft to site defacement or distribution of malware. CSP provides a set

of standard HTTP headers that allow website owners to declare approved sources

of content that browsers should be allowed to load on that page — covered

types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects

such as Java applets, ActiveX, audio and video files.

Mitigation

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- <https://www.w3.org/TR/CSP/>
- <https://w3c.github.io/webappsec-csp/>
- <https://web.dev/articles/csp>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Images

No images found.

Finding 526 - Cross-Domain Misconfiguration						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	264 4378

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Domain Misconfiguration' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/chunk-524KQQJQ.js'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/chunk-UNFVUBM2.js'	Active	June 7, 2026	June 7, 2026
'Cross-Domain Misconfiguration' on 'http://localhost:3000/robots.txt'	Active	June 7, 2026	June 7, 2026

Description

Web browser data loading may be possible, due to a Cross Origin Resource

Sharing (CORS) misconfiguration on the web server.

Mitigation

Ensure that sensitive data is not available in an unauthenticated manner

(using IP address white-listing, for instance).

Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive

set of domains, or remove all CORS headers entirely, to allow the web browser

to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

Access-Control-Allow-Origin: *

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

Access-Control-Allow-Origin: *

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

Access-Control-Allow-Origin: *

References

<https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy>

Images

No images found.

Finding 527 - HTTP Only Site

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	311 4379

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'HTTP Only Site' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The site is only served under HTTP and not HTTPS.

Mitigation

Configure your web or application server to use SSL (https).

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwuLa
EndpointFragment:

References

https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html

https://letsencrypt.org/

Images

No images found.

Finding 528 - Missing Anti-Clickjacking Header

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1021 4380

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Missing Anti-Clickjacking Header' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Mitigation

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Sample Request(s): Displaying 3 of 3

Request 1

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 2

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlac&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 3

Method: POST
Param: x-frame-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwlhE&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Images

No images found.

Finding 529 - Session ID in URL Rewrite						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	598 4381
Vulnerable Endpoints / Systems (1)						
Endpoint		Status	Date Discovered	Last Modified		
'Session ID in URL Rewrite' on 'http://localhost:3000/socket.io/'		Active	June 7, 2026	June 7, 2026		

Description

URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.

Mitigation

For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: sid

Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRv&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 1

nnvG-jZnYstsM_FAAAAO

Request 2

Method: GET
Param: sid
Attack:
EndpointQuery: EIO=4&transport=websocket&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 2

nnvG-jZnYstsM_FAAAAO

Request 3

Method: POST
Param: sid
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Response 3

nnvG-jZnYstsM_FAAAAO

References

<https://seclists.org/webappsec/2002/q4/111>

Images

No images found.

Low

Finding 530 - Cross-Origin-Embedder-Policy Header Missing or Invalid

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	693 4382

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Embedder-Policy Header Missing or Invalid' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).

Mitigation

Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents.

If possible, ensure that the end user uses a standards-compliant and modern

web browser that supports the Cross-Origin-Embedder-Policy header

(https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param: Cross-Origin-Embedder-Policy
Attack:
EndpointQuery:
EndpointFragment:

References

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross->

[Origin-Embedder-Policy](#)

Images

No images found.

Finding 531 - Cross-Origin-Opener-Policy Header Missing or Invalid

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	693 4383

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/ftp'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Cross-Origin-Opener-Policy Header Missing or Invalid' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.

Mitigation

Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents.

'same-origin-allow-popups' is considered as less secured and should be avoided.

If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param: Cross-Origin-Opener-Policy
Attack:
EndpointQuery:
EndpointFragment:

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy

Images

No images found.

Finding 532 - Dangerous JS Functions						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	749 4384
Vulnerable Endpoints / Systems (2)						
Endpoint			Status	Date Discovered	Last Modified	
'Dangerous JS Functions' on 'http://localhost:3000/chunk-GJJPXCX3.js'			Active	June 7, 2026	June 7, 2026	
'Dangerous JS Functions' on 'http://localhost:3000/main.js'			Active	June 7, 2026	June 7, 2026	

Description

A dangerous JS function seems to be in use that would leave the site vulnerable.

Mitigation

See the references for security advice on the use of these functions.

Sample Request(s): Displaying 2 of 2

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

bypassSecurityTrustHtml(

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

bypassSecurityTrustHtml(

References

https://v17.angular.io/guide/security

Images

No images found.

Finding 533 - Deprecated Feature Policy Header Set						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	16 4385

Vulnerable Endpoints / Systems (4)			
Endpoint	Status	Date Discovered	Last Modified
'Deprecated Feature Policy Header Set' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-GNBEOV4E.js'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-PX7UKXVL.js'	Active	June 7, 2026	June 7, 2026
'Deprecated Feature Policy Header Set' on 'http://localhost:3000/chunk-SI2GTEZM.js'	Active	June 7, 2026	June 7, 2026

Description

The header has now been renamed to Permissions-Policy.

Mitigation

Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header instead of the Feature-Policy header.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

Feature-Policy

Request 2

Method: GET
Param:
Attack:
EndpointQuery:

EndpointFragment:

Response 2

Feature-Policy

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

Feature-Policy

References

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy>
- <https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/>

Images

No images found.

Finding 534 - Private IP Disclosure

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	497 4386

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Private IP Disclosure' on 'http://localhost:3000/rest/admin/application-configuration'	Active	June 7, 2026	June 7, 2026

Description

A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.

Mitigation

Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

192.168.99.100:3000

References

Images

No images found.

Finding 535 - Timestamp Disclosure - Unix

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	497 4387

Vulnerable Endpoints / Systems (2)

Endpoint	Status	Date Discovered	Last Modified
'Timestamp Disclosure - Unix' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Timestamp Disclosure - Unix' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

A timestamp was disclosed by the application/web server. - Unix

Mitigation

Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

1666666667

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

1839622642

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

1666666667

References

https://cwe.mitre.org/data/definitions/200.html

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	693 4388

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'X-Content-Type-Options Header Missing' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'.

This allows older versions of Internet Explorer and Chrome to perform MIME-

sniffing on the response body, potentially causing the response body to be

interpreted and displayed as a content type other than the declared content

type. Current (early 2014) and legacy versions of Firefox will use the

declared content type (if one is set), rather than performing MIME-sniffing.

Mitigation

Ensure that the application/web server sets the Content-Type header

appropriately, and that it sets the X-Content-Type-Options header to 'nosniff'

for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern

web browser that does not perform MIME-sniffing at all, or that can be

directed by the web application/web server to not perform MIME-sniffing.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRv&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

Request 2

Method: GET
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIFv
EndpointFragment:

Request 3

Method: POST
Param: x-content-type-options
Attack:
EndpointQuery: EIO=4&transport=polling&t=PwSwIRq&sid=nnvG-jZnYstsM_FAAAAO
EndpointFragment:

References

https://learn.microsoft.com/en-us/previous-versions/windows/internet-

explorer/ie-developer/compatibility/gg622941(v=vs.85)

https://owasp.org/www-community/Security-Headers

Images

No images found.

Info

Finding 537 - Cookie Slack Detector

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	205 4389

Vulnerable Endpoints / Systems (5)

Endpoint	Status	Date Discovered	Last Modified
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/hackingInstructor.png'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/apple_juice.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/apple_pressings.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/assets/public/images/products/artwork2.jpg'	Active	June 7, 2026	June 7, 2026
'Cookie Slack Detector' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

Repeated GET requests: drop a different cookie each time, followed by normal request with all cookies to stabilize session, compare responses against original baseline GET. This can reveal areas where cookie based authentication/attributes are not actually enforced.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

https://cwe.mitre.org/data/definitions/205.html

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4390

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Modern Web Application' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/juice-shop/build/routes/fileServer.js:43:13'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/juice-shop/node_modules/express/lib/router/styles.css'	Active	June 7, 2026	June 7, 2026
'Modern Web Application' on 'http://localhost:3000/sitemap.xml'	Active	June 7, 2026	June 7, 2026

Description

The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

Mitigation

This is an informational alert and so no changes are required.

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

```
<script>
  window.addEventListener('load', function(){
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)', 'text': 'var(--theme-text)' },
        'button': { 'background': 'var(--theme-accent)', 'text': 'var(--theme-text)' }
      },
      'theme': 'classic',
      'position': 'bottom-right',
      'content': { 'message': 'This website uses fruit cookies to ensure you get the juiciest tracking experience.',
'dismiss': 'Me want it!', 'link': 'But me wait!', 'href': 'https://www.youtube.com/watch?v=9PnbKL3wuH4' }
    });
  });
</script>
```

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

```
<script>
  window.addEventListener('load', function(){
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)', 'text': 'var(--theme-text)' },
        'button': { 'background': 'var(--theme-accent)', 'text': 'var(--theme-text)' }
      },
      'theme': 'classic',
      'position': 'bottom-right',
      'content': { 'message': 'This website uses fruit cookies to ensure you get the juiciest tracking experience.',
'dismiss': 'Me want it!', 'link': 'But me wait!', 'href': 'https://www.youtube.com/watch?v=9PnbKL3wuH4' }
    });
  });
</script>
```

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

```
<script>
  window.addEventListener('load', function(){
    window.cookieconsent.initialise({
      'palette': {
        'popup': { 'background': 'var(--theme-primary)', 'text': 'var(--theme-text)' },
        'button': { 'background': 'var(--theme-accent)', 'text': 'var(--theme-text)' }
      },
      'theme': 'classic',
      'position': 'bottom-right',
      'content': { 'message': 'This website uses fruit cookies to ensure you get the juiciest tracking experience.',
        'dismiss': 'Me want it!',
        'link': 'But me wait!',
        'href': 'https://www.youtube.com/watch?v=9PnbKL3wuH4' }
    });
  }
</script>
```

References

Images

No images found.

Finding 539 - Session Management Response Identified

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4391

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Session Management Response Identified' on 'http://localhost:3000/rest/continue-code'	Active	June 7, 2026	June 7, 2026

Description

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Mitigation

This is an informational alert rather than a vulnerability and so there is nothing to fix.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param: continueCode
Attack:
EndpointQuery:
EndpointFragment:

Response 1

continueCode

References

https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Images

No images found.

Finding 540 - Storable and Cacheable Content

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	524 4392

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'Storable and Cacheable Content' on 'http://localhost:3000/robots.txt'	Active	June 7, 2026	June 7, 2026

Description

The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Mitigation

Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

Sample Request(s): Displaying 1 of 1

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

References

https://datatracker.ietf.org/doc/html/rfc7234

https://datatracker.ietf.org/doc/html/rfc7231

https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

Images

No images found.

Finding 541 - Storable but Non-Cacheable Content

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	524 4393

Vulnerable Endpoints / Systems (4)

Endpoint	Status	Date Discovered	Last Modified
'Storable but Non-Cacheable Content' on 'http://localhost:3000'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/assets/public/favicon_js.ico'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/chunk-GNBEOV4E.js'	Active	June 7, 2026	June 7, 2026
'Storable but Non-Cacheable Content' on 'http://localhost:3000/chunk-SI2GTEZM.js'	Active	June 7, 2026	June 7, 2026

Description

The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 1

max-age=0

Request 2

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 2

max-age=0

Request 3

Method: GET
Param:
Attack:
EndpointQuery:
EndpointFragment:

Response 3

max-age=0

References

https://datatracker.ietf.org/doc/html/rfc7234

https://datatracker.ietf.org/doc/html/rfc7231

https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

Images

No images found.

Finding 542 - User Agent Fuzzer

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Info	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4394

Vulnerable Endpoints / Systems (1)

Endpoint	Status	Date Discovered	Last Modified
'User Agent Fuzzer' on 'http://localhost:3000/socket.io/'	Active	June 7, 2026	June 7, 2026

Description

Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Mitigation

Sample Request(s): Displaying 3 of 5

Request 1

Method: GET
Param: Header User-Agent
Attack: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
EndpointQuery: EIO=4&transport=polling&t=PwSwuYN&sid=lgwqBbriKyjtpqgVAAAn
EndpointFragment:

Request 2

Method: GET
Param: Header User-Agent
Attack: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
EndpointQuery: EIO=4&transport=websocket&sid=lgwqBbriKyjtpqgVAAAn
EndpointFragment:

Request 3

Method: GET
Param: Header User-Agent
Attack: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
EndpointQuery: EIO=4&transport=websocket&sid=lgwqBbriKyjtpqgVAAAn
EndpointFragment:

References

Images

No images found.

Medium

Finding 543 - CVE-2026-4046 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	617	[CVE-2026-4046]	4395

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

glibc: glibc: Denial of Service via iconv() function with specific character sets

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

The iconv() function in the GNU C Library versions 2.43 and earlier may crash due to an assertion failure when converting inputs from the IBM1390 or IBM1399 character sets, which may be used to remotely crash an application.

This vulnerability can be trivially mitigated by removing the IBM1390 and IBM1399 character sets from systems that do not need them.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2026:20587

https://access.redhat.com/security/cve/CVE-2026-4046

https://bugzilla.redhat.com/2453117

https://bugzilla.redhat.com/show_bug.cgi?id=2449777

https://bugzilla.redhat.com/show_bug.cgi?id=2449783

https://bugzilla.redhat.com/show_bug.cgi?id=2453117

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438

https://errata.almalinux.org/8/ALSA-2026-20587.html

https://errata.rockylinux.org/RLSA-2026:20597

https://inbox.sourceware.org/libc-announce/76814edf-cf7f-47ec-979d-2dce0a2c76bf@gotpl.org/T/#u

https://linux.oracle.com/cve/CVE-2026-4046.html

https://linux.oracle.com/errata/ELSA-2026-50291.html

https://nvd.nist.gov/vuln/detail/CVE-2026-4046

https://packages.fedoraproject.org/pkgs/glibc/glibc-gconv-extra/

https://sourceware.org/bugzilla/show_bug.cgi?id=33980

https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007

https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007;hb=HEAD

https://www.cve.org/CVERecord?id=CVE-2026-4046

Images

No images found.

Finding 544 - CVE-2026-4437 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	125	['CVE-2026-4437']	4396

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

glibc: glibc: Incorrect DNS response parsing via crafted DNS server response

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C Library version 2.34 to version 2.43 could, with a crafted response from the configured DNS server, result in a violation of the DNS specification that causes the application to treat a non-answer section of the DNS response as a valid answer.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

- https://access.redhat.com/errata/RHSA-2026:19061
- https://access.redhat.com/security/cve/CVE-2026-4437
- https://bugzilla.redhat.com/2449777
- https://bugzilla.redhat.com/2449783
- https://bugzilla.redhat.com/show_bug.cgi?id=2449777
- https://bugzilla.redhat.com/show_bug.cgi?id=2449783
- https://bugzilla.redhat.com/show_bug.cgi?id=2453117
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438
- https://errata.almalinux.org/10/ALSA-2026-19061.html
- https://errata.rockylinux.org/RLSA-2026:20597
- https://nvd.nist.gov/vuln/detail/CVE-2026-4437
- https://sourceware.org/bugzilla/show_bug.cgi?id=34014
- https://www.cve.org/CVERecord?id=CVE-2026-4437
- https://www.openwall.com/lists/oss-security/2026/03/23/2

Images

No images found.

Finding 545 - CVE-2026-5435 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-5435']	4397

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:H

Description

glibc: glibc: Out-of-bounds write via TSIG record processing

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to enforce the caller-supplied buffer length, and can result in an out-of-bounds write when printing TSIG records.

Impact

affected

References

- https://access.redhat.com/security/cve/CVE-2026-5435
- https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/
- https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u
- https://nvd.nist.gov/vuln/detail/CVE-2026-5435
- https://sourceware.org/bugzilla/show_bug.cgi?id=34033
- https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0011
- https://www.cve.org/CVERecord?id=CVE-2026-5435

Images

No images found.

Finding 546 - CVE-2026-5450 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	122	['CVE-2026-5450']	4398

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:H

Description

glibc: glibc: Heap Buffer Overflow in scanf with %mc format specifier and large width

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

Calling the scanf family of functions with a %mc (malloc'd character match) in the GNU C Library version 2.7 to version 2.43 with a format width specifier with an explicit width greater than 1024 could result in a one byte heap buffer overflow.

Impact

affected

References

- https://access.redhat.com/security/cve/CVE-2026-5450
- https://inbox.sourceware.org/libc-announce/b11f0003-6ec1-4bd6-b9de-9e38a4efeca3@redhat.com/T/#u
- https://nvd.nist.gov/vuln/detail/CVE-2026-5450
- https://nvd.nist.gov/vuln/detail/CVE-2026-5450#range-21286997

https://sourceware.org/bugzilla/show_bug.cgi?id=CVE-2026-5450

https://www.cve.org/CVERecord?id=CVE-2026-5450

Images

No images found.

Finding 547 - CVE-2026-5928 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	127 ['CVE-2026-5928']	4399

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:N/A:H

Description

glibc: glibc: Information disclosure or denial of service via ungetwc function with specific wide character encodings

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

Calling the ungetwc function on a FILE stream with wide characters encoded in a character set that has overlaps between its single byte and multi-byte character encodings, in the GNU C Library version 2.43 or earlier, may result in an attempt to read bytes before an allocated buffer, potentially resulting in unintentional disclosure of neighboring data in the heap, or a program crash.

A bug in the wide character pushback implementation (_IO_wdefault_pbackfail in libio/wgenops.c) causes ungetwc() to operate on the regular character buffer (fp->_IO_read_ptr) instead of the actual wide-stream read pointer (fp->_wide_data->_IO_read_ptr). The program crash may happen in cases where fp->_IO_read_ptr is not initialized and hence points to NULL. The buffer under-read requires a special situation where the input character encoding is such that there are overlaps between single byte representations and multibyte representations in that encoding, resulting in spurious matches. The spurious match case is not possible in the standard Unicode character sets.

Impact

affected

References

https://access.redhat.com/security/cve/CVE-2026-5928

https://nvd.nist.gov/vuln/detail/CVE-2026-5928

https://sourceware.org/bugzilla/show_bug.cgi?id=33998

https://www.cve.org/CVERecord?id=CVE-2026-5928

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	126 ['CVE-2026-6238']	4400

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:H

Description

glibc: glibc: Application crash or uninitialized memory read via crafted DNS response

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to validate the RDATA content against the RDATA length in a DNS response when processing LOC, CERT, TKEY or TSIG records, which may allow an attacker to craft a DNS response, causing a target application to crash or read uninitialized memory.

These functions are for application debugging only and hence not in the path of code executed by the DNS resolver. Further, they have been deprecated since version 2.34 and should not be used by any new applications. Applications should consider porting away from these interfaces since they may be removed in future versions.

Impact

affected

References

- <https://access.redhat.com/security/cve/CVE-2026-6238>
- <https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/>
- <https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-6238>
- https://sourceware.org/bugzilla/show_bug.cgi?id=34069
- https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0012
- <https://www.cve.org/CVERecord?id=CVE-2026-6238>

Images

No images found.

Low

Finding 549 - CVE-2010-4756 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	399	['CVE-2010-4756']	4401

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

Description

glibc: glob implementation can cause excessive CPU and memory consumption due to crafted glob expressions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

The glob implementation in the GNU C Library (aka glibc or libc6) allows remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in STAT commands to an FTP daemon, a different vulnerability than CVE-2010-2632.

Impact

affected

References

- http://cxib.net/stuff/glob-0day.c
- http://securityreason.com/achievement_securityalert/89
- http://securityreason.com/exploitalert/9223
- https://access.redhat.com/security/cve/CVE-2010-4756
- https://bugzilla.redhat.com/show_bug.cgi?id=681681
- https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2010-4756
- https://nvd.nist.gov/vuln/detail/CVE-2010-4756
- https://security.netapp.com/advisory/ntap-20241108-0002/
- https://www.cve.org/CVERecord?id=CVE-2010-4756

Images

No images found.

Finding 550 - CVE-2018-20796 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2018-20796']	4402

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

glibc: uncontrolled recursion in function check_dst_limits_calc_pos_1 in posix/regexec.c

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by `'(\227)(\1\1t1\2537)+'` in grep.

Impact

affected

References

- <http://www.securityfocus.com/bid/107160>
- <https://access.redhat.com/security/cve/CVE-2018-20796>
- <https://debbugs.gnu.org/cgi/bugreport.cgi?bug=34141>
- <https://lists.gnu.org/archive/html/bug-gnulib/2019-01/msg00108.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2018-20796>
- <https://security.netapp.com/advisory/ntap-20190315-0002/>
- https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS
- <https://www.cve.org/CVERecord?id=CVE-2018-20796>

Images

No images found.

Finding 551 - CVE-2019-1010022 Libc6 2.41-12+deb13u2 **debian os-pkgs**

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (9.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	119	['CVE-2019-1010022']	4403

Location	
Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

glibc: stack guard protection bypass

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat."

Impact

affected

References

- <https://access.redhat.com/security/cve/CVE-2019-1010022>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010022>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010022>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22850
- https://sourceware.org/bugzilla/show_bug.cgi?id=22850#c3
- <https://ubuntu.com/security/CVE-2019-1010022>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010022>

Images

No images found.

Finding 552 - CVE-2019-1010023 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Low (8.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['CVE-2019-1010023']	4404

Location	
Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

glibc: running ldd on malicious ELF leads to code execution because of wrong size computation

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Re-mapping current loaded library with malicious ELF file. The impact is: In worst case attacker may evaluate privileges. The component is: libld. The attack vector is: Attacker sends 2 ELF files to victim and asks to run ldd on it. ldd execute code. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Impact

affected

References

- <http://www.securityfocus.com/bid/109167>
- <https://access.redhat.com/security/cve/CVE-2019-1010023>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010023>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010023>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22851
- https://support.f5.com/csp/article/K11932200?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010023>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010023>

Images

No images found.

Finding 553 - CVE-2019-1010024 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	200	[CVE-2019-1010024]	4405

Location

Component	Version
libc6	2.41-12+deb13u2

File Path
bkimminich/juice-shop (debian 13.4)

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

glibc: ASLR bypass using cache of thread stack and heap

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass ASLR using cache of thread stack and heap. The component is: glibc. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

Impact

affected

References

- <http://www.securityfocus.com/bid/109162>
- <https://access.redhat.com/security/cve/CVE-2019-1010024>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010024>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010024>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22852
- <https://support.f5.com/csp/article/K06046097>
- https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS
- <https://ubuntu.com/security/CVE-2019-1010024>
- <https://www.cve.org/CVERecord?id=CVE-2019-1010024>

Images

No images found.

Finding 554 - CVE-2019-1010025 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	330	['CVE-2019-1010025']	4406

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

glibc: information disclosure of heap addresses of pthread_created thread

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may guess the heap addresses of pthread_created thread. The component is: glibc. NOTE: the vendor's position is "ASLR bypass itself is not a vulnerability."

Impact

affected

References

- <https://access.redhat.com/security/cve/CVE-2019-1010025>
- <https://nvd.nist.gov/vuln/detail/CVE-2019-1010025>
- <https://security-tracker.debian.org/tracker/CVE-2019-1010025>
- https://sourceware.org/bugzilla/show_bug.cgi?id=22853

https://support.f5.com/csp/article/K06046097

https://support.f5.com/csp/article/K06046097?utm_source=f5support&%3Butm_medium=RSS

https://ubuntu.com/security/CVE-2019-1010025

https://www.cve.org/CVERecord?id=CVE-2019-1010025

Images

No images found.

Finding 555 - CVE-2019-9192 Libc6 2.41-12+deb13u2 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2019-9192']	4407

Location	
Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

glibc: uncontrolled recursion in function check_dst_limits_calc_pos_1 in posix/regexec.c

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '()
(\1\1)*' in grep, a different issue than CVE-2018-20796. NOTE: the software maintainer disputes that this is a vulnerability because the behavior occurs only with a crafted pattern

Impact

affected

References

https://access.redhat.com/security/cve/CVE-2019-9192

https://nvd.nist.gov/vuln/detail/CVE-2019-9192

https://sourceware.org/bugzilla/show_bug.cgi?id=24269

https://support.f5.com/csp/article/K26346590?utm_source=f5support&%3Butm_medium=RSS

https://www.cve.org/CVERecord?id=CVE-2019-9192

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (4.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-4438']	4408

Location

Component	Version
libc6	2.41-12+deb13u2
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

glibc: glibc: Invalid DNS hostname returned via gethostbyaddr functions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version: 2.41-12+deb13u3

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C library version 2.34 to version 2.43 could result in an invalid DNS hostname being returned to the caller in violation of the DNS specification.

Mitigation

2.41-12+deb13u3

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2026:19061

https://access.redhat.com/security/cve/CVE-2026-4438

https://bugzilla.redhat.com/2449777

https://bugzilla.redhat.com/2449783

https://bugzilla.redhat.com/show_bug.cgi?id=2449777

https://bugzilla.redhat.com/show_bug.cgi?id=2449783

https://bugzilla.redhat.com/show_bug.cgi?id=2453117

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438

https://errata.almalinux.org/10/ALSA-2026-19061.html

https://errata.rockylinux.org/RLSA-2026:20597

https://nvd.nist.gov/vuln/detail/CVE-2026-4438

https://sourceware.org/bugzilla/show_bug.cgi?id=34015

Images

No images found.

Medium

Finding 557 - CVE-2026-27171 Zlib1g 1:1.3.dfsg+really1.3.1-1+b1 debian os-pkgs

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1284	['CVE-2026-27171']	4409

Location

Component	Version
zlib1g	1:1.3.dfsg+really1.3.1-1+b1
File Path	
bkimminich/juice-shop (debian 13.4)	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

zlib: zlib: Denial of Service via infinite loop in CRC32 combine functions

Target: bkimminich/juice-shop (debian 13.4)

Type: debian

Fixed version:

zlib before 1.3.2 allows CPU consumption via crc32_combine64 and crc32_combine_gen64 because x2nmodp can do right shifts within a loop that has no termination condition.

Impact

affected

References

https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit

https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit/

https://7asecurity.com/reports/pentest-report-zlib-RC1.1.pdf

https://access.redhat.com/security/cve/CVE-2026-27171

https://github.com/advisories/GHSA-h858-mf2m-8jf4

https://github.com/madler/zlib/issues/904

https://github.com/madler/zlib/releases/tag/v1.3.2

https://nvd.nist.gov/vuln/detail/CVE-2026-27171

https://ostif.org/zlib-audit-complete

https://ostif.org/zlib-audit-complete/

https://www.cve.org/CVERecord?id=CVE-2026-27171

Images

No images found.

Low

Finding 558 - CVE-2026-3449 @Tootallnate/Once 1.1.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	705	[CVE-2026-3449]	4410

Location

Component	Version
@tootallnate/once	1.1.2
File Path	
juice-shop/node_modules/@tootallnate/once/package.json	

Description

@tootallnate/once: @tootallnate/once: Denial of Service due to incorrect control flow scoping with AbortSignal

Target: Node.js

Type: node-pkg

Fixed version: 3.0.1, 2.0.1

Versions of the package @tootallnate/once before 3.0.1 are vulnerable to Incorrect Control Flow Scoping in promise resolving when AbortSignal option is used. The Promise remains in a permanently pending state after the signal is aborted, causing any await or .then() usage to hang indefinitely. This can cause a control-flow leak that can lead to stalled requests, blocked workers, or degraded application availability.

Mitigation

3.0.1, 2.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-3449
- https://github.com/TooTallNate/once
- https://github.com/TooTallNate/once/commit/b9f43cc5259bee2952d91ad3cdbd201a82df448a
- https://github.com/TooTallNate/once/issues/8
- https://github.com/TooTallNate/once/releases/tag/v2.0.1
- https://nvd.nist.gov/vuln/detail/CVE-2026-3449
- https://security.snyk.io/vuln/SNYK-JS-TOOTALLNATEONCE-15250612
- https://www.cve.org/CVERecord?id=CVE-2026-3449

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-428']	4411

Location

Component	Version
base64url	0.0.6
File Path	
juice-shop/node_modules/base64url/package.json	

Description

Out-of-bounds Read

Target: Node.js

Type: node-pkg

Fixed version: >=3.0.0

base64url allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below

Mitigation

>=3.0.0

Impact

fixed

References

https://github.com/brianloveswords/base64url/pull/25

https://hackerone.com/reports/321687

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['GHSA-rvg8-pwq2-xj7q']	4412

Location

Component	Version
base64url	0.0.6
File Path	
juice-shop/node_modules/base64url/package.json	

Description

Out-of-bounds Read in base64url

Target: Node.js

Type: node-pkg

Fixed version: 3.0.0

Versions of base64url before 3.0.0 are vulnerable to to out-of-bounds reads as it allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below.

Recommendation

Update to version 3.0.0 or later.

Mitigation

3.0.0

Impact

fixed

References

https://github.com/brianloveswords/base64url

https://github.com/brianloveswords/base64url/commit/4fbd954a0a69e9d898de2146557cc6e893e79542

https://github.com/brianloveswords/base64url/pull/25

https://hackerone.com/reports/321687

Images

No images found.

Low

Finding 561 - CVE-2024-47764 Cookie 0.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.7)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	74	[CVE-2024-47764]	4413

Location

Component	Version
cookie	0.4.2

File Path
juice-shop/node_modules/engine.io/node_modules/cookie/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

cookie: cookie accepts cookie name, path, and domain with out of bounds characters

Target: Node.js

Type: node-pkg

Fixed version: 0.7.0

cookie is a basic HTTP cookie parser and serializer for HTTP servers. The cookie name could be used to set other fields of the cookie, resulting in an unexpected cookie value. A similar escape can be used for path and domain, which could be abused to alter other fields of the cookie. Upgrade to 0.7.0, which updates the validation for name, path, and domain.

Mitigation

0.7.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2024-47764
- https://github.com/jshttp/cookie
- https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c
- https://github.com/jshttp/cookie/pull/167
- https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x
- https://nvd.nist.gov/vuln/detail/CVE-2024-47764
- https://www.cve.org/CVERecord?id=CVE-2024-47764

Images

No images found.

Critical

Finding 562 - CVE-2023-46233 Crypto-Js 3.3.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	328	['CVE-2023-46233']	4414

Location

Component	Version
crypto-js	3.3.0

File Path
juice-shop/node_modules/crypto-js/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

crypto-js: PBKDF2 1,000 times weaker than specified in 1993 and 1.3M times weaker than current standard

Target: Node.js

Type: node-pkg

Fixed version: 4.2.0

crypto-js is a JavaScript library of crypto standards. Prior to version 4.2.0, crypto-js PBKDF2 is 1,000 times weaker than originally specified in 1993, and at

least 1,300,000 times weaker than current industry standard. This is because it both defaults to SHA1, a cryptographic hash algorithm considered insecure since at least 2005, and defaults to one single iteration, a 'strength' or 'difficulty' value specified at 1,000 when specified in 1993. PBKDF2 relies on iteration count as a countermeasure to preimage and collision attacks. If used to protect passwords, the impact is high. If used to generate signatures, the impact is high. Version 4.2.0 contains a patch for this issue. As a workaround, configure crypto-js to use SHA256 with at least 250,000 iterations.

Mitigation

4.2.0

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2023-46233>
- <https://github.com/brix/crypto-js>
- <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>
- <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>
- <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>
- <https://ubuntu.com/security/notices/USN-6753-1>
- <https://www.cve.org/CVERecord?id=CVE-2023-46233>

Images

No images found.

Medium

Finding 563 - CVE-2022-41940 engine.io 4.1.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2022-41940']	4415

Location

Component	Version
engine.io	4.1.2
File Path	
juice-shop/node_modules/engine.io/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

engine.io: Specially crafted HTTP request can trigger an uncaught exception

Target: Node.js

Type: node-pkg

Fixed version: 3.6.1, 6.2.1

Engine.IO is the implementation of transport-based cross-browser/cross-device bi-directional communication layer for Socket.IO. A specially crafted HTTP request can trigger an uncaught exception on the Engine.IO server, thus killing the Node.js process. This impacts all the users of the engine.io package, including those who uses depending packages like socket.io. There is no known workaround except upgrading to a safe version. There are patches for this

Mitigation

3.6.1, 6.2.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-41940
- https://github.com/socketio/engine.io
- https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6
- https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085
- https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w
- https://nvd.nist.gov/vuln/detail/CVE-2022-41940
- https://www.cve.org/CVERecord?id=CVE-2022-41940

Images

No images found.

High

Finding 564 - CVE-2020-15084 Express-JWT 0.1.3 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.7)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	285	[CVE-2020-15084]	4416

Location

Component	Version
express-jwt	0.1.3
File Path	
juice-shop/node_modules/express-jwt/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Description

Authorization bypass in express-jwt

Target: Node.js

Type: node-pkg

Fixed version: 6.0.0

In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration is not being enforced. When algorithms is not specified in the configuration, with the combination of jwks-rsa, it may lead to authorization bypass. You are affected by this vulnerability if all of the following conditions apply: - You are using express-jwt - You do not have **algorithms** configured in your express-jwt configuration. - You are using libraries such as jwks-rsa as the **secret**. You can fix this by specifying **algorithms** in the express-jwt configuration. See linked GHSA for example. This is also fixed in version 6.0.0.

Mitigation

Impact

fixed

References

https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef

https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf

https://nvd.nist.gov/vuln/detail/CVE-2020-15084

Images

No images found.

Medium

Finding 565 - CVE-2026-31808 File-Type 16.5.4 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	835	['CVE-2026-31808']	4417

Location

Component	Version
file-type	16.5.4

File Path
juice-shop/node_modules/file-type/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

file-type: file-type: Denial of Service due to infinite loop in ASF file parsing

Target: Node.js

Type: node-pkg

Fixed version: 21.3.1

file-type detects the file type of a file, stream, or data. Prior to 21.3.1, a denial of service vulnerability exists in the ASF (WMV/WMA) file type detection parser. When parsing a crafted input where an ASF sub-header has a size field of zero, the parser enters an infinite loop. The payload value becomes negative (-24), causing tokenizer.ignore(payload) to move the read position backwards, so the same sub-header is read repeatedly forever. Any application that uses file-type to detect the type of untrusted/attacker-controlled input is affected. An attacker can stall the Node.js event loop with a 55-byte payload. Fixed in version 21.3.1.

Mitigation

21.3.1

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2026-31808

https://github.com/sindresorhus/file-type

https://github.com/sindresorhus/file-type/commit/319abf871b50ba2fa221b4a7050059f1ae096f4f

https://github.com/sindresorhus/file-type/security/advisories/GHSA-5v7r-6r5c-r473

https://nvd.nist.gov/vuln/detail/CVE-2026-31808

https://www.cve.org/CVERecord?id=CVE-2026-31808

Images

No images found.

Finding 566 - CVE-2022-33987 Got 8.3.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['CVE-2022-33987']	4418

Location	
Component	Version
got	8.3.2
File Path	
juice-shop/node_modules/got/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

nodejs-got: missing verification of requested URLs allows redirects to UNIX sockets

Target: Node.js

Type: node-pkg

Fixed version: 12.1.0, 11.8.5

The got package before 12.1.0 (also fixed in 11.8.5) for Node.js allows a redirect to a UNIX socket.

Mitigation

12.1.0, 11.8.5

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2022:6595

https://access.redhat.com/security/cve/CVE-2022-33987

https://bugzilla.redhat.com/1907444

https://bugzilla.redhat.com/1945459

https://bugzilla.redhat.com/1964461

https://bugzilla.redhat.com/2007557

https://bugzilla.redhat.com/2098556

https://bugzilla.redhat.com/2102001

<https://bugzilla.redhat.com/2105422>

<https://bugzilla.redhat.com/2105426>

<https://bugzilla.redhat.com/2105428>

<https://bugzilla.redhat.com/2105430>

https://bugzilla.redhat.com/show_bug.cgi?id=1907444

https://bugzilla.redhat.com/show_bug.cgi?id=1945459

https://bugzilla.redhat.com/show_bug.cgi?id=1964461

https://bugzilla.redhat.com/show_bug.cgi?id=2007557

https://bugzilla.redhat.com/show_bug.cgi?id=2098556

https://bugzilla.redhat.com/show_bug.cgi?id=2102001

https://bugzilla.redhat.com/show_bug.cgi?id=2105422

https://bugzilla.redhat.com/show_bug.cgi?id=2105426

https://bugzilla.redhat.com/show_bug.cgi?id=2105428

https://bugzilla.redhat.com/show_bug.cgi?id=2105430

https://bugzilla.redhat.com/show_bug.cgi?id=2121019

https://bugzilla.redhat.com/show_bug.cgi?id=2124299

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-28469>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-7788>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-33502>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-3807>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-29244>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32212>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32213>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32214>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32215>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-33987>

<https://errata.almalinux.org/9/ALSA-2022-6595.html>

<https://errata.rockylinux.org/RLSA-2022:6595>

<https://github.com/sindresorhus/got>

<https://github.com/sindresorhus/got/commit/861ccd9ac2237df762a9e2beed7edd88c60782dc>

<https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0>

<https://github.com/sindresorhus/got/pull/2047>

<https://github.com/sindresorhus/got/releases/tag/v11.8.5>

<https://github.com/sindresorhus/got/releases/tag/v12.1.0>

<https://linux.oracle.com/cve/CVE-2022-33987.html>

<https://linux.oracle.com/errata/ELSA-2022-6595.html>

<https://nvd.nist.gov/vuln/detail/CVE-2022-33987>

<https://www.cve.org/CVERecord?id=CVE-2022-33987>

Images

No images found.

High

Finding 567 - CVE-2022-25881 HTTP-Cache-Semantics 3.8.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25881']	4419

Location

Component	Version
http-cache-semantics	3.8.1
File Path	
juice-shop/node_modules/http-cache-semantics/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

http-cache-semantics: Regular Expression Denial of Service (ReDoS) vulnerability

Target: Node.js

Type: node-pkg

Fixed version: 4.1.1

This affects versions of the package http-cache-semantics before 4.1.1. The issue can be exploited via malicious request header values sent to a server, when that server reads the cache policy from the request using this library.

Mitigation

4.1.1

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2023:2655

https://access.redhat.com/security/cve/CVE-2022-25881

https://bugzilla.redhat.com/2165824

https://bugzilla.redhat.com/2168631

https://bugzilla.redhat.com/2171935

https://bugzilla.redhat.com/2172190

https://bugzilla.redhat.com/2172204

https://bugzilla.redhat.com/2172217

https://bugzilla.redhat.com/show_bug.cgi?id=2165824

https://bugzilla.redhat.com/show_bug.cgi?id=2168631

https://bugzilla.redhat.com/show_bug.cgi?id=2171935

https://bugzilla.redhat.com/show_bug.cgi?id=2172190

https://bugzilla.redhat.com/show_bug.cgi?id=2172204

https://bugzilla.redhat.com/show_bug.cgi?id=2172217

https://bugzilla.redhat.com/show_bug.cgi?id=2178076

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-25881

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-4904

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23918

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23920

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23936

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-24807

https://errata.almalinux.org/9/ALSA-2023-2655.html

https://errata.rockylinux.org/RLSA-2023:2655

https://github.com/kornelski/http-cache-semantics

https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83

https://github.com/kornelski/http-cache-semantics/commit/560b2d8ef452bbba20ffed69dc155d63ac757b74

https://linux.oracle.com/cve/CVE-2022-25881.html

https://linux.oracle.com/errata/ELSA-2023-2655.html

https://nvd.nist.gov/vuln/detail/CVE-2022-25881

https://security.netapp.com/advisory/ntap-20230622-0008

https://security.netapp.com/advisory/ntap-20230622-0008/

https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332

https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783

https://www.cve.org/CVERecord?id=CVE-2022-25881

Images

No images found.

Critical

Finding 568 - CVE-2015-9235 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4420

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-jsonwebtoken: verification step bypass with an altered token

Target: Node.js

Type: node-pkg

Fixed version: 4.2.2

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

4.2.2

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2015-9235
- https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries
- https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/
- https://github.com/advisories/GHSA-c7hr-j4mj-j2w6
- https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687
- https://nodesecurity.io/advisories/17
- https://nvd.nist.gov/vuln/detail/CVE-2015-9235
- https://www.cve.org/CVERecord?id=CVE-2015-9235
- https://www.npmjs.com/advisories/17
- https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

High

Finding 569 - CVE-2022-23539 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	327	['CVE-2022-23539']	4421

Location	
Component	Version
jsonwebtoken	0.1.0
File Path	
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

jsonwebtoken: Unrestricted key type could lead to legacy keys usagen

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

9.0.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-23539
- https://github.com/auth0/node-jwebtoken
- https://github.com/auth0/node-jwebtoken/commit/elfa9dcc12054a8681db4e6373da1b30cf7016e3
- https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33
- https://nvd.nist.gov/vuln/detail/CVE-2022-23539
- https://security.netapp.com/advisory/ntap-20240621-0007
- https://security.netapp.com/advisory/ntap-20240621-0007/
- https://www.cve.org/CVERecord?id=CVE-2022-23539

Images

No images found.

Finding 570 - NSWG-ECO-17 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4422

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

Description

Verification Bypass

Target: Node.js

Type: node-pkg

Fixed version: >=4.2.2

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

=4.2.2

Impact

fixed

References

- https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/
- https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687
- https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

Medium

Finding 571 - CVE-2022-23540 Jwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4423

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

jsonwebtoken: Insecure default algorithm in jwt.verify() could lead to signature validation bypass

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

9.0.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-23540
- https://github.com/auth0/node-jsonwebtoken
- https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3
- https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-qwph-4952-7xr6
- https://nvd.nist.gov/vuln/detail/CVE-2022-23540
- https://security.netapp.com/advisory/ntap-20240621-0007
- https://security.netapp.com/advisory/ntap-20240621-0007/
- https://www.cve.org/CVERecord?id=CVE-2022-23540

Images

No images found.

Finding 572 - CVE-2022-23541 Jsonwebtoken 0.1.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4424

Location

Component	Version
jsonwebtoken	0.1.0

File Path
juice-shop/node_modules/express-jwt/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken: Insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

9.0.0

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2022-23541>
- <https://github.com/auth0/node-jsonwebtoken>
- <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>
- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>
- <https://security.netapp.com/advisory/ntap-20240621-0007>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>
- <https://www.cve.org/CVERecord?id=CVE-2022-23541>

Images

No images found.

Critical

Finding 573 - CVE-2015-9235 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	[CVE-2015-9235]	4425

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-jsonwebtoken: verification step bypass with an altered token

Target: Node.js

Type: node-pkg

Fixed version: 4.2.2

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

4.2.2

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2015-9235>

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries

https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/

https://github.com/advisories/GHSA-c7hr-j4mj-j2w6

https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687

https://nodesecurity.io/advisories/17

https://nvd.nist.gov/vuln/detail/CVE-2015-9235

https://www.cve.org/CVERecord?id=CVE-2015-9235

https://www.npmjs.com/advisories/17

https://www.timmclean.net/2015/02/25/jwt-alg-none.html

Images

No images found.

High

Finding 574 - CVE-2022-23539 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	327	['CVE-2022-23539']	4426

Location

Component	Version
jsonwebtoken	0.4.0

File Path
juice-shop/node_modules/jsonwebtoken/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

jsonwebtoken: Unrestricted key type could lead to legacy keys usagen

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

9.0.0

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2022-23539>
- <https://github.com/auth0/node-jsonwebtoken>
- <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>
- <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>
- <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>
- <https://security.netapp.com/advisory/ntap-20240621-0007>
- <https://security.netapp.com/advisory/ntap-20240621-0007/>
- <https://www.cve.org/CVERecord?id=CVE-2022-23539>

Images

No images found.

Finding 575 - NSWG-ECO-17 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17'] 4427

Location

Component	Version
jsonwebtoken	0.4.0

File Path
juice-shop/node_modules/jsonwebtoken/package.json

Description

Verification Bypass

Target: Node.js

Type: node-pkg

Fixed version: >=4.2.2

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

=4.2.2

Impact

fixed

References

- <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- <https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>
- <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Medium

Finding 576 - CVE-2022-23540 Jsonwebtoken 0.4.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4428

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

jsonwebtoken: Insecure default algorithm in jwt.verify() could lead to signature validation bypass

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

9.0.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-23540
- https://github.com/auth0/node-jsonwebtoken
- https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3
- https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-qwph-4952-7xr6
- https://nvd.nist.gov/vuln/detail/CVE-2022-23540
- https://security.netapp.com/advisory/ntap-20240621-0007
- https://security.netapp.com/advisory/ntap-20240621-0007/
- https://www.cve.org/CVERecord?id=CVE-2022-23540

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4429

Location

Component	Version
jsonwebtoken	0.4.0
File Path	
juice-shop/node_modules/jsonwebtoken/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken: Insecure implementation of key retrieval function could lead to Forgeable Public/Private Tokens from RSA to HMAC

Target: Node.js

Type: node-pkg

Fixed version: 9.0.0

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

9.0.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-23541

https://github.com/auth0/node-jwebtoken

https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

https://github.com/auth0/node-jwebtoken/releases/tag/v9.0.0

https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-hjrf-2m68-5959

https://nvd.nist.gov/vuln/detail/CVE-2022-23541

https://security.netapp.com/advisory/ntap-20240621-0007

https://security.netapp.com/advisory/ntap-20240621-0007/

https://www.cve.org/CVERecord?id=CVE-2022-23541

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High (8.7)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	[CVE-2016-1000223]	4430

Location

Component	Version
jws	0.2.6
File Path	
juice-shop/node_modules/jws/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Description

Forgeable Public/Private Tokens

Target: Node.js

Type: node-pkg

Fixed version: >=3.0.0

Since "algorithm" isn't enforced in jws.verify(), a malicious user could choose what algorithm is sent to the server. If the server is expecting RSA but is sent HMAC-SHA with RSA's public key, the server will think the public key is actually an HMAC private key. This could be used to forge any data an attacker wants.

In addition, there is the none algorithm to be concerned about. In versions prior to 3.0.0, verification of the token could be bypassed when the alg field is set to none.

Edit (7/29/16): A previous version of this advisory incorrectly stated that the vulnerability was patched in version 2.0.0 instead of 3.0.0. The advisory has been updated to reflect this new information. Thanks to Fabien Catteau for reporting the error.

Mitigation

=3.0.0

Impact

fixed

References

<https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

<https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

<https://github.com/brianloveswords/node-jws>

<https://github.com/brianloveswords/node-jws/commit/585d0e1e97b6747c10cf5b7689ccc5618a89b299#diff-4ac32a78649ca5bdd8e0ba38b7006a1e>

<https://nvd.nist.gov/vuln/detail/CVE-2016-1000223>

<https://snyk.io/vuln/npm:jws:20160726>

<https://www.npmjs.com/advisories/88>

Images

No images found.

Finding 579 - CVE-2025-65945 JWS 0.2.6 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	347	['CVE-2025-65945']	4431

Location

Component	Version
jws	0.2.6
File Path	
juice-shop/node_modules/jws/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-jws: auth0/node-jws: Improper signature verification in HS256 algorithm

Target: Node.js

Type: node-pkg

Fixed version: 3.2.3, 4.0.1

auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the jws.createVerify() function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Mitigation

3.2.3, 4.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-65945
- https://github.com/auth0/node-jws
- https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e
- https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6
- https://github.com/auth0/node-jws/releases/tag/v3.2.3
- https://github.com/auth0/node-jws/releases/tag/v4.0.1
- https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x
- https://nvd.nist.gov/vuln/detail/CVE-2025-65945
- https://www.cve.org/CVERecord?id=CVE-2025-65945

Images

No images found.

Finding 580 - CVE-2019-10744 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2019-10744']	4432

Location

Component	Version
lodash	2.4.2
File Path	
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

nodejs-lodash: prototype pollution in defaultsDeep function leading to modifying properties

Target: Node.js

Type: node-pkg

Fixed version: 4.17.12

Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked into adding or modifying properties of Object.prototype using a constructor payload.

Mitigation

4.17.12

Impact

fixed

References

- https://access.redhat.com/errata/RHSA-2019:3024
- https://access.redhat.com/security/cve/CVE-2019-10744
- https://github.com/advisories/GHSA-jf85-cpcp-j695
- https://github.com/lodash/lodash/pull/4336
- https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2019-10744.yml
- https://nvd.nist.gov/vuln/detail/CVE-2019-10744
- https://security.netapp.com/advisory/ntap-20191004-0005
- https://security.netapp.com/advisory/ntap-20191004-0005/
- https://snyk.io/vuln/SNYK-JS-LODASH-450202
- https://support.f5.com/csp/article/K47105354
- https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS
- https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS
- https://www.cve.org/CVERecord?id=CVE-2019-10744

Images

No images found.

High

Finding 581 - CVE-2018-16487 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (5.6)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	[CVE-2018-16487]	4433

Location

Component	Version
lodash	2.4.2

File Path
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

lodash: Prototype pollution in utilities function

Target: Node.js

Type: node-pkg

Fixed version: >=4.17.11

A prototype pollution vulnerability was found in lodash <4.17.11 where the functions merge, mergeWith, and defaultsDeep can be tricked into adding or modifying properties of Object.prototype.

Mitigation

=4.17.11

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2018-16487

https://github.com/advisories/GHSA-4xc9-xhrj-v574

https://github.com/lodash/lodash/commit/90e6199a161b6445b01454517b40ef65eabcd2ad

https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-16487.yml

https://hackerone.com/reports/380873

https://nvd.nist.gov/vuln/detail/CVE-2018-16487

https://security.netapp.com/advisory/ntap-20190919-0004

https://security.netapp.com/advisory/ntap-20190919-0004/

https://www.cve.org/CVERecord?id=CVE-2018-16487

https://www.npmjs.com/advisories/782

Images

No images found.

Finding 582 - CVE-2021-23337 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	94	[CVE-2021-23337]	4434

Location

Component	Version
lodash	2.4.2

File Path
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Description

nodejs-lodash: command injection via template

Target: Node.js

Type: node-pkg

Fixed version: 4.17.21

Lodash versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Mitigation

4.17.21

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2021-23337

https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf

https://github.com/advisories/GHSA-35jh-r3h4-6jhm

https://github.com/lodash/lodash

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js#L14851

https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js%23L14851

https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b5a91dde28ba4b1c

https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2021-23337.yml

- https://nvd.nist.gov/vuln/detail/CVE-2021-23337
- https://security.netapp.com/advisory/ntap-20210312-0006
- https://security.netapp.com/advisory/ntap-20210312-0006/
- https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLDASH-1074931
- https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929
- https://snyk.io/vuln/SNYK-JS-LODASH-1040724
- https://www.cve.org/CVERecord?id=CVE-2021-23337
- https://www.oracle.com//security-alerts/cpujul2021.html
- https://www.oracle.com/security-alerts/cpujan2022.html
- https://www.oracle.com/security-alerts/cpujul2022.html
- https://www.oracle.com/security-alerts/cpuoct2021.html

Images

No images found.

Medium

Finding 583 - CVE-2026-2950 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321 ['CVE-2026-2950'] 4435

Location

Component	Version
lodash	2.4.2

File Path
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

lodash: Lodash: Prototype pollution allows deletion of built-in prototype properties via array path bypass

Target: Node.js

Type: node-pkg

Fixed version: 4.18.0

Impact:

Lodash versions 4.17.23 and earlier are vulnerable to prototype pollution in the `.unset` and `.omit` functions. The fix for (CVE-2025-13465: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>) only guards against string key members, so an attacker can bypass the check

by passing array-wrapped path segments. This allows deletion of properties from built-in prototypes such as Object.prototype, Number.prototype, and String.prototype.

The issue permits deletion of prototype properties but does not allow overwriting their original behavior.

Patches:

This issue is patched in 4.18.0.

Workarounds:

None. Upgrade to the patched version.

Mitigation

4.18.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-2950
- https://github.com/lodash/lodash
- https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh
- https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg
- https://nvd.nist.gov/vuln/detail/CVE-2026-2950
- https://www.cve.org/CVERecord?id=CVE-2026-2950

Images

No images found.

Low

Finding 584 - CVE-2018-3721 Lodash 2.4.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Low (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	471 ['CVE-2018-3721']	4436

Location

Component	Version
lodash	2.4.2
File Path	
juice-shop/node_modules/sanitize-html/node_modules/lodash/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Description

lodash: Prototype pollution in utilities function

Type: node-pkg

Description

nodejs-lodash: prototype pollution in zipObjectDeep function

Target: Node.js

Type: node-pkg

Fixed version:

Prototype pollution attack when using `_zipObjectDeep` in `lodash` before 4.17.20.

Impact

affected

References

<https://access.redhat.com/security/cve/CVE-2020-8203>

<https://github.com/advisories/GHSA-p6mc-m468-83gw>

<https://github.com/github/advisory-database/pull/2884>

<https://github.com/lodash/lodash>

<https://github.com/lodash/lodash/commit/c84fe82760fb2d3e03a63379b297a1cc1a2fce12>

<https://github.com/lodash/lodash/issues/4744>

<https://github.com/lodash/lodash/issues/4874>

<https://github.com/lodash/lodash/wiki/Changelog#v41719>

<https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2020-8203.yml>

<https://hackerone.com/reports/712065>

<https://hackerone.com/reports/864701>

<https://nvd.nist.gov/vuln/detail/CVE-2020-8203>

<https://security.netapp.com/advisory/ntap-20200724-0006>

<https://security.netapp.com/advisory/ntap-20200724-0006/>

<https://web.archive.org/web/20210914001339/https://github.com/lodash/lodash/issues/4744>

<https://www.cve.org/CVERecord?id=CVE-2020-8203>

<https://www.npmjs.com/advisories/1523>

<https://www.oracle.com//security-alerts/cpujul2021.html>

<https://www.oracle.com/security-alerts/cpuApr2021.html>

<https://www.oracle.com/security-alerts/cpuapr2022.html>

<https://www.oracle.com/security-alerts/cpujan2022.html>

<https://www.oracle.com/security-alerts/cpuoct2021.html>

Images

No images found.

Critical

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Critical	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['GHSA-5mrr-rgp6-x4gr']	4438

Location

Component	Version
marsdb	0.6.11
File Path	
juice-shop/node_modules/marsdb/package.json	

Description

Command Injection in marsdb

Target: Node.js

Type: node-pkg

Fixed version:

All versions of marsdb are vulnerable to Command Injection. In the DocumentMatcher class, selectors on \$where clauses are passed to a Function constructor unsanitized. This allows attackers to run arbitrary commands in the system when the function is executed.

Recommendation

No fix is currently available. Consider using an alternative package until a fix is made available.

Impact

affected

References

https://github.com/bkimminich/juice-shop/issues/1173

https://www.npmjs.com/advisories/1122

Images

No images found.

Low

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2025-57349']	4439

Location

Component	Version
messageformat	2.3.0
File Path	
juice-shop/node_modules/messageformat/package.json	

Description

messageformat has a prototype pollution vulnerability

Target: Node.js

Type: node-pkg

Fixed version: 3.0.0-beta.0

The messageformat package, an implementation of the Unicode MessageFormat 2 specification for JavaScript, is vulnerable to prototype pollution due to improper handling of message key paths in versions prior to 2.3.0. The flaw arises when processing nested message keys containing special characters (e.g., **proto**), which can lead to unintended modification of the JavaScript Object prototype. This vulnerability may allow a remote attacker to inject properties into the global object prototype via specially crafted message input, potentially causing denial of service or other undefined behaviors in applications using the affected component.

Mitigation

3.0.0-beta.0

Impact

fixed

References

<https://github.com/messageformat/messageformat>

<https://github.com/messageformat/messageformat/issues/452>

<https://nvd.nist.gov/vuln/detail/CVE-2025-57349>

Images

No images found.

High

Finding 588 - CVE-2026-26996 Minimatch 3.0.5 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-26996']	4440

Location	
Component	Version
minimatch	3.0.5
File Path	
juice-shop/node_modules/replace/node_modules/minimatch/package.json	

Description

minimatch: minimatch: Denial of Service via specially crafted glob patterns

Target: Node.js

Type: node-pkg

Fixed version: 10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate [^/?]* regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is O(4^N) where N is the number of * characters. With N=15, a single minimatch() call takes ~2 seconds. With N=34, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.

Mitigation

10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2026:7896>
- <https://access.redhat.com/security/cve/CVE-2026-26996>
- <https://bugzilla.redhat.com/2441268>
- <https://bugzilla.redhat.com/2442922>
- <https://bugzilla.redhat.com/2448754>
- <https://bugzilla.redhat.com/2453151>
- https://bugzilla.redhat.com/show_bug.cgi?id=2441268
- https://bugzilla.redhat.com/show_bug.cgi?id=2442922
- https://bugzilla.redhat.com/show_bug.cgi?id=2448754
- https://bugzilla.redhat.com/show_bug.cgi?id=2453151
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904>
- <https://errata.almalinux.org/9/ALSA-2026-7896.html>
- <https://errata.rockylinux.org/RLSA-2026:7896>
- <https://github.com/isaacs/minimatch>
- <https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
- <https://linux.oracle.com/cve/CVE-2026-26996.html>
- <https://linux.oracle.com/errata/ELSA-2026-8339.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26996>
- <https://www.cve.org/CVERecord?id=CVE-2026-26996>

Images

No images found.

Finding 589 - CVE-2026-27903 Minimatch 3.0.5 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	407	['CVE-2026-27903']	4441

Location		
Component	Version	
minimatch	3.0.5	
File Path		
juice-shop/node_modules/replace/node_modules/minimatch/package.json		

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch: minimatch: Denial of Service due to unbounded recursive backtracking via crafted glob patterns

Target: Node.js

Type: node-pkg

Fixed version: 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, `matchOne()` performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent `**` (GLOBSTAR) segments and the input path does not match. The time complexity is $O(C(n, k))$ -- binomial -- where n is the number of path segments and k is the number of globstars. With $k=11$ and $n=30$, a call to the default `minimatch()` API stalls for roughly 5 seconds. With $k=13$, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to `minimatch()` is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Mitigation

10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-27903>
- <https://github.com/isaacs/minimatch>
- <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>
- <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
- <https://www.cve.org/CVERecord?id=CVE-2026-27903>

Images

No images found.

Finding 590 - CVE-2026-27904 Minimatch 3.0.5 lang-pkgs node-pkg							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-27904'] 4442

Location

Component	Version
minimatch	3.0.5

File Path
juice-shop/node_modules/replace/node_modules/minimatch/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch: Minimatch: Denial of Service via catastrophic backtracking in glob expressions

Target: Node.js

Type: node-pkg

Fixed version: 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested `*`() extglobs produce regexps with nested unbounded quantifiers (e.g. `?(?:a|b)*`), which exhibit catastrophic backtracking in V8. With a 12-byte pattern `*(*(a|b))` and an 18-byte non-matching input, `minimatch()` stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default `minimatch()` API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects `+`() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Mitigation

10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026-7896>

<https://access.redhat.com/security/cve/CVE-2026-27904>

<https://bugzilla.redhat.com/2441268>

<https://bugzilla.redhat.com/2442922>

<https://bugzilla.redhat.com/2448754>

<https://bugzilla.redhat.com/2453151>

https://bugzilla.redhat.com/show_bug.cgi?id=2441268

https://bugzilla.redhat.com/show_bug.cgi?id=2442922

https://bugzilla.redhat.com/show_bug.cgi?id=2448754

https://bugzilla.redhat.com/show_bug.cgi?id=2453151

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904>

<https://errata.almalinux.org/9/ALSA-2026-7896.html>

<https://errata.rockylinux.org/RLSA-2026-7896>

https://github.com/isaacs/minimatch

https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce

https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74

https://linux.oracle.com/cve/CVE-2026-27904.html

https://linux.oracle.com/errata/ELSA-2026-8339.html

https://nvd.nist.gov/vuln/detail/CVE-2026-27904

https://www.cve.org/CVERecord?id=CVE-2026-27904

Images

No images found.

Finding 591 - CVE-2017-18214 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2017-18214']	4443

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

nodejs-moment: Regular expression denial of service

Target: Node.js

Type: node-pkg

Fixed version: 2.19.3

The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.

Mitigation

2.19.3

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2017-18214

https://github.com/advisories/GHSA-446m-mv8f-q348

https://github.com/moment/moment

https://github.com/moment/moment/commit/69ed9d44957fa6ab12b73d2ae29d286a857b80eb

https://github.com/moment/moment/issues/4163

https://github.com/moment/moment/pull/4326

https://nodesecurity.io/advisories/532

https://nvd.nist.gov/vuln/detail/CVE-2017-18214

https://ubuntu.com/security/notices/USN-4786-1

https://www.cve.org/CVERecord?id=CVE-2017-18214

https://www.npmjs.com/advisories/532

https://www.tenable.com/security/tns-2019-02

Images

No images found.

Finding 592 - CVE-2022-24785 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2022-24785]	4444

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Moment.js: Path traversal in moment.locale

Target: Node.js

Type: node-pkg

Fixed version: 2.29.2

Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

Mitigation

2.29.2

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2022-24785

https://github.com/moment/moment

https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5

https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4

https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q/

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5/

https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

https://nvd.nist.gov/vuln/detail/CVE-2022-24785

https://security.netapp.com/advisory/ntap-20220513-0006

https://security.netapp.com/advisory/ntap-20220513-0006/

https://security.netapp.com/advisory/ntap-20241108-0002

https://security.netapp.com/advisory/ntap-20241108-0002/

https://ubuntu.com/security/notices/USN-5559-1

https://www.cve.org/CVERecord?id=CVE-2022-24785

https://www.tenable.com/security/tns-2022-09

Images

No images found.

Medium

Finding 593 - CVE-2016-4055 Moment 2.0.0 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400 ['CVE-2016-4055']	4445

Location

Component	Version
moment	2.0.0

File Path
juice-shop/node_modules/express-jwt/node_modules/moment/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

moment.js: regular expression denial of service

Target: Node.js

Type: node-pkg

Fixed version: >=2.11.2

The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."

Mitigation

Impact

fixed

References

<http://www.openwall.com/lists/oss-security/2016/04/20/11>

<http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>

<http://www.securityfocus.com/bid/95849>

<https://access.redhat.com/security/cve/CVE-2016-4055>

<https://github.com/advisories/GHSA-87vv-r9j6-g5qv>

<https://github.com/moment/moment>

<https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731%40%3Cdev.flink.apache.org%3E>

<https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731@%3Cdev.flink.apache.org%3E>

<https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49@%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2@%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854%40%3Cuser.flink.apache.org%3E>

<https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854@%3Cuser.flink.apache.org%3E>

<https://nodesecurity.io/advisories/55>

<https://nvd.nist.gov/vuln/detail/CVE-2016-4055>

<https://ubuntu.com/security/notices/USN-4786-1>

<https://www.cve.org/CVERecord?id=CVE-2016-4055>

<https://www.npmjs.com/advisories/55>

https://www.owasp.org/index.php/Regular_expression_Denial_of_Service_-_ReDoS

<https://www.tenable.com/security/tns-2019-02>

Images

No images found.

High

Finding 594 - CVE-2025-47935 Multer 1.4.5-lts.2 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	401	[CVE-2025-47935]	4446

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer vulnerable to Denial of Service via memory leaks from unclosed streams

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0

Multer is a node.js middleware for handling multipart/form-data. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal busboy stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

2.0.0

Impact

fixed

References

- <https://github.com/expressjs/multer>
- <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>
- <https://github.com/expressjs/multer/pull/1120>
- <https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-47935>

Images

No images found.

Finding 595 - CVE-2025-47944 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-47944']	4447

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

Multer vulnerable to Denial of Service from maliciously crafted requests

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

2.0.0

Impact

fixed

References

- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665
- https://github.com/expressjs/multer/issues/1176
- https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h
- https://nvd.nist.gov/vuln/detail/CVE-2025-47944

Images

No images found.

Finding 596 - CVE-2025-48997 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-48997']	4448

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer vulnerable to Denial of Service via unhandled exception

Target: Node.js

Type: node-pkg

Fixed version: 2.0.1

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to 2.0.1 to receive a patch. No known workarounds are available.

Mitigation

2.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-48997
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9
- https://github.com/expressjs/multer/issues/1233
- https://github.com/expressjs/multer/pull/1256
- https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qg
- https://nvd.nist.gov/vuln/detail/CVE-2025-48997
- https://www.cve.org/CVERecord?id=CVE-2025-48997

Images

No images found.

Finding 597 - CVE-2025-7338 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-7338']	4449

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

multer: Multer Denial of Service

Target: Node.js

Type: node-pkg

Fixed version: 2.0.2

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Mitigation

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2025-7338
- https://cna.openjsf.org/security-advisories.html
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b
- https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p
- https://nvd.nist.gov/vuln/detail/CVE-2025-7338
- https://www.cve.org/CVERecord?id=CVE-2025-7338

Images

No images found.

Finding 598 - CVE-2026-2359 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	772	['CVE-2026-2359']	4450

Location

Component	Version
multer	1.4.5-lts.2

File Path
juice-shop/node_modules/multer/package.json

Description

multer: Multer: Denial of Service via dropped file upload connections

Target: Node.js

Type: node-pkg

Fixed version: 2.1.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by dropping connection during file upload, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

2.1.0

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-2359
- https://cna.openjsf.org/security-advisories.html

https://github.com/expressjs/multer

https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab

https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc

https://nvd.nist.gov/vuln/detail/CVE-2026-2359

https://www.cve.org/CVERecord?id=CVE-2026-2359

Images

No images found.

Finding 599 - CVE-2026-3304 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	459	['CVE-2026-3304']	4451

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer: Denial of Service via malformed requests

Target: Node.js

Type: node-pkg

Fixed version: 2.1.0

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

2.1.0

Impact

fixed

References

https://access.redhat.com/security/cve/CVE-2026-3304

https://cna.openjsf.org/security-advisories.html

https://github.com/expressjs/multer

https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee

https://github.com/expressjs/multer/security/advisories/GHSA-xf7r-hgr6-v32p

https://nvd.nist.gov/vuln/detail/CVE-2026-3304

https://www.cve.org/CVERecord?id=CVE-2026-3304

Images

No images found.

Finding 600 - CVE-2026-3520 Multer 1.4.5-lts.2 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674 ['CVE-2026-3520']	4452

Location

Component	Version
multer	1.4.5-lts.2
File Path	
juice-shop/node_modules/multer/package.json	

Description

multer: Multer: Denial of Service via malformed requests

Target: Node.js

Type: node-pkg

Fixed version: 2.1.1

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.1 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing stack overflow. Users should upgrade to version 2.1.1 to receive a patch. No known workarounds are available.

Mitigation

2.1.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-3520
- https://cna.openjsf.org/security-advisories.html
- https://github.com/expressjs/multer
- https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752
- https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2
- https://nvd.nist.gov/vuln/detail/CVE-2026-3520
- https://www.cve.org/CVERecord?id=CVE-2026-3520

Images

No images found.

Medium

Finding 601 - CVE-2021-23771 Notevil 1.3.3 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321 ['CVE-2021-23771']	4453

Location

Component	Version
notevil	1.3.3
File Path	
juice-shop/node_modules/notevil/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

Sandbox escape in notevil and argencoders-notevil

Target: Node.js

Type: node-pkg

Fixed version:

This affects all versions of package notevil; all versions of package argencoders-notevil. It is vulnerable to Sandbox Escape leading to Prototype pollution. The package fails to restrict access to the main context, allowing an attacker to add or modify an object's prototype. **Note:** This vulnerability derives from an incomplete fix in [SNYK-JS-NOTEVIL-608878](#).

Impact

affected

References

- <https://github.com/mmckegg/notevil>
- <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>
- <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>
- <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Images

No images found.

Finding 602 - CVE-2026-8723 Qs 6.15.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2026-8723']	4454

Location

Component	Version
qs	6.15.1
File Path	
juice-shop/node_modules/qs/package.json	

Description

Summary qs.stringify throws TypeError when called with `arr ...

Target: Node.js

Type: node-pkg

Fixed version: 6.15.2

Summary

qs.stringify throws `TypeError` when called with `arrayFormat: 'comma'` and `encodeValuesOnly: true` on an array containing null or undefined. The throw is synchronous and not handled by any of qs's null-related options (`skipNulls`, `strictNullHandling`).

Details

In the comma + `encodeValuesOnly` branch, `lib/stringify.js:145` mapped the array through the raw encoder before joining:

```
obj = utils.maybeMap(obj, encoder);
```

`utils.encode` (`lib/utils.js:195`) reads `str.length` with no null guard, so a null or undefined element throws `TypeError`. `skipNulls` and `strictNullHandling` are both checked in the per-element loop below this line and never get a chance to run.

Same class of bug as the filter-array path fixed in `0c180a4`. The vulnerable shape of the comma + `encodeValuesOnly` branch was introduced in `4c4b23d` ("encode comma values more consistently", PR #463, 2023-01-19), first released in v6.11.1.

PoC

```
const qs = require('qs');
```

```
qs.stringify({ a: [null, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [undefined, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [null] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
// TypeError: Cannot read properties of null (reading 'length')
```

```
//   at encode (lib/utils.js:195:13)
```

```
//   at Object.maybeMap (lib/utils.js:322:37)
```

```
//   at stringify (lib/stringify.js:145:25)
```

Fix

`lib/stringify.js:145`, applied in `21f80b3` on main and released as v6.15.2:

```
- obj = utils.maybeMap(obj, encoder);
```

```
+ obj = utils.maybeMap(obj, function (v) {
```

```
+   return v == null ? v : encoder(v);
```

```
+ });
```

null and undefined now pass through maybeMap unchanged and reach the join(',') step as-is. For { a: [null, 'b'] } this produces a=,b, matching the non-encodeValuesOnly comma path (which already joins before encoding and produces a=%2Cb for the same input). Single-element [null] arrays still collapse via the existing obj.join(',') || null and remain subject to skipNulls / strictNullHandling in the main loop.

Affected versions

>=6.11.1 <6.15.2 – fixed in v6.15.2.

The vulnerable code shape was introduced in 4c4b23d and first shipped in v6.11.1. Earlier versions – including all of 6.7.x, 6.8.x, 6.9.x, 6.10.x, and 6.11.0 – implemented the comma + encodeValuesOnly path differently (joining before encoding) and are not affected. Empirically verified across released versions.

Impact

Application code that calls qs.stringify with both arrayFormat: 'comma' and encodeValuesOnly: true (both non-default) on input that may contain a null or undefined array element will throw synchronously instead of producing a query string. In a typical Node.js HTTP framework (Express, Fastify, Koa, hapi) the sync throw is caught by the framework's error boundary and the affected request returns a 500; the worker process does not exit and subsequent requests are unaffected. The "kills the worker process" framing applies only to call sites outside a request-handler error boundary (background jobs, startup paths, stream pipelines) or to deployments with framework error handling explicitly disabled.

The vulnerable input is a null or undefined entry inside an array; this is reachable from JSON request bodies or from application code constructing arrays from user input, but not from standard HTML form submissions (which produce strings or omitted fields, not literal null).

Mitigation

6.15.2

Impact

fixed

References

<https://github.com/ljharb/qs>

<https://github.com/ljharb/qs/commit/21f80b33e5c8b3f7eba1034fff0da4a4a37a1d41>

<https://github.com/ljharb/qs/security/advisories/GHSA-q8mj-m7cp-5q26>

<https://nvd.nist.gov/vuln/detail/CVE-2026-8723>

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25887']	4455

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

sanitize-html: insecure global regular expression replacement logic may lead to ReDoS

Target: Node.js

Type: node-pkg

Fixed version: 2.7.1

The package sanitize-html before 2.7.1 are vulnerable to Regular Expression Denial of Service (ReDoS) due to insecure global regular expression replacement logic of HTML comment removal.

Mitigation

2.7.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2022-25887
- https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c
- https://github.com/apostrophecms/sanitize-html/pull/557
- https://nvd.nist.gov/vuln/detail/CVE-2022-25887
- https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3008102
- https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-2957526
- https://ubuntu.com/security/notices/USN-7464-1
- https://www.cve.org/CVERecord?id=CVE-2022-25887

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2016-1000237']	4456

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

XSS - Sanitization not applied recursively

Target: Node.js

Type: node-pkg

Fixed version: >=1.4.3

sanitize-html before 1.4.3 has XSS.

Mitigation

=1.4.3

Impact

fixed

References

- https://github.com/apostrophecms/sanitize-html/commit/762fbc7bba389f3f789cc291c1eb2b64f60f2caf
- https://github.com/apostrophecms/sanitize-html/issues/29
- https://github.com/punkave/sanitize-html/issues/29
- https://nodesecurity.io/advisories/135
- https://nvd.nist.gov/vuln/detail/CVE-2016-1000237
- https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json
- https://www.npmjs.com/advisories/135

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2017-16016']	4457

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Cross-Site Scripting in sanitize-html

Target: Node.js

Type: node-pkg

Fixed version: 1.11.4

Sanitize-html is a library for scrubbing html input of malicious values. Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios: If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

Mitigation

1.11.4

Impact

fixed

References

- https://github.com/advisories/GHSA-xc6g-ggrc-qq4r
- https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403
- https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403)))
- https://github.com/punkave/sanitize-html/issues/100
- https://nodesecurity.io/advisories/154
- https://npmjs.com/package/sanitize-html#discarding-the-entire-contents-of-a-disallowed-tag
- https://nvd.nist.gov/vuln/detail/CVE-2017-16016
- https://www.npmjs.com/advisories/154

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2019-25225']	4458

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html: sanitize-html cross site scripting

Target: Node.js

Type: node-pkg

Fixed version: 2.0.0-beta

sanitize-html prior to version 2.0.0-beta is vulnerable to Cross-site Scripting (XSS). The sanitizeHtml() function in index.js does not sanitize content when using the custom transformTags option, which is intended to convert attribute values into text. As a result, malicious input can be transformed into executable code.

Mitigation

2.0.0-beta

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2019-25225
- https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225
- https://github.com/apostrophecms/sanitize-html
- https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3
- https://github.com/apostrophecms/sanitize-html/issues/293
- https://github.com/apostrophecms/sanitize-html/pull/156
- https://nvd.nist.gov/vuln/detail/CVE-2019-25225
- https://www.cve.org/CVERecord?id=CVE-2019-25225

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	[CVE-2021-26539]	4459

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

sanitize-html: improper handling of internationalized domain name (IDN) can lead to bypass hostname whitelist validation

Target: Node.js

Type: node-pkg

Fixed version: 2.3.1

Apostrophe Technologies sanitize-html before 2.3.1 does not properly handle internationalized domain name (IDN) which could allow an attacker to bypass hostname whitelist validation set by the "allowedIframeHostnames" option.

Mitigation

2.3.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2021-26539
- https://advisory.checkmarx.net/advisory/CX-2021-4308
- https://github.com/apostrophecms/sanitize-html
- https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22
- https://github.com/apostrophecms/sanitize-html/commit/bdf7836ef8f0e5b21f9a1aab0623ae8fcd09c1da
- https://github.com/apostrophecms/sanitize-html/pull/458
- https://nvd.nist.gov/vuln/detail/CVE-2021-26539
- https://www.cve.org/CVERecord?id=CVE-2021-26539

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	[CVE-2021-26540]	4460

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

sanitize-html: improper validation of hostnames set by the "allowedIframeHostnames" option can lead to bypass hostname whitelist for iframe element

Target: Node.js

Type: node-pkg

Fixed version: 2.3.2

Apostrophe Technologies sanitize-html before 2.3.2 does not properly validate the hostnames set by the "allowedIframeHostnames" option when the "allowIframeRelativeUrls" is set to true, which allows attackers to bypass hostname whitelist for iframe element, related using an src value that starts with "/\example.com".

Mitigation

2.3.2

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2021-26540
- https://advisory.checkmarx.net/advisory/CX-2021-4309
- https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26
- https://github.com/apostrophecms/sanitize-html/pull/460
- https://nvd.nist.gov/vuln/detail/CVE-2021-26540
- https://www.cve.org/CVERecord?id=CVE-2021-26540

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	200	[CVE-2024-21501]	4461

Location

Component	Version
sanitize-html	1.4.2

File Path
juice-shop/node_modules/sanitize-html/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

sanitize-html: Information Exposure when used on the backend

Target: Node.js

Type: node-pkg

Fixed version: 2.12.1

Versions of the package sanitize-html before 2.12.1 are vulnerable to Information Exposure when used on the backend and with the style attribute allowed, allowing enumeration of files in the system (including project dependencies). An attacker could exploit this vulnerability to gather details about the file system structure and dependencies of the targeted server.

Mitigation

2.12.1

Impact

fixed

References

<https://access.redhat.com/security/cve/CVE-2024-21501>

<https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf>

<https://github.com/apostrophecms/apostrophe/discussions/4436>

<https://github.com/apostrophecms/sanitize-html>

<https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4>

<https://github.com/apostrophecms/sanitize-html/pull/650>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7/>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S>

<https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S/>

<https://nvd.nist.gov/vuln/detail/CVE-2024-21501>

<https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>

<https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>

<https://www.cve.org/CVERecord?id=CVE-2024-21501>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-154'] 4462

Location

Component	Version
sanitize-html	1.4.2
File Path	
juice-shop/node_modules/sanitize-html/package.json	

Description

Cross Site Scripting

Target: Node.js

Type: node-pkg

Fixed version: >=1.11.4

Sanitize-html is a library for scrubbing html input of malicious values.

Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios:

If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

PoC:

```
var sanitizeHtml = require('sanitize-html');

var dirty = '<textarea>&lt;/textarea><svg/onload=prompt`xs`&gt;</textarea>!';
var clean = sanitizeHtml(dirty, {
  allowedTags: [ 'textarea' ]
});

console.log(clean);

// <textarea></textarea><svg/onload=prompt`xs`></textarea>!
```

Mitigation

=1.11.4

Impact

fixed

References

https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403

https://github.com/punkave/sanitize-html/issues/100

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2024-38355']	4463

Location

Component	Version
socket.io	3.1.2
File Path	
juice-shop/node_modules/socket.io/package.json	

Description

socket.io: Unhandled 'error' event

Target: Node.js

Type: node-pkg

Fixed version: 2.5.1, 4.6.2

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. This issue is fixed by commit 15af22fc22 which has been included in socket.io@4.6.2 (released in May 2023). The fix was backported in the 2.x branch as well with commit d30630ba10. Users are advised to upgrade. Users unable to upgrade may attach a listener for the "error" event to catch these errors.

Mitigation

2.5.1, 4.6.2

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2024-38355
- https://github.com/socketio/socket.io
- https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115
- https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c
- https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj
- https://nvd.nist.gov/vuln/detail/CVE-2024-38355
- https://www.cve.org/CVERecord?id=CVE-2024-38355
- https://www.vicarius.io/vsociety/posts/unhandled-exception-in-socketio-cve-2024-38355

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-33151']	4464

Location

Component	Version
socket.io-parser	4.0.5
File Path	
juice-shop/node_modules/socket.io-parser/package.json	

Description

socket.io: Socket.IO: Denial of Service due to excessive buffering of specially crafted packets

Target: Node.js

Type: node-pkg

Fixed version: 3.3.5, 3.4.4, 4.2.6

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. Prior to versions 3.3.5, 3.4.4, and 4.2.6, a specially crafted Socket.IO packet can make the server wait for a large number of binary attachments and buffer them, which can be exploited to make the server run out of memory. This issue has been patched in versions 3.3.5, 3.4.4, and 4.2.6.

Mitigation

3.3.5, 3.4.4, 4.2.6

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-33151>
- <https://github.com/socketio/socket.io>
- <https://github.com/socketio/socket.io/commit/719f9ebab0772ffb882bd614b387e585c1aa75d4>
- <https://github.com/socketio/socket.io/commit/9d39f1f080510f036782f2177fac701cc041faaf>
- <https://github.com/socketio/socket.io/commit/b25738c416c4e32fbff62ee182afa8f6d0dacf78>
- <https://github.com/socketio/socket.io/security/advisories/GHSA-677m-j7p3-52f9>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-33151>
- <https://www.cve.org/CVERecord?id=CVE-2026-33151>

Images

No images found.

Medium

Finding 613 - CVE-2023-32695 socket.io-parser 4.0.5 lang-pkgs node-pkg							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2023-32695'] 4465

Location

Component	Version
socket.io-parser	4.0.5
File Path	
juice-shop/node_modules/socket.io-parser/package.json	

Description

socket.io parser is a socket.io encoder and decoder written in JavaScr ...

Target: Node.js

Type: node-pkg

Fixed version: 4.2.3, 3.4.3, 3.3.4

socket.io parser is a socket.io encoder and decoder written in JavaScript complying with version 5 of socket.io-protocol. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. A patch has been released in version 4.2.3.

Mitigation

4.2.3, 3.4.3, 3.3.4

Impact

fixed

References

- <https://github.com/socketio/socket.io-parser>
- <https://github.com/socketio/socket.io-parser/commit/1c220ddbf45ea4b44bc8dbf6f9ae245f672ba1b9>
- <https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23bled46b02ced>
- <https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3>
- <https://github.com/socketio/socket.io-parser/commit/ee006607495eca4ec7262ad080dd3a91439a5ba4>
- <https://github.com/socketio/socket.io-parser/releases/tag/4.2.3>
- <https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-32695>

Images

No images found.

High

Finding 614 - CVE-2026-23745 Tar 4.4.19 lang-pkgs node-pkg							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745'] 4466

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description
node-tar: tar: node-tar: Arbitrary file overwrite and symlink poisoning via unsanitized linkpaths in archives
Target: Node.js
Type: node-pkg
Fixed version: 7.5.3
node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.
Mitigation
7.5.3
Impact
fixed
References
https://access.redhat.com/errata/RHSA-2026:18868
https://access.redhat.com/security/cve/CVE-2026-23745
https://bugzilla.redhat.com/2425946
https://bugzilla.redhat.com/2430538
https://bugzilla.redhat.com/2431036
https://bugzilla.redhat.com/2431740
https://bugzilla.redhat.com/2433645
https://bugzilla.redhat.com/show_bug.cgi?id=2425946
https://bugzilla.redhat.com/show_bug.cgi?id=2430538
https://bugzilla.redhat.com/show_bug.cgi?id=2431036
https://bugzilla.redhat.com/show_bug.cgi?id=2431740
https://bugzilla.redhat.com/show_bug.cgi?id=2433645
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842
https://errata.almalinux.org/9/ALSA-2026-18868.html
https://errata.rockylinux.org/RLSA-2026:18868
https://github.com/isaacs/node-tar
https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e
https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97
https://nvd.nist.gov/vuln/detail/CVE-2026-23745
https://www.cve.org/CVERecord?id=CVE-2026-23745
Images

Finding 615 - CVE-2026-23950 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	176	[CVE-2026-23950]	4467

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar: tar: node-tar: Arbitrary file overwrite via Unicode path collision race condition

Target: Node.js

Type: node-pkg

Fixed version: 7.5.4

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

7.5.4

Impact

fixed

References

- https://access.redhat.com/errata/RHSA-2026:18868
- https://access.redhat.com/security/cve/CVE-2026-23950
- https://bugzilla.redhat.com/2425946
- https://bugzilla.redhat.com/2430538
- https://bugzilla.redhat.com/2431036
- https://bugzilla.redhat.com/2431740
- https://bugzilla.redhat.com/2433645
- https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

https://errata.almalinux.org/9/ALSA-2026-18868.html

https://errata.rockylinux.org/RLSA-2026:18868

https://github.com/isaacs/node-tar

https://github.com/isaacs/node-tar/commit/3blabfae650056edfabcb0a0df5954d390521e6

https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

https://nvd.nist.gov/vuln/detail/CVE-2026-23950

https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 616 - CVE-2026-24842 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-24842]	4468

Location

Component	Version
tar	4.4.19

File Path
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar: tar: node-tar: Arbitrary file creation via path traversal bypass in hardlink security check

Target: Node.js

Type: node-pkg

Fixed version: 7.5.7

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2026:18868>
- <https://access.redhat.com/security/cve/CVE-2026-24842>
- <https://bugzilla.redhat.com/2425946>
- <https://bugzilla.redhat.com/2430538>
- <https://bugzilla.redhat.com/2431036>
- <https://bugzilla.redhat.com/2431740>
- <https://bugzilla.redhat.com/2433645>
- https://bugzilla.redhat.com/show_bug.cgi?id=2425946
- https://bugzilla.redhat.com/show_bug.cgi?id=2430538
- https://bugzilla.redhat.com/show_bug.cgi?id=2431036
- https://bugzilla.redhat.com/show_bug.cgi?id=2431740
- https://bugzilla.redhat.com/show_bug.cgi?id=2433645
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>
- <https://errata.almalinux.org/9/ALSA-2026-18868.html>
- <https://errata.rockylinux.org/RLSA-2026:18868>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
- <https://www.cve.org/CVERecord?id=CVE-2026-24842>

Images

No images found.

Finding 617 - CVE-2026-26960 Tar 4.4.19 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4469

Location

Component	Version
tar	4.4.19

File Path
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar: node-tar: Arbitrary file read/write via malicious archive hardlink creation

Target: Node.js

Type: node-pkg

Fixed version: 7.5.8

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

7.5.8

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-26960>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
- <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>
- <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 618 - CVE-2026-29786 Tar 4.4.19 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4470

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description

node-tar: hardlink path traversal via drive-relative linkpath

Target: Node.js

Type: node-pkg

Fixed version: 7.5.10

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

7.5.10

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-29786>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-29786>
- <https://www.cve.org/CVERecord?id=CVE-2026-29786>

Images

No images found.

Finding 619 - CVE-2026-31802 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4471

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

Description

tar: tar: File overwrite via drive-relative symlink traversal

Target: Node.js

Type: node-pkg

Fixed version: 7.5.11

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:/.././target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

7.5.11

Impact

fixed

References

<https://access.redhat.com/security/cve/CVE-2026-31802>

<https://github.com/isaacs/node-tar>

<https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>

<https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>

<https://nvd.nist.gov/vuln/detail/CVE-2026-31802>

<https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Medium

Finding 620 - CVE-2024-28863 Tar 4.4.19 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2024-28863']	4472

Location

Component	Version
tar	4.4.19
File Path	
juice-shop/node_modules/node-pre-gyp/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

node-tar: denial of service while parsing a tar file due to lack of folders depth validation

Target: Node.js

Type: node-pkg

Fixed version: 6.2.1

node-tar is a Tar for Node.js. node-tar prior to version 6.2.1 has no limit on the number of sub-folders created in the folder creation process. An attacker who generates a large number of sub-folders can consume memory on the system running node-tar and even crash the Node.js client within few seconds of running it using a path with too many sub-folders inside. Version 6.2.1 fixes this issue by preventing extraction in excessively deep sub-folders.

Mitigation

6.2.1

Impact

fixed

References

- <https://access.redhat.com/errata/RHSA-2024:6147>
- <https://access.redhat.com/security/cve/CVE-2024-28863>
- <https://bugzilla.redhat.com/2293200>
- <https://bugzilla.redhat.com/2296417>
- https://bugzilla.redhat.com/show_bug.cgi?id=2293200
- https://bugzilla.redhat.com/show_bug.cgi?id=2296417
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-22020>
- <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-28863>
- <https://errata.almalinux.org/9/ALSA-2024-6147.html>
- <https://errata.rockylinux.org/RLSA-2024:6147>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7>
- <https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7> (v6.2.1)
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36>
- <https://linux.oracle.com/cve/CVE-2024-28863.html>
- <https://linux.oracle.com/errata/ELSA-2024-6148.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-28863>
- <https://security.netapp.com/advisory/ntap-20240524-0005>
- <https://security.netapp.com/advisory/ntap-20240524-0005/>
- <https://www.cve.org/CVERecord?id=CVE-2024-28863>

Images

No images found.

High

Finding 621 - CVE-2026-23745 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745']	4473

Location

Component	Version
tar	6.2.1

File Path
juice-shop/node_modules/sqlite3/node_modules/tar/package.json

Description

node-tar: tar: node-tar: Arbitrary file overwrite and symlink poisoning via unsanitized linkpaths in archives

Target: Node.js

Type: node-pkg

Fixed version: 7.5.3

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

7.5.3

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026:18868>

<https://access.redhat.com/security/cve/CVE-2026-23745>

<https://bugzilla.redhat.com/2425946>

<https://bugzilla.redhat.com/2430538>

<https://bugzilla.redhat.com/2431036>

<https://bugzilla.redhat.com/2431740>

<https://bugzilla.redhat.com/2433645>

https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

<https://errata.almalinux.org/9/ALSA-2026-18868.html>

<https://errata.rockylinux.org/RLSA-2026:18868>

<https://github.com/isaacs/node-tar>

https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e

https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97

https://nvd.nist.gov/vuln/detail/CVE-2026-23745

https://www.cve.org/CVERecord?id=CVE-2026-23745

Images

No images found.

Finding 622 - CVE-2026-23950 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	176	[CVE-2026-23950]	4474

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar: tar: node-tar: Arbitrary file overwrite via Unicode path collision race condition

Target: Node.js

Type: node-pkg

Fixed version: 7.5.4

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

7.5.4

Impact

fixed

References

https://access.redhat.com/errata/RHSA-2026:18868

https://access.redhat.com/security/cve/CVE-2026-23950

https://bugzilla.redhat.com/2425946

https://bugzilla.redhat.com/2430538

https://bugzilla.redhat.com/2431036

https://bugzilla.redhat.com/2431740

https://bugzilla.redhat.com/2433645

https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

https://errata.almalinux.org/9/ALSA-2026-18868.html

https://errata.rockylinux.org/RLSA-2026:18868

https://github.com/isaacs/node-tar

https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6

https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

https://nvd.nist.gov/vuln/detail/CVE-2026-23950

https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 623 - CVE-2026-24842 Tar 6.2.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-24842']	4475

Location

Component	Version
tar	6.2.1

File Path
juice-shop/node_modules/sqlite3/node_modules/tar/package.json

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar: tar: node-tar: Arbitrary file creation via path traversal bypass in hardlink security check

Target: Node.js

Type: node-pkg

Fixed version: 7.5.7

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

7.5.7

Impact

fixed

References

<https://access.redhat.com/errata/RHSA-2026:18868>

<https://access.redhat.com/security/cve/CVE-2026-24842>

<https://bugzilla.redhat.com/2425946>

<https://bugzilla.redhat.com/2430538>

<https://bugzilla.redhat.com/2431036>

<https://bugzilla.redhat.com/2431740>

<https://bugzilla.redhat.com/2433645>

https://bugzilla.redhat.com/show_bug.cgi?id=2425946

https://bugzilla.redhat.com/show_bug.cgi?id=2430538

https://bugzilla.redhat.com/show_bug.cgi?id=2431036

https://bugzilla.redhat.com/show_bug.cgi?id=2431740

https://bugzilla.redhat.com/show_bug.cgi?id=2433645

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

<https://errata.almalinux.org/9/ALSA-2026-18868.html>

<https://errata.rockylinux.org/RLSA-2026:18868>

<https://github.com/isaacs/node-tar>

<https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

<https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

<https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

<https://www.cve.org/CVERecord?id=CVE-2026-24842>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4476

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar: node-tar: Arbitrary file read/write via malicious archive hardlink creation

Target: Node.js

Type: node-pkg

Fixed version: 7.5.8

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

7.5.8

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-26960
- https://github.com/isaacs/node-tar
- https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384
- https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f
- https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx
- https://nvd.nist.gov/vuln/detail/CVE-2026-26960
- https://www.cve.org/CVERecord?id=CVE-2026-26960

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4477

Location

Component	Version
tar	6.2.1
File Path	
juice-shop/node_modules/sqlite3/node_modules/tar/package.json	

Description

node-tar: hardlink path traversal via drive-relative linkpath

Target: Node.js

Type: node-pkg

Fixed version: 7.5.10

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

7.5.10

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-29786
- https://github.com/isaacs/node-tar
- https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f
- https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96
- https://nvd.nist.gov/vuln/detail/CVE-2026-29786
- https://www.cve.org/CVERecord?id=CVE-2026-29786

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4478

Location		
Component	Version	
tar	6.2.1	
File Path		
juice-shop/node_modules/sqlite3/node_modules/tar/package.json		

Description

tar: tar: File overwrite via drive-relative symlink traversal

Target: Node.js

Type: node-pkg

Fixed version: 7.5.11

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:\...\../target.txt, which enables file overwrite outside cwd during normal tar x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

7.5.11

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2026-31802>
- <https://github.com/isaacs/node-tar>
- <https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>
- <https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>
- <https://nvd.nist.gov/vuln/detail/CVE-2026-31802>
- <https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Medium

Finding 627 - CVE-2026-41907 Uuid 8.3.2 lang-pkgs node-pkg								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-41907']	4479

Location		
Component	Version	
uuid	8.3.2	
File Path		
juice-shop/node_modules/uuid/package.json		

Description

uuid: uuid: Out-of-bounds write vulnerability impacts data integrity and confidentiality

Target: Node.js

Type: node-pkg

Fixed version: 11.1.1, 12.0.1, 13.0.1

uuid is for the creation of RFC9562 (formerly RFC4122) UUIDs. Prior to 14.0.0, v3, v5, and v6 accept external output buffers but do not reject out-of-range writes (small buf or large offset). This allows silent partial writes into caller-provided buffers. This vulnerability is fixed in 14.0.0.

Mitigation

11.1.1, 12.0.1, 13.0.1

Impact

fixed

References

- https://access.redhat.com/security/cve/CVE-2026-41907
- https://github.com/uuidjs/uuid
- https://github.com/uuidjs/uuid/commit/32389c887c9e75f90442ee4cc95bbab0c4e8346e
- https://github.com/uuidjs/uuid/commit/3d2c5b0342f0fcb52a5ac681c3d47c13e7444b34
- https://github.com/uuidjs/uuid/commit/3d61d6ac1f782cf6b1dd8661c60f11722cd49a0d
- https://github.com/uuidjs/uuid/commit/9d27ddf7046ce496ef39569ff84d948eeff9cb2a
- https://github.com/uuidjs/uuid/releases/tag/v11.1.1
- https://github.com/uuidjs/uuid/releases/tag/v12.0.1
- https://github.com/uuidjs/uuid/releases/tag/v13.0.1
- https://github.com/uuidjs/uuid/releases/tag/v14.0.0
- https://github.com/uuidjs/uuid/security/advisories/GHSA-w5hq-g745-h8pq
- https://nvd.nist.gov/vuln/detail/CVE-2026-41907
- https://www.cve.org/CVERecord?id=CVE-2026-41907

Images

No images found.

High

Finding 628 - CVE-2024-37890 Ws 7.4.6 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2024-37890']	4480

Location

Component	Version
ws	7.4.6
File Path	
juice-shop/node_modules/engine.io/node_modules/ws/package.json	

Description

nodejs-ws: denial of service when handling a request with many HTTP headers

Target: Node.js

Type: node-pkg

Fixed version: 5.2.4, 6.2.3, 7.5.10, 8.17.1

ws is an open source WebSocket client and server for Node.js. A request with a number of headers exceeding theserver.maxHeadersCount threshold could be used to crash a ws server. The vulnerability was fixed in ws@8.17.1 (e55e510) and backported to ws@7.5.10 (22c2876), ws@6.2.3 (eeb76d3), and ws@5.2.4 (4abd8f6). In vulnerable versions of ws, the issue can be mitigated in the following ways: 1. Reduce the maximum allowed length of the request headers using the --max-http-header-size=size and/or the maxHeaderSize options so that no more headers than the server.maxHeadersCount limit can be sent. 2. Set server.maxHeadersCount to 0 so that no limit is applied.

Mitigation

5.2.4, 6.2.3, 7.5.10, 8.17.1

Impact

fixed

References

- <https://access.redhat.com/security/cve/CVE-2024-37890>
- <https://github.com/websockets/ws>
- <https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f>
- <https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e>
- <https://github.com/websockets/ws/commit/e55e5106f10fcbaac37cfa89759e4cc0d073a52c>
- <https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63>
- <https://github.com/websockets/ws/issues/2230>
- <https://github.com/websockets/ws/pull/2231>
- <https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q>
- <https://nodejs.org/api/http.html#servermaxheaderscount>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-37890>
- <https://www.cve.org/CVERecord?id=CVE-2024-37890>

Images

No images found.

Medium

Finding 629 - CVE-2026-45736 Ws 8.17.1 lang-pkgs node-pkg

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	908	['CVE-2026-45736']	4481

Location

Component	Version
ws	8.17.1
File Path	
juice-shop/node_modules/ws/package.json	

CVSS v3

Description

ws is an open source WebSocket client and server for Node.js. Prior to ...

Target: Node.js

Type: node-pkg

Fixed version: 8.20.1

ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.

Mitigation

8.20.1

Impact

fixed

References

- https://github.com/websockets/ws
- https://github.com/websockets/ws/commit/c0327ec15a54d701eb6ccefaa8bef328cfc03086
- https://github.com/websockets/ws/security/advisories/GHSA-58qx-3vcg-4xpx
- https://nvd.nist.gov/vuln/detail/CVE-2026-45736

Images

No images found.

High

Finding 630 - Secret Detected in /juice-shop/build/lib/insecurity.js - Asymmetric Private Key ^{secret}

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4482

Location

Line Number
46
File Path
/juice-shop/build/lib/insecurity.js

Description

Asymmetric Private Key

Category: AsymmetricPrivateKey

Match: ----BEGIN RSA PRIVATE KEY----
_*****-----END RSA PRIVATE

Images

No images found.

Medium

Finding 631 - Secret Detected in /juice-shop/frontend/src/app/app.guard.spec.ts - JWT Token secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4483

Location

Line Number	File Path
46	/juice-shop/frontend/src/app/app.guard.spec.ts

Description

JWT token

Category: JWT

Match: ocalStorage.setItem('token', '*****')

Images

No images found.

Finding 632 - Secret Detected in /juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts - JWT Token secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4484

Location

Line Number	File Path
72	/juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts

Description

JWT token

Category: JWT

Match: ocalStorage.setItem('token', '*****')

Images

No images found.

High

Finding 633 - Secret Detected in /juice-shop/lib/insecurity.ts - Asymmetric Private Key secret

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	4485

Location

Line Number
23
File Path
/juice-shop/lib/insecurity.ts

Description

Asymmetric Private Key

Category: AsymmetricPrivateKey

Match: ---BEGIN RSA PRIVATE KEY---
_*****-----END RSA PRIVATE

Images

No images found.

Low

Finding 634 - libc6:2.41-12+deb13u2 CVE-2010-4756						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	399 ['CVE-2010-4756'] 4486

Description

The glob implementation in the GNU C Library (aka glibc or libc6) allows remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in STAT commands to an FTP daemon, a different vulnerability than CVE-2010-2632.

References

URL: https://avd.aquasec.com/nvd/cve-2010-4756

URL: http://cxib.net/stuff/glob-0day.c

URL: http://securityreason.com/achievement_securityalert/89

URL: http://securityreason.com/exploitalert/9223

URL: https://access.redhat.com/security/cve/CVE-2010-4756

URL: https://bugzilla.redhat.com/show_bug.cgi?id=681681

URL: https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2010-4756

URL: https://nvd.nist.gov/vuln/detail/CVE-2010-4756

URL: https://security.netapp.com/advisory/ntap-20241108-0002/

Images

No images found.

High

Finding 635 - jsonwebtoken:0.1.0 | CVE-2015-9235

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2015-9235']	4487

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

Upgrade jsonwebtoken to version 4.2.2

References

URL: <https://avd.aquasec.com/nvd/cve-2015-9235>

URL: <https://access.redhat.com/security/cve/CVE-2015-9235>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>

URL: <https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>

URL: <https://nodesecurity.io/advisories/17>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>

URL: <https://www.cve.org/CVERecord?id=CVE-2015-9235>

URL: <https://www.npmjs.com/advisories/17>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20 [CVE-2015-9235]	4488

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family).

Mitigation

Upgrade jsonwebtoken to version 4.2.2

References

- URL:** <https://avd.aquasec.com/nvd/cve-2015-9235>
- URL:** <https://access.redhat.com/security/cve/CVE-2015-9235>
- URL:** <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>
- URL:** <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>
- URL:** <https://github.com/advisories/GHSA-c7hr-j4mj-j2w6>
- URL:** <https://github.com/auth0/node-jwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>
- URL:** <https://nodesecurity.io/advisories/17>
- URL:** <https://nvd.nist.gov/vuln/detail/CVE-2015-9235>
- URL:** <https://www.cve.org/CVERecord?id=CVE-2015-9235>
- URL:** <https://www.npmjs.com/advisories/17>
- URL:** <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High (8.7)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	[CVE-2016-1000223]	4489

CVSS v3

Description

Since "algorithm" isn't enforced in `jws.verify()`, a malicious user could choose what algorithm is sent to the server. If the server is expecting RSA but is sent HMAC-SHA with RSA's public key, the server will think the public key is actually an HMAC private key. This could be used to forge any data an attacker wants.

In addition, there is the none algorithm to be concerned about. In versions prior to 3.0.0, verification of the token could be bypassed when the `alg` field is set to none.

Edit (7/29/16): A previous version of this advisory incorrectly stated that the vulnerability was patched in version 2.0.0 instead of 3.0.0. The advisory has been updated to reflect this new information. Thanks to Fabien Catteau for reporting the error.

Mitigation

Upgrade jws to version >=3.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2016-1000223>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries>

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/brianloveswords/node-jws>

URL: <https://github.com/brianloveswords/node-jws/commit/585d0e1e97b6747c10cf5b7689ccc5618a89b299#diff-4ac32a78649ca5bdd8e0ba38b7006a1e>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2016-1000223>

URL: <https://snyk.io/vuln/npm:jws:20160726>

URL: <https://www.npmjs.com/advisories/88>

Images

No images found.

Medium

Finding 638 - sanitize-html:1.4.2 CVE-2016-1000237									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	['CVE-2016-1000237']	4490	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html before 1.4.3 has XSS.

Mitigation

Upgrade sanitize-html to version >=1.4.3

References

URL: <https://avd.aquasec.com/nvd/cve-2016-1000237>

URL: <https://github.com/apostrophecms/sanitize-html/commit/762fbc7bba389f3f789cc291c1eb2b64f60f2caf>

URL: <https://github.com/apostrophecms/sanitize-html/issues/29>

URL: <https://github.com/punkave/sanitize-html/issues/29>

URL: <https://nodesecurity.io/advisories/135>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2016-1000237>

URL: <https://raw.githubusercontent.com/distributedweaknessfiling/cvelist/master/2016/1000xxx/CVE-2016-1000237.json>

URL: <https://www.npmjs.com/advisories/135>

Images

No images found.

Finding 639 - moment:2.0.0 CVE-2016-4055						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400 ['CVE-2016-4055'] 4491

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."

Mitigation

Upgrade moment to version >=2.11.2

References

URL: <https://avd.aquasec.com/nvd/cve-2016-4055>

URL: <http://www.openwall.com/lists/oss-security/2016/04/20/11>

URL: <http://www.oracle.com/technetwork/security-advisory/cpujul2018-4258247.html>

URL: <http://www.securityfocus.com/bid/95849>

URL: <https://access.redhat.com/security/cve/CVE-2016-4055>

URL: <https://github.com/advisories/GHSA-87vv-r9j6-g5qv>

URL: <https://github.com/moment/moment>

URL: <https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731%40%3Cdev.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/10f0f3aefd51444d1198c65f44ffdf2d78ca3359423dbc1c168c9731@%3Cdev.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49%40%3Cuser.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/17ff53f7999e74fbe3cc0ceb4e1c3b00b180b7c5afec8e978837bc49@%3Cuser.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2%40%3Cuser.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/52bafac05ad174000ea465fe275fd3cc7bd5c25535a7631c0bc9bfb2@%3Cuser.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854%40%3Cuser.flink.apache.org%3E>

URL: <https://lists.apache.org/thread.html/54df3aeb4239b64b50b356f0ca6f986e3c4ca5b84c515dce077c7854@%3Cuser.flink.apache.org%3E>

URL: <https://nodesecurity.io/advisories/55>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2016-4055>

URL: <https://ubuntu.com/security/notices/USN-4786-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2016-4055>

URL: <https://www.npmjs.com/advisories/55>

URL: https://www.owasp.org/index.php/Regular_expression_Denial_of_Service_-_ReDoS

URL: <https://www.tenable.com/security/tns-2019-02>

Images

No images found.

Finding 640 - sanitize-html:1.4.2 | CVE-2017-16016

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	[CVE-2017-16016]	4492

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

Sanitize-html is a library for scrubbing html input of malicious values. Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios: If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

Mitigation

Upgrade sanitize-html to version 1.11.4

References

URL: <https://avd.aquasec.com/nvd/cve-2017-16016>

URL: <https://github.com/advisories/GHSA-xc6g-ggrc-qq4r>

URL: <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>

URL: [https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403\)\)\)](https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403))))

URL: <https://github.com/punkave/sanitize-html/issues/100>

URL: <https://nodesecurity.io/advisories/154>

URL: <https://npmjs.com/package/sanitize-html#discarding-the-entire-contents-of-a-disallowed-tag>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2017-16016>

URL: <https://www.npmjs.com/advisories/154>

Images

No images found.

Finding 641 - moment:2.0.0 CVE-2017-18214									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2017-18214']	4493	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.

Mitigation

Upgrade moment to version 2.19.3

References

URL: <https://avd.aquasec.com/nvd/cve-2017-18214>

URL: <https://access.redhat.com/security/cve/CVE-2017-18214>

URL: <https://github.com/advisories/GHSA-446m-mv8f-q348>

URL: <https://github.com/moment/moment>

URL: <https://github.com/moment/moment/commit/69ed9d44957fa6ab12b73d2ae29d286a857b80eb>

URL: <https://github.com/moment/moment/issues/4163>

URL: <https://github.com/moment/moment/pull/4326>

URL: <https://nodesecurity.io/advisories/532>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2017-18214>

URL: <https://ubuntu.com/security/notices/USN-4786-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2017-18214>

URL: <https://www.npmjs.com/advisories/532>

URL: <https://www.tenable.com/security/tns-2019-02>

Images

No images found.

Finding 642 - lodash:2.4.2 CVE-2018-16487									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.6)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2018-16487']	4494	

CVSS v3

CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

A prototype pollution vulnerability was found in lodash <4.17.11 where the functions merge, mergeWith, and defaultsDeep can be tricked into adding or modifying properties of Object.prototype.

Mitigation

Upgrade lodash to version >=4.17.11

References

URL: <https://avd.aquasec.com/nvd/cve-2018-16487>

URL: <https://access.redhat.com/security/cve/CVE-2018-16487>

URL: <https://github.com/advisories/GHSA-4xc9-xhrj-v574>

URL: <https://github.com/lodash/lodash/commit/90e6199a161b6445b01454517b40ef65ebed2ad>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-16487.yml>

URL: <https://hackerone.com/reports/380873>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2018-16487>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004/>

URL: <https://www.cve.org/CVERecord?id=CVE-2018-16487>

URL: <https://www.npmjs.com/advisories/782>

Images

No images found.

Finding 643 - libc6:2.41-12+deb13u2 CVE-2018-20796									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2018-20796']	4495	

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '(\227)(\1\1|t|l|\2537)+' in grep.

References

URL: <https://avd.aquasec.com/nvd/cve-2018-20796>

URL: <http://www.securityfocus.com/bid/107160>

URL: <https://access.redhat.com/security/cve/CVE-2018-20796>

URL: <https://debbugs.gnu.org/cgi/bugreport.cgi?bug=34141>

URL: <https://lists.gnu.org/archive/html/bug-gnulib/2019-01/msg00108.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2018-20796>

URL: <https://security.netapp.com/advisory/ntap-20190315-0002/>

URL: https://support.f5.com/csp/article/K26346590?utm_source=f5support&utm_medium=RSS

URL: <https://www.cve.org/CVERecord?id=CVE-2018-20796>

Images

No images found.

Low

Finding 644 - lodash:2.4.2 | CVE-2018-3721

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	471	['CVE-2018-3721']	4496

CVSS v3

CVSS:3.0/AV:L/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

lodash node module before 4.17.5 suffers from a Modification of Assumed-Immutable Data (MAID) vulnerability via defaultsDeep, merge, and mergeWith functions, which allows a malicious user to modify the prototype of "Object" via **proto**, causing the addition or modification of an existing property that will exist on all objects.

Mitigation

Upgrade lodash to version >=4.17.5

References

URL: <https://avd.aquasec.com/nvd/cve-2018-3721>

URL: <https://access.redhat.com/security/cve/CVE-2018-3721>

URL: <https://github.com/advisories/GHSA-fvqr-27wr-82fm>

URL: <https://github.com/lodash/lodash/commit/d8e069cc3410082e44eb18fcf8e7f3d08ebe1d4a>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2018-3721.yml>

URL: <https://hackerone.com/reports/310443>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2018-3721>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004>

URL: <https://security.netapp.com/advisory/ntap-20190919-0004/>

URL: <https://snyk.io/vuln/npm:lodash:20180130>

URL: <https://www.cve.org/CVERecord?id=CVE-2018-3721>

URL: https://www.npmjs.com/advisories/577

Images

No images found.

Critical

Finding 645 - libc6:2.41-12+deb13u2 CVE-2019-1010022								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	119	['CVE-2019-1010022']	4497

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: https://avd.aquasec.com/nvd/cve-2019-1010022

URL: https://access.redhat.com/security/cve/CVE-2019-1010022

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010022

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010022

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22850

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22850#c3

URL: https://ubuntu.com/security/CVE-2019-1010022

URL: https://www.cve.org/CVERecord?id=CVE-2019-1010022

Images

No images found.

Low

Finding 646 - libc6:2.41-12+deb13u2 CVE-2019-1010023								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID	
Low (7.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['CVE-2019-1010023']	4498	

CVSS v3

CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Description

GNU Libc current is affected by: Re-mapping current loaded library with malicious ELF file. The impact is: In worst case attacker may evaluate privileges. The component is: libld. The attack vector is: Attacker sends 2 ELF files to victim and asks to run ldd on it. ldd execute code. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: <https://avd.aquasec.com/nvd/cve-2019-1010023>

URL: <http://www.securityfocus.com/bid/109167>

URL: <https://access.redhat.com/security/cve/CVE-2019-1010023>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2019-1010023>

URL: <https://security-tracker.debian.org/tracker/CVE-2019-1010023>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22851

URL: https://support.f5.com/csp/article/K11932200?utm_source=f5support&utm_medium=RSS

URL: <https://ubuntu.com/security/CVE-2019-1010023>

URL: <https://www.cve.org/CVERecord?id=CVE-2019-1010023>

Images

No images found.

Medium

Finding 647 - libc6:2.41-12+deb13u2 CVE-2019-1010024								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	200	['CVE-2019-1010024']	4499

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass ASLR using cache of thread stack and heap. The component is: glibc. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.

References

URL: <https://avd.aquasec.com/nvd/cve-2019-1010024>

URL: <http://www.securityfocus.com/bid/109162>

URL: <https://access.redhat.com/security/cve/CVE-2019-1010024>

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010024

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010024

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22852

URL: https://support.f5.com/csp/article/K06046097

URL: https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS

URL: https://ubuntu.com/security/CVE-2019-1010024

URL: https://www.cve.org/CVERecord?id=CVE-2019-1010024

Images

No images found.

Low

Finding 648 - libc6:2.41-12+deb13u2 | CVE-2019-1010025

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	330	['CVE-2019-1010025']	4500

CVSS v3

CVSS:3.0/AV:L/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may guess the heap addresses of pthread_created thread. The component is: glibc. NOTE: the vendor's position is "ASLR bypass itself is not a vulnerability."

References

URL: https://avd.aquasec.com/nvd/cve-2019-1010025

URL: https://access.redhat.com/security/cve/CVE-2019-1010025

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-1010025

URL: https://security-tracker.debian.org/tracker/CVE-2019-1010025

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=22853

URL: https://support.f5.com/csp/article/K06046097

URL: https://support.f5.com/csp/article/K06046097?utm_source=f5support&utm_medium=RSS

URL: https://ubuntu.com/security/CVE-2019-1010025

URL: <https://www.cve.org/CVERecord?id=CVE-2019-1010025>

Images

No images found.

High

Finding 649 - lodash:2.4.2 | CVE-2019-10744

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2019-10744']	4501

CVSS v3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked into adding or modifying properties of Object.prototype using a constructor payload.

Mitigation

Upgrade lodash to version 4.17.12

References

URL: <https://avd.aquasec.com/nvd/cve-2019-10744>

URL: <https://access.redhat.com/errata/RHSA-2019:3024>

URL: <https://access.redhat.com/security/cve/CVE-2019-10744>

URL: <https://github.com/advisories/GHSA-jf85-cpcp-j695>

URL: <https://github.com/lodash/lodash/pull/4336>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2019-10744.yml>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2019-10744>

URL: <https://security.netapp.com/advisory/ntap-20191004-0005>

URL: <https://security.netapp.com/advisory/ntap-20191004-0005/>

URL: <https://snyk.io/vuln/SNYK-JS-LODASH-450202>

URL: <https://support.f5.com/csp/article/K47105354>

URL: https://support.f5.com/csp/article/K47105354?utm_source=f5support&utm_medium=RSS

URL: https://www.cve.org/CVERecord?id=CVE-2019-10744

URL: https://www.npmjs.com/advisories/1065

URL: https://www.oracle.com/security-alerts/cpujan2021.html

URL: https://www.oracle.com/security-alerts/cpuoct2020.html

Images

No images found.

Medium

Finding 650 - sanitize-html:1.4.2 | CVE-2019-25225

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	79	[CVE-2019-25225]	4502

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Description

sanitize-html prior to version 2.0.0-beta is vulnerable to Cross-site Scripting (XSS). The sanitizeHtml() function in index.js does not sanitize content when using the custom transformTags option, which is intended to convert attribute values into text. As a result, malicious input can be transformed into executable code.

Mitigation

Upgrade sanitize-html to version 2.0.0-beta

References

URL: https://avd.aquasec.com/nvd/cve-2019-25225

URL: https://access.redhat.com/security/cve/CVE-2019-25225

URL: https://github.com/Checkmarx/Vulnerabilities-Proofs-of-Concept/tree/main/2019/CVE-2019-25225

URL: https://github.com/apostrophecms/sanitize-html

URL: https://github.com/apostrophecms/sanitize-html/commit/712cb6895825c8bb6ede71a16b42bade42abcaf3

URL: https://github.com/apostrophecms/sanitize-html/issues/293

URL: https://github.com/apostrophecms/sanitize-html/pull/156

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-25225

Images

No images found.

Low

Finding 651 - libc6:2.41-12+deb13u2 | CVE-2019-9192

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (2.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2019-9192']	4503

CVSS v3

CVSS:3.0/AV:L/AC:L/PR:L/UI:R/S:U/C:N/I:N/A:L

Description

In the GNU C Library (aka glibc or libc6) through 2.29, check_dst_limits_calc_pos_1 in posix/regexec.c has Uncontrolled Recursion, as demonstrated by '(\\|\\1)*' in grep, a different issue than CVE-2018-20796. NOTE: the software maintainer disputes that this is a vulnerability because the behavior occurs only with a crafted pattern

References

URL: https://avd.aquasec.com/nvd/cve-2019-9192

URL: https://access.redhat.com/security/cve/CVE-2019-9192

URL: https://nvd.nist.gov/vuln/detail/CVE-2019-9192

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=24269

URL: https://support.f5.com/csp/article/K26346590?utm_source=f5support&%3Butm_medium=RSS

URL: https://www.cve.org/CVERecord?id=CVE-2019-9192

Images

No images found.

Critical

Finding 652 - express-jwt:0.1.3 | CVE-2020-15084

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Critical (9.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	285	['CVE-2020-15084']	4504

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration is not being enforced. When algorithms is not specified in the configuration, with the combination of jwks-rsa, it may lead to authorization bypass. You are affected by this vulnerability if all of the following conditions apply: - You are using express-jwt - You do not have **algorithms** configured in your express-jwt configuration. - You are using libraries such as jwks-rsa as the **secret**. You can fix this by specifying **algorithms** in the express-jwt configuration. See linked GHSA for example. This is also fixed in version 6.0.0.

Mitigation

Upgrade express-jwt to version 6.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2020-15084>

URL: <https://github.com/auth0/express-jwt/commit/7ecab5f8f0cab5297c2b863596566eb0c019cdef>

URL: <https://github.com/auth0/express-jwt/security/advisories/GHSA-6g6m-m6h5-w9gf>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2020-15084>

Images

No images found.

Medium

Finding 653 - lodash.set:4.3.2 CVE-2020-8203						
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Medium (7.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	770 ['CVE-2020-8203'] 4505

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:H

Description

Prototype pollution attack when using _.zipObjectDeep in lodash before 4.17.20.

References

URL: <https://avd.aquasec.com/nvd/cve-2020-8203>

URL: <https://access.redhat.com/security/cve/CVE-2020-8203>

URL: <https://github.com/advisories/GHSA-p6mc-m468-83gw>

URL: <https://github.com/github/advisory-database/pull/2884>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/commit/c84fe82760fb2d3e03a63379b297a1cc1a2fce12>

URL: <https://github.com/lodash/lodash/issues/4744>

URL: <https://github.com/lodash/lodash/issues/4874>

URL: <https://github.com/lodash/lodash/wiki/Changelog#v41719>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2020-8203.yml>

URL: <https://hackerone.com/reports/712065>

URL: <https://hackerone.com/reports/864701>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2020-8203>

URL: <https://security.netapp.com/advisory/ntap-20200724-0006>

URL: <https://security.netapp.com/advisory/ntap-20200724-0006/>

URL: <https://web.archive.org/web/20210914001339/https://github.com/lodash/lodash/issues/4744>

URL: <https://www.cve.org/CVERecord?id=CVE-2020-8203>

URL: <https://www.npmjs.com/advisories/1523>

URL: <https://www.oracle.com//security-alerts/cpujul2021.html>

URL: <https://www.oracle.com/security-alerts/cpuApr2021.html>

URL: <https://www.oracle.com/security-alerts/cpuapr2022.html>

URL: <https://www.oracle.com/security-alerts/cpujan2022.html>

URL: <https://www.oracle.com/security-alerts/cpuoct2021.html>

Images

No images found.

Finding 654 - lodash:2.4.2 | CVE-2021-23337

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	94	['CVE-2021-23337']	4506

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Description

Lodash versions prior to 4.17.21 are vulnerable to Command Injection via the template function.

Mitigation

Upgrade lodash to version 4.17.21

References

URL: <https://avd.aquasec.com/nvd/cve-2021-23337>

URL: <https://access.redhat.com/security/cve/CVE-2021-23337>

URL: <https://cert-portal.siemens.com/productcert/pdf/ssa-637483.pdf>

URL: <https://github.com/advisories/GHSA-35jh-r3h4-6jhm>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js#L14851>

URL: <https://github.com/lodash/lodash/blob/ddfd9b11a0126db2302cb70ec9973b66baec0975/lodash.js%23L14851>

URL: <https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b5a91dde28ba4b1c>

URL: <https://github.com/rubysec/ruby-advisory-db/blob/master/gems/lodash-rails/CVE-2021-23337.yml>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-23337>

URL: <https://security.netapp.com/advisory/ntap-20210312-0006>

URL: <https://security.netapp.com/advisory/ntap-20210312-0006/>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLodash-1074931>

URL: <https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929>

URL: <https://snyk.io/vuln/SNYK-JS-LODASH-1040724>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-23337>

URL: <https://www.oracle.com//security-alerts/cpujul2021.html>

URL: <https://www.oracle.com/security-alerts/cpujan2022.html>

Images

No images found.

Finding 655 - notevil:1.3.3 CVE-2021-23771								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2021-23771']	4507

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description

This affects all versions of package notevil; all versions of package argencoders-notevil. It is vulnerable to Sandbox Escape leading to Prototype pollution. The package fails to restrict access to the main context, allowing an attacker to add or modify an object's prototype. **Note:** This vulnerability derives from an incomplete fix in [SNYK-JS-NOTEVIL-608878](#).

References

URL: <https://avd.aquasec.com/nvd/cve-2021-23771>

URL: <https://github.com/mmckegg/notevil>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-23771>

URL: <https://snyk.io/vuln/SNYK-JS-ARGENCODERSNOTEVIL-2388587>

URL: <https://snyk.io/vuln/SNYK-JS-NOTEVIL-2385946>

Images

No images found.

Finding 656 - sanitize-html:1.4.2 CVE-2021-26539								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['CVE-2021-26539']	4508	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Apostrophe Technologies sanitize-html before 2.3.1 does not properly handle internationalized domain name (IDN) which could allow an attacker to bypass hostname whitelist validation set by the "allowedIframeHostnames" option.

Mitigation

Upgrade sanitize-html to version 2.3.1

References

URL: <https://avd.aquasec.com/nvd/cve-2021-26539>

URL: <https://access.redhat.com/security/cve/CVE-2021-26539>

URL: <https://advisory.checkmarx.net/advisory/CX-2021-4308>

URL: <https://github.com/apostrophecms/sanitize-html>

URL: <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#231-2021-01-22>

URL: <https://github.com/apostrophecms/sanitize-html/commit/bdf7836ef8f0e5b21f9a1aab0623ae8fcd09c1da>

URL: <https://github.com/apostrophecms/sanitize-html/pull/458>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-26539>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-26539>

Images

No images found.

Finding 657 - sanitize-html:1.4.2 CVE-2021-26540							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['CVE-2021-26540']	4509

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Apostrophe Technologies sanitize-html before 2.3.2 does not properly validate the hostnames set by the "allowedIframeHostnames" option when the "allowIframeRelativeUrls" is set to true, which allows attackers to bypass hostname whitelist for iframe element, related using an src value that starts with "/\example.com".

Mitigation

Upgrade sanitize-html to version 2.3.2

References

URL: <https://avd.aquasec.com/nvd/cve-2021-26540>

URL: <https://access.redhat.com/security/cve/CVE-2021-26540>

URL: <https://advisory.checkmarx.net/advisory/CX-2021-4309>

URL: <https://github.com/apostrophecms/sanitize-html/blob/main/CHANGELOG.md#232-2021-01-26>

URL: <https://github.com/apostrophecms/sanitize-html/pull/460>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2021-26540>

URL: <https://www.cve.org/CVERecord?id=CVE-2021-26540>

Images

No images found.

Finding 658 - jsonwebtoken:0.1.0 | CVE-2022-23539

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (8.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	327	['CVE-2022-23539']	4510

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23539>

URL: <https://access.redhat.com/security/cve/CVE-2022-23539>

URL: <https://github.com/auth0/node-jwebtoken>

URL: <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3>

URL: <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23539>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23539>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (8.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	327	[CVE-2022-23539]	4511

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description

Versions <=8.5.1 of jsonwebtoken library could be misconfigured so that legacy, insecure key types are used for signature verification. For example, DSA keys could be used with the RS256 algorithm. You are affected if you are using an algorithm and a key type other than a combination listed in the GitHub Security Advisory as unaffected. This issue has been fixed, please update to version 9.0.0. This version validates for asymmetric key type and algorithm combinations. Please refer to the above mentioned algorithm / key type combinations for the valid secure configuration. After updating to version 9.0.0, if you still intend to continue with signing or verifying tokens using invalid key type/algorithm value combinations, you'll need to set the allowInvalidAsymmetricKeyTypes option to true in the sign() and/or verify() functions.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2022-23539

URL: https://access.redhat.com/security/cve/CVE-2022-23539

URL: https://github.com/auth0/node-jwebtoken

URL: https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3

URL: https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-8cf7-32gw-wr33

URL: https://nvd.nist.gov/vuln/detail/CVE-2022-23539

URL: https://security.netapp.com/advisory/ntap-20240621-0007

URL: https://security.netapp.com/advisory/ntap-20240621-0007/

URL: https://www.cve.org/CVERecord?id=CVE-2022-23539

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	[CVE-2022-23540]	4512

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23540>

URL: <https://access.redhat.com/security/cve/CVE-2022-23540>

URL: <https://github.com/auth0/node-jwebtoken>

URL: <https://github.com/auth0/node-jwebtoken/commit/e1fa9dcc12054a8681db4e6373dalb30cf7016e3>

URL: <https://github.com/auth0/node-jwebtoken/security/advisories/GHSA-qwph-4952-7xr6>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23540>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23540>

Images

No images found.

Finding 661 - jsonwebtoken:0.4.0 CVE-2022-23540									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.4)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23540']	4513	

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:H/A:L

Description

In versions <=8.5.1 of jsonwebtoken library, lack of algorithm definition in the jwt.verify() function can lead to signature validation bypass due to defaulting to the none algorithm for signature verification. Users are affected if you do not specify algorithms in the jwt.verify() function. This issue has been fixed, please update to version 9.0.0 which removes the default support for the none algorithm in the jwt.verify() method. There will be no impact, if you update to version 9.0.0 and you don't need to allow for the none algorithm. If you need 'none' algorithm, you have to explicitly specify that in jwt.verify() options.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2022-23540

URL: https://access.redhat.com/security/cve/CVE-2022-23540

URL: https://github.com/auth0/node-jsonwebtoken

URL: https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

URL: https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-qwph-4952-7xr6

URL: https://nvd.nist.gov/vuln/detail/CVE-2022-23540

URL: https://security.netapp.com/advisory/ntap-20240621-0007

URL: https://security.netapp.com/advisory/ntap-20240621-0007/

URL: https://www.cve.org/CVERecord?id=CVE-2022-23540

Images

No images found.

Finding 662 - jsonwebtoken:0.1.0 CVE-2022-23541								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4514

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2022-23541

URL: https://access.redhat.com/security/cve/CVE-2022-23541

URL: https://github.com/auth0/node-jsonwebtoken

URL: https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3

URL: <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>

URL: <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007>

URL: <https://security.netapp.com/advisory/ntap-20240621-0007/>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-23541>

Images

No images found.

Finding 663 - jsonwebtoken:0.4.0 | CVE-2022-23541

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	287	['CVE-2022-23541']	4515

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L

Description

jsonwebtoken is an implementation of JSON Web Tokens. Versions <= 8.5.1 of jsonwebtoken library can be misconfigured so that passing a poorly implemented key retrieval function referring to the secretOrPublicKey argument from the readme link will result in incorrect verification of tokens. There is a possibility of using a different algorithm and key combination in verification, other than the one that was used to sign the tokens. Specifically, tokens signed with an asymmetric public key could be verified with a symmetric HS256 algorithm. This can lead to successful validation of forged tokens. If your application is supporting usage of both symmetric key and asymmetric key in jwt.verify() implementation with the same key retrieval function. This issue has been patched, please update to version 9.0.0.

Mitigation

Upgrade jsonwebtoken to version 9.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2022-23541>

URL: <https://access.redhat.com/security/cve/CVE-2022-23541>

URL: <https://github.com/auth0/node-jsonwebtoken>

URL: <https://github.com/auth0/node-jsonwebtoken/commit/e1fa9dcc12054a8681db4e6373da1b30cf7016e3>

URL: <https://github.com/auth0/node-jsonwebtoken/releases/tag/v9.0.0>

URL: <https://github.com/auth0/node-jsonwebtoken/security/advisories/GHSA-hjrf-2m68-5959>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-23541>

URL: https://security.netapp.com/advisory/ntap-20240621-0007

URL: https://security.netapp.com/advisory/ntap-20240621-0007/

URL: https://www.cve.org/CVERecord?id=CVE-2022-23541

Images

No images found.

Finding 664 - moment:2.0.0 | CVE-2022-24785

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2022-24785']	4516

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

Mitigation

Upgrade moment to version 2.29.2

References

URL: https://avd.aquasec.com/nvd/cve-2022-24785

URL: https://access.redhat.com/security/cve/CVE-2022-24785

URL: https://github.com/moment/moment

URL: https://github.com/moment/moment/commit/4211bfc8f15746be4019bba557e29a7ba83d54c5

URL: https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4

URL: https://lists.debian.org/debian-lts-announce/2023/01/msg00035.html

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q/

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5

URL: https://lists.fedoraproject.org/archives/list/package-announce%40lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5/

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/6QIO6YNLTK2T7SPKDS4JEL45FANLNC2Q

URL: <https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/ORJX2LF6KMPIHP6B2P6KZIVKMLE3LVJ5>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-24785>

URL: <https://security.netapp.com/advisory/ntap-20220513-0006>

URL: <https://security.netapp.com/advisory/ntap-20220513-0006/>

URL: <https://security.netapp.com/advisory/ntap-20241108-0002>

URL: <https://security.netapp.com/advisory/ntap-20241108-0002/>

URL: <https://ubuntu.com/security/notices/USN-5559-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-24785>

URL: <https://www.tenable.com/security/tns-2022-09>

Images

No images found.

Finding 665 - http-cache-semantics:3.8.1 CVE-2022-25881									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25881']	4517	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

This affects versions of the package http-cache-semantics before 4.1.1. The issue can be exploited via malicious request header values sent to a server, when that server reads the cache policy from the request using this library.

Mitigation

Upgrade http-cache-semantics to version 4.1.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-25881>

URL: <https://access.redhat.com/errata/RHSA-2023:2655>

URL: <https://access.redhat.com/security/cve/CVE-2022-25881>

URL: <https://bugzilla.redhat.com/2165824>

URL: <https://bugzilla.redhat.com/2168631>

URL: <https://bugzilla.redhat.com/2171935>

URL: <https://bugzilla.redhat.com/2172190>

URL: <https://bugzilla.redhat.com/2172204>

URL: <https://bugzilla.redhat.com/2172217>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2165824

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2168631

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2171935

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172190

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172204

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2172217

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2178076

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-25881>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-4904>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23918>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23920>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-23936>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-24807>

URL: <https://errata.almaLinux.org/9/ALSA-2023-2655.html>

URL: <https://errata.rockylinux.org/RLSA-2023:2655>

URL: <https://github.com/kornelski/http-cache-semantics>

URL: <https://github.com/kornelski/http-cache-semantics/blob/master/index.js%23L83>

URL: <https://github.com/kornelski/http-cache-semantics/commit/560b2d8ef452bbba20ffed69dc155d63ac757b74>

URL: <https://linux.oracle.com/cve/CVE-2022-25881.html>

URL: <https://linux.oracle.com/errata/ELSA-2023-2655.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-25881>

URL: <https://security.netapp.com/advisory/ntap-20230622-0008>

URL: <https://security.netapp.com/advisory/ntap-20230622-0008/>

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3253332>

URL: <https://security.snyk.io/vuln/SNYK-JS-HTTPCACHESEMANTICS-3248783>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-25881>

Images

No images found.

Low

Finding 666 - sanitize-html:1.4.2 | CVE-2022-25887

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2022-25887']	4518

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The package sanitize-html before 2.7.1 are vulnerable to Regular Expression Denial of Service (ReDoS) due to insecure global regular expression replacement logic of HTML comment removal.

Mitigation

Upgrade sanitize-html to version 2.7.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-25887>

URL: <https://access.redhat.com/security/cve/CVE-2022-25887>

URL: <https://github.com/apostrophecms/sanitize-html/commit/b4682c12fd30e12e82fa2d9b766de91d7d2cd23c>

URL: <https://github.com/apostrophecms/sanitize-html/pull/557>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-25887>

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-3008102>

URL: <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-2957526>

URL: <https://ubuntu.com/security/notices/USN-7464-1>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-25887>

Images

No images found.

Medium

Finding 667 - got:8.3.2 CVE-2022-33987							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	[CVE-2022-33987]	4519

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/IL:A/N

Description

The got package before 12.1.0 (also fixed in 11.8.5) for Node.js allows a redirect to a UNIX socket.

Mitigation

Upgrade got to version 12.1.0, 11.8.5

References

URL: <https://avd.aquasec.com/nvd/cve-2022-33987>

URL: <https://access.redhat.com/errata/RHSA-2022:6595>

URL: <https://access.redhat.com/security/cve/CVE-2022-33987>

URL: <https://bugzilla.redhat.com/1907444>

URL: <https://bugzilla.redhat.com/1945459>

URL: <https://bugzilla.redhat.com/1964461>

URL: <https://bugzilla.redhat.com/2007557>

URL: <https://bugzilla.redhat.com/2098556>

URL: <https://bugzilla.redhat.com/2102001>

URL: <https://bugzilla.redhat.com/2105422>

URL: <https://bugzilla.redhat.com/2105426>

URL: <https://bugzilla.redhat.com/2105428>

URL: <https://bugzilla.redhat.com/2105430>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1907444

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1945459

URL: https://bugzilla.redhat.com/show_bug.cgi?id=1964461

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2007557

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2098556

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2102001

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105422

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105426

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105428

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2105430

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2121019

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2124299

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-28469>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-7788>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-33502>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-3807>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-29244>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32212>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32213>

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32214

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-32215

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-33987

URL: https://errata.almalinux.org/9/ALSA-2022-6595.html

URL: https://errata.rockylinux.org/RLSA-2022:6595

URL: https://github.com/sindresorhus/got

URL: https://github.com/sindresorhus/got/commit/861ccd9ac2237df762a9e2beed7edd88c60782dc

URL: https://github.com/sindresorhus/got/compare/v12.0.3...v12.1.0

URL: https://github.com/sindresorhus/got/pull/2047

URL: https://github.com/sindresorhus/got/releases/tag/v11.8.5

URL: https://github.com/sindresorhus/got/releases/tag/v12.1.0

URL: https://linux.oracle.com/cve/CVE-2022-33987.html

URL: https://linux.oracle.com/errata/ELSA-2022-6595.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2022-33987

URL: https://www.cve.org/CVERecord?id=CVE-2022-33987

Images

No images found.

Finding 668 - engine.io:4.1.2 CVE-2022-41940									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2022-41940']	4520	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Description

Engine.IO is the implementation of transport-based cross-browser/cross-device bi-directional communication layer for Socket.IO. A specially crafted HTTP request can trigger an uncaught exception on the Engine.IO server, thus killing the Node.js process. This impacts all the users of the engine.io package, including those who uses depending packages like socket.io. There is no known workaround except upgrading to a safe version. There are patches for this issue released in versions 3.6.1 and 6.2.1.

Mitigation

Upgrade engine.io to version 3.6.1, 6.2.1

References

URL: <https://avd.aquasec.com/nvd/cve-2022-41940>

URL: <https://access.redhat.com/security/cve/CVE-2022-41940>

URL: <https://github.com/socketio/engine.io>

URL: <https://github.com/socketio/engine.io/commit/425e833ab13373edf1dd5a0706f07100db14e3c6>

URL: <https://github.com/socketio/engine.io/commit/83c4071af871fc188298d7d591e95670bf9f9085>

URL: <https://github.com/socketio/engine.io/security/advisories/GHSA-r7qp-cfhv-p84w>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-41940>

URL: <https://www.cve.org/CVERecord?id=CVE-2022-41940>

Images

No images found.

High

Finding 669 - socket.io-parser:4.0.5 CVE-2023-32695								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2023-32695']	4521

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

socket.io parser is a socket.io encoder and decoder written in JavaScript complying with version 5 of socket.io-protocol. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. A patch has been released in version 4.2.3.

Mitigation

Upgrade socket.io-parser to version 4.2.3, 3.4.3, 3.3.4

References

URL: <https://avd.aquasec.com/nvd/cve-2023-32695>

URL: <https://github.com/socketio/socket.io-parser>

URL: <https://github.com/socketio/socket.io-parser/commit/1c220ddb45ea4b44bc8dbf6f9ae245f672ba1b9>

URL: <https://github.com/socketio/socket.io-parser/commit/2dc3c92622dad113b8676be06f23b1ed46b02ced>

URL: <https://github.com/socketio/socket.io-parser/commit/3b78117bf6ba7e99d7a5cfc1ba54d0477554a7f3>

URL: <https://github.com/socketio/socket.io-parser/commit/ee006607495eca4ec7262ad080dd3a91439a5ba4>

URL: <https://github.com/socketio/socket.io-parser/releases/tag/4.2.3>

URL: <https://github.com/socketio/socket.io-parser/security/advisories/GHSA-cqmj-92xf-r6r9>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2023-32695>

Images

No images found.

Finding 670 - crypto-js:3.3.0 | CVE-2023-46233

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (9.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	328	['CVE-2023-46233']	4522

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

crypto-js is a JavaScript library of crypto standards. Prior to version 4.2.0, crypto-js PBKDF2 is 1,000 times weaker than originally specified in 1993, and at least 1,300,000 times weaker than current industry standard. This is because it both defaults to SHA1, a cryptographic hash algorithm considered insecure since at least 2005, and defaults to one single iteration, a 'strength' or 'difficulty' value specified at 1,000 when specified in 1993. PBKDF2 relies on iteration count as a countermeasure to preimage and collision attacks. If used to protect passwords, the impact is high. If used to generate signatures, the impact is high. Version 4.2.0 contains a patch for this issue. As a workaround, configure crypto-js to use SHA256 with at least 250,000 iterations.

Mitigation

Upgrade crypto-js to version 4.2.0

References

URL: <https://avd.aquasec.com/nvd/cve-2023-46233>

URL: <https://access.redhat.com/security/cve/CVE-2023-46233>

URL: <https://github.com/brix/crypto-js>

URL: <https://github.com/brix/crypto-js/commit/421dd538b2d34e7c24a5b72cc64dc2b9167db40a>

URL: <https://github.com/brix/crypto-js/security/advisories/GHSA-xwcq-pm8m-c4vf>

URL: <https://lists.debian.org/debian-lts-announce/2023/11/msg00025.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2023-46233>

URL: <https://ubuntu.com/security/notices/USN-6753-1>

URL: https://www.cve.org/CVERecord?id=CVE-2023-46233

Images

No images found.

Medium

Finding 671 - sanitize-html:1.4.2 CVE-2024-21501								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	200	['CVE-2024-21501']	4523

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

Versions of the package sanitize-html before 2.12.1 are vulnerable to Information Exposure when used on the backend and with the style attribute allowed, allowing enumeration of files in the system (including project dependencies). An attacker could exploit this vulnerability to gather details about the file system structure and dependencies of the targeted server.

Mitigation

Upgrade sanitize-html to version 2.12.1

References

URL: https://avd.aquasec.com/nvd/cve-2024-21501

URL: https://access.redhat.com/security/cve/CVE-2024-21501

URL: https://gist.github.com/Slonser/8b4d061abe6ee1b2e10c7242987674cf

URL: https://github.com/apostrophecms/apostrophe/discussions/4436

URL: https://github.com/apostrophecms/sanitize-html

URL: https://github.com/apostrophecms/sanitize-html/commit/c5dbdf77fe8b836d3bf4554ea39edb45281ec0b4

URL: https://github.com/apostrophecms/sanitize-html/pull/650

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/4EB5JPYRCTS64EA5AMV3INHDPi6I4AW7/

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S

URL: https://lists.fedoraproject.org/archives/list/package-announce@lists.fedoraproject.org/message/P4I5X6V3LYUNBMZ5YOW4BV427TH3IK4S/

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-21501

URL: <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6276557>

URL: <https://security.snyk.io/vuln/SNYK-JS-SANITIZEHTML-6256334>

URL: <https://www.cve.org/CVERecord?id=CVE-2024-21501>

Images

No images found.

Finding 672 - tar:4.4.19 | CVE-2024-28863

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	400	['CVE-2024-28863']	4524

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

node-tar is a Tar for Node.js. node-tar prior to version 6.2.1 has no limit on the number of sub-folders created in the folder creation process. An attacker who generates a large number of sub-folders can consume memory on the system running node-tar and even crash the Node.js client within few seconds of running it using a path with too many sub-folders inside. Version 6.2.1 fixes this issue by preventing extraction in excessively deep sub-folders.

Mitigation

Upgrade tar to version 6.2.1

References

URL: <https://avd.aquasec.com/nvd/cve-2024-28863>

URL: <https://access.redhat.com/errata/RHSA-2024:6147>

URL: <https://access.redhat.com/security/cve/CVE-2024-28863>

URL: <https://bugzilla.redhat.com/2293200>

URL: <https://bugzilla.redhat.com/2296417>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2293200

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2296417

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-22020>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-28863>

URL: <https://errata.almalinux.org/9/ALSA-2024-6147.html>

URL: https://errata.rockylinux.org/RLSA-2024-6147

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7

URL: https://github.com/isaacs/node-tar/commit/fe8cd57da5686f8695415414bda49206a545f7f7

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-f5x3-32g6-xq36

URL: https://linux.oracle.com/cve/CVE-2024-28863.html

URL: https://linux.oracle.com/errata/ELSA-2024-6148.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-28863

URL: https://security.netapp.com/advisory/ntap-20240524-0005

URL: https://security.netapp.com/advisory/ntap-20240524-0005/

URL: https://www.cve.org/CVERecord?id=CVE-2024-28863

Images

No images found.

Finding 673 - ws:7.4.6 | CVE-2024-37890

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	476	['CVE-2024-37890']	4525

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

ws is an open source WebSocket client and server for Node.js. A request with a number of headers exceeding theserver.maxHeadersCount threshold could be used to crash a ws server. The vulnerability was fixed in ws@8.17.1 (e55e510) and backported to ws@7.5.10 (22c2876), ws@6.2.3 (eeb76d3), and ws@5.2.4 (4abd8f6). In vulnerable versions of ws, the issue can be mitigated in the following ways: 1. Reduce the maximum allowed length of the request headers using the --max-http-header-size=size and/or the maxHeaderSize options so that no more headers than the server.maxHeadersCount limit can be sent. 2. Set server.maxHeadersCount to 0 so that no limit is applied.

Mitigation

Upgrade ws to version 5.2.4, 6.2.3, 7.5.10, 8.17.1

References

URL: https://avd.aquasec.com/nvd/cve-2024-37890

URL: https://access.redhat.com/security/cve/CVE-2024-37890

URL: https://github.com/websockets/ws

URL: https://github.com/websockets/ws/commit/22c28763234aa75a7e1b76f5c01c181260d7917f

URL: https://github.com/websockets/ws/commit/4abd8f6de4b0b65ef80b3ff081989479ed93377e

URL: https://github.com/websockets/ws/commit/e55e5106f10fcbaac37cfa89759e4cc0d073a52c

URL: https://github.com/websockets/ws/commit/eeb76d313e2a00dd5247ca3597bba7877d064a63

URL: https://github.com/websockets/ws/issues/2230

URL: https://github.com/websockets/ws/pull/2231

URL: https://github.com/websockets/ws/security/advisories/GHSA-3h5v-q93c-6h6q

URL: https://nodejs.org/api/http.html#servermaxheaderscount

URL: https://nvd.nist.gov/vuln/detail/CVE-2024-37890

URL: https://www.cve.org/CVERecord?id=CVE-2024-37890

Images

No images found.

High

Finding 674 - socket.io:3.1.2 | CVE-2024-38355

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	[CVE-2024-38355]	4526

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Description

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. A specially crafted Socket.IO packet can trigger an uncaught exception on the Socket.IO server, thus killing the Node.js process. This issue is fixed by commit 15af22fc22 which has been included in socket.io@4.6.2 (released in May 2023). The fix was backported in the 2.x branch as well with commit d30630ba10. Users are advised to upgrade. Users unable to upgrade may attach a listener for the "error" event to catch these errors.

Mitigation

Upgrade socket.io to version 2.5.1, 4.6.2

References

URL: https://avd.aquasec.com/nvd/cve-2024-38355

URL: https://access.redhat.com/security/cve/CVE-2024-38355

URL: <https://github.com/socketio/socket.io>

URL: <https://github.com/socketio/socket.io/commit/15af22fc22bc6030fcead322c106f07640336115>

URL: <https://github.com/socketio/socket.io/commit/d30630ba10562bf987f4d2b42440fc41a828119c>

URL: <https://github.com/socketio/socket.io/security/advisories/GHSA-25hc-qcg6-38wj>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2024-38355>

URL: <https://www.cve.org/CVERecord?id=CVE-2024-38355>

URL: <https://www.vicarius.io/vsociety/posts/unhandled-exception-in-socketio-cve-2024-38355>

Images

No images found.

Low

Finding 675 - cookie:0.4.2 | CVE-2024-47764

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.7)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	74	['CVE-2024-47764']	4527

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

cookie is a basic HTTP cookie parser and serializer for HTTP servers. The cookie name could be used to set other fields of the cookie, resulting in an unexpected cookie value. A similar escape can be used for path and domain, which could be abused to alter other fields of the cookie. Upgrade to 0.7.0, which updates the validation for name, path, and domain.

Mitigation

Upgrade cookie to version 0.7.0

References

URL: <https://avd.aquasec.com/nvd/cve-2024-47764>

URL: <https://access.redhat.com/security/cve/CVE-2024-47764>

URL: <https://github.com/jshttp/cookie>

URL: <https://github.com/jshttp/cookie/commit/e10042845354fea83bd8f34af72475eed1dadf5c>

URL: <https://github.com/jshttp/cookie/pull/167>

URL: <https://github.com/jshttp/cookie/security/advisories/GHSA-pxg6-pf52-xh8x>

Images

No images found.

High

Finding 676 - multer:1.4.5-lts.2 | CVE-2025-47935

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	401	['CVE-2025-47935']	4528

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal busboy stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.0

References

URL: https://avd.aquasec.com/nvd/cve-2025-47935

URL: https://github.com/expressjs/multer

URL: https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665

URL: https://github.com/expressjs/multer/pull/1120

URL: https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5

URL: https://nvd.nist.gov/vuln/detail/CVE-2025-47935

Images

No images found.

Finding 677 - multer:1.4.5-lts.2 | CVE-2025-47944

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-47944']	4529

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.0

References

URL: <https://avd.aquasec.com/nvd/cve-2025-47944>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665>

URL: <https://github.com/expressjs/multer/issues/1176>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-47944>

Images

No images found.

Medium

Finding 678 - multer:1.4.5-lts.2 CVE-2025-48997									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-48997']	4530	

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to 2.0.1 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.1

References

URL: <https://avd.aquasec.com/nvd/cve-2025-48997>

URL: <https://access.redhat.com/security/cve/CVE-2025-48997>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9>

URL: <https://github.com/expressjs/multer/issues/1233>

URL: <https://github.com/expressjs/multer/pull/1256>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qq>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-48997>

URL: <https://www.cve.org/CVERecord?id=CVE-2025-48997>

Images

No images found.

Low

Finding 679 - messageformat:2.3.0 | CVE-2025-57349

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321	['CVE-2025-57349']	4531

Description

The messageformat package, an implementation of the Unicode MessageFormat 2 specification for JavaScript, is vulnerable to prototype pollution due to improper handling of message key paths in versions prior to 2.3.0. The flaw arises when processing nested message keys containing special characters (e.g., **proto**), which can lead to unintended modification of the JavaScript Object prototype. This vulnerability may allow a remote attacker to inject properties into the global object prototype via specially crafted message input, potentially causing denial of service or other undefined behaviors in applications using the affected component.

Mitigation

Upgrade messageformat to version 3.0.0-beta.0

References

URL: <https://avd.aquasec.com/nvd/cve-2025-57349>

URL: <https://github.com/messageformat/messageformat>

URL: <https://github.com/messageformat/messageformat/issues/452>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-57349>

Images

No images found.

High

Finding 680 - jws:0.2.6 | CVE-2025-65945

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	347	['CVE-2025-65945']	4532

CVSS v3

Description

auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the jws.createVerify() function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Mitigation

Upgrade jws to version 3.2.3, 4.0.1

References

URL: <https://avd.aquasec.com/nvd/cve-2025-65945>

URL: <https://access.redhat.com/security/cve/CVE-2025-65945>

URL: <https://github.com/auth0/node-jws>

URL: <https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e>

URL: <https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6>

URL: <https://github.com/auth0/node-jws/releases/tag/v3.2.3>

URL: <https://github.com/auth0/node-jws/releases/tag/v4.0.1>

URL: <https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-65945>

URL: <https://www.cve.org/CVERecord?id=CVE-2025-65945>

Images

No images found.

Medium

Finding 681 - multer:1.4.5-lts.2 | CVE-2025-7338

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	248	['CVE-2025-7338']	4533

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.0.2

References

URL: https://avd.aquasec.com/nvd/cve-2025-7338

URL: https://access.redhat.com/security/cve/CVE-2025-7338

URL: https://cna.openjsf.org/security-advisories.html

URL: https://github.com/expressjs/multer

URL: https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b

URL: https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p

URL: https://nvd.nist.gov/vuln/detail/CVE-2025-7338

URL: https://www.cve.org/CVERecord?id=CVE-2025-7338

Images

No images found.

High

Finding 682 - multer:1.4.5-lts.2 | CVE-2026-2359

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	772	['CVE-2026-2359']	4534

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by dropping connection during file upload, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.0

References

URL: https://avd.aquasec.com/nvd/cve-2026-2359

URL: https://access.redhat.com/security/cve/CVE-2026-2359

URL: https://cna.openjsf.org/security-advisories.html

URL: https://github.com/expressjs/multer

URL: <https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-2359>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-2359>

Images

No images found.

Finding 683 - tar:4.4.19 CVE-2026-23745								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-23745]	4535

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Description

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

Upgrade tar to version 7.5.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23745>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23745>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-23745

URL: https://www.cve.org/CVERecord?id=CVE-2026-23745

Images

No images found.

Finding 684 - tar:6.2.1 | CVE-2026-23745

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-23745']	4536

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Description

node-tar is a Tar for Node.js. The node-tar library (<= 7.5.2) fails to sanitize the linkpath of Link (hardlink) and SymbolicLink entries when preservePaths is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to Arbitrary File Overwrite via hardlinks

and Symlink Poisoning via absolute symlink targets. This vulnerability is fixed in 7.5.3.

Mitigation

Upgrade tar to version 7.5.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23745>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23745>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almalinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-23745>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-23745>

Images

No images found.

Finding 685 - tar:4.4.19 | CVE-2026-23950

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	176	['CVE-2026-23950']	4537

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/SC:C/L:I/H:A/L

Description

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, in which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

Upgrade tar to version 7.5.4

References

URL: <https://avd.aquasec.com/nvd/cve-2026-23950>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-23950>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almalinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-23950>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-23950>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	176	['CVE-2026-23950']	4538

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:L

Description

node-tar,a Tar for Node.js, has a race condition vulnerability in versions up to and including 7.5.3. This is due to an incomplete handling of Unicode path collisions in the path-reservations system. On case-insensitive or normalization-insensitive filesystems (such as macOS APFS, In which it has been tested), the library fails to lock colliding paths (e.g., ß and ss), allowing them to be processed in parallel. This bypasses the library's internal concurrency safeguards and permits Symlink Poisoning attacks via race conditions. The library uses a PathReservations system to ensure that metadata checks and file operations for the same path are serialized. This prevents race conditions where one entry might clobber another concurrently. This is a Race Condition which enables Arbitrary File Overwrite. This vulnerability affects users and systems using node-tar on macOS (APFS/HFS+). Because of using NFD Unicode normalization (in which ß and ss are different), conflicting paths do not have their order properly preserved under filesystems that ignore Unicode normalization (e.g., APFS (in which ß causes an inode collision with ss)). This enables an attacker to circumvent internal parallelization locks (PathReservations) using conflicting filenames within a malicious tar archive. The patch in version 7.5.4 updates path-reservations.js to use a normalization form that matches the target filesystem's behavior (e.g., NFKD), followed by first toLocaleLowerCase('en') and then toLocaleUpperCase('en'). As a workaround, users who cannot upgrade promptly, and who are programmatically using node-tar to extract arbitrary tarball data should filter out all SymbolicLink entries (as npm does) to defend against arbitrary file writes via this file system entry name collision issue.

Mitigation

Upgrade tar to version 7.5.4

References

URL: https://avd.aquasec.com/nvd/cve-2026-23950

URL: https://access.redhat.com/errata/RHSA-2026:18868

URL: https://access.redhat.com/security/cve/CVE-2026-23950

URL: https://bugzilla.redhat.com/2425946

URL: https://bugzilla.redhat.com/2430538

URL: https://bugzilla.redhat.com/2431036

URL: https://bugzilla.redhat.com/2431740

URL: https://bugzilla.redhat.com/2433645

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcb0a0df5954d390521e6

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-23950

URL: https://www.cve.org/CVERecord?id=CVE-2026-23950

Images

No images found.

Finding 687 - tar:4.4.19 | CVE-2026-24842

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-24842']	4539

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Upgrade tar to version 7.5.7

References

URL: https://avd.aquasec.com/nvd/cve-2026-24842

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-24842>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842>

URL: <https://errata.almaLinux.org/9/ALSA-2026-18868.html>

URL: <https://errata.rockylinux.org/RLSA-2026:18868>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-24842>

Images

No images found.

Finding 688 - tar:6.2.1 | CVE-2026-24842

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-24842]	4540

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Description

node-tar,a Tar for Node.js, contains a vulnerability in versions prior to 7.5.7 where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory. Version 7.5.7 contains a fix for the issue.

Mitigation

Upgrade tar to version 7.5.7

References

URL: <https://avd.aquasec.com/nvd/cve-2026-24842>

URL: <https://access.redhat.com/errata/RHSA-2026:18868>

URL: <https://access.redhat.com/security/cve/CVE-2026-24842>

URL: <https://bugzilla.redhat.com/2425946>

URL: <https://bugzilla.redhat.com/2430538>

URL: <https://bugzilla.redhat.com/2431036>

URL: <https://bugzilla.redhat.com/2431740>

URL: <https://bugzilla.redhat.com/2433645>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2425946

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2430538

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431036

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2431740

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2433645

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-13465

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-15284

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23745

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23950

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-24842

URL: https://errata.almalinux.org/9/ALSA-2026-18868.html

URL: https://errata.rockylinux.org/RLSA-2026:18868

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-24842

URL: https://www.cve.org/CVERecord?id=CVE-2026-24842

Images

No images found.

Medium

Finding 689 - tar:4.4.19 | CVE-2026-26960

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (7.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4541

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

Upgrade tar to version 7.5.8

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26960>

URL: <https://access.redhat.com/security/cve/CVE-2026-26960>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>

URL: <https://github.com/isaacs/node-tar/commit/d18e4elf846f4dddc153b0f536a19c050e7499f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 690 - tar:6.2.1 CVE-2026-26960									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (7.1)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-26960']	4542	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. When using default options in versions 7.5.7 and below, an attacker-controlled archive can create a hardlink inside the extraction directory that points to a file outside the extraction root, enabling arbitrary file read and write as the extracting user. Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive. This issue has been fixed in version 7.5.8.

Mitigation

Upgrade tar to version 7.5.8

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26960>

URL: <https://access.redhat.com/security/cve/CVE-2026-26960>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>

URL: <https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-26960>

Images

No images found.

Finding 691 - minimatch:3.0.5 | CVE-2026-26996

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-26996']	4543

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Versions 10.2.0 and below are vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive * wildcards followed by a literal character that doesn't appear in the test string. Each * compiles to a separate [^/]*? regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits. The time complexity is O(4^N) where N is the number of * characters. With N=15, a single minimatch() call takes ~2 seconds. With N=34, it hangs effectively forever. Any application that passes user-controlled strings to minimatch() as the pattern argument is vulnerable to DoS. This issue has been fixed in version 10.2.1.

Mitigation

Upgrade minimatch to version 10.2.1, 9.0.6, 8.0.5, 7.4.7, 6.2.1, 5.1.7, 4.2.4, 3.1.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-26996>

URL: <https://access.redhat.com/errata/RHSA-2026:7896>

URL: <https://access.redhat.com/security/cve/CVE-2026-26996>

URL: <https://bugzilla.redhat.com/2441268>

URL: <https://bugzilla.redhat.com/2442922>

URL: <https://bugzilla.redhat.com/2448754>

URL: <https://bugzilla.redhat.com/2453151>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2441268

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2442922

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2448754

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453151

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904

URL: https://errata.almalinux.org/9/ALSA-2026-7896.html

URL: https://errata.rockylinux.org/RLSA-2026:7896

URL: https://github.com/isaacs/minimatch

URL: https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5

URL: https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26

URL: https://linux.oracle.com/cve/CVE-2026-26996.html

URL: https://linux.oracle.com/errata/ELSA-2026-8339.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-26996

URL: https://www.cve.org/CVERecord?id=CVE-2026-26996

Images

No images found.

Low

Finding 692 - zlib1g:1:1.3.dfsg+really1.3.1-1+b1 | CVE-2026-27171

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (3.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1284	[CVE-2026-27171]	4544

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L

Description

zlib before 1.3.2 allows CPU consumption via crc32_combine64 and crc32_combine_gen64 because x2nmodp can do right shifts within a loop that has no termination condition.

References

URL: https://avd.aquasec.com/nvd/cve-2026-27171

URL: https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit

URL: https://7asecurity.com/blog/2026/02/zlib-7asecurity-audit/

URL: https://7asecurity.com/reports/pentest-report-zlib-RC1.1.pdf

URL: https://access.redhat.com/security/cve/CVE-2026-27171

URL: https://github.com/advisories/GHSA-h858-mf2m-8jf4

URL: https://github.com/madler/zlib/issues/904

URL: https://github.com/madler/zlib/releases/tag/v1.3.2

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-27171

URL: https://ostif.org/zlib-audit-complete

URL: https://ostif.org/zlib-audit-complete/

URL: https://www.cve.org/CVERecord?id=CVE-2026-27171

Images

No images found.

Medium

Finding 693 - minimatch:3.0.5 | CVE-2026-27903

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	407	['CVE-2026-27903']	4545

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3, matchOne() performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ** (GLOBSTAR) segments and the input path does not match. The time complexity is O(C(n, k)) -- binomial -- where n is the number of path segments and k is the number of globstars. With k=11 and n=30, a call to the default minimatch() API stalls for roughly 5 seconds. With k=13, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior. Any application where an attacker can influence the glob pattern passed to minimatch() is vulnerable. The realistic attack surface includes build tools and task runners that accept user-supplied glob arguments (ESLint, Webpack, Rollup config), multi-tenant systems where one tenant configures glob-based rules that run in a shared process, admin or developer interfaces that accept ignore-rule or filter configuration as globs, and CI/CD pipelines that evaluate user-submitted config files containing glob patterns. An attacker who can place a crafted pattern into any of these paths can stall the Node.js event loop for tens of seconds per invocation. The pattern is 56 bytes for a 5-second stall and does not require authentication in contexts where pattern input is part of the feature. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.3 fix the issue.

Mitigation

Upgrade minimatch to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-27903>

URL: <https://access.redhat.com/security/cve/CVE-2026-27903>

URL: <https://github.com/isaacs/minimatch>

URL: <https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>

URL: <https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-27903>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-27903>

Images

No images found.

Finding 694 - minimatch:3.0.5 | CVE-2026-27904

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1333	['CVE-2026-27904']	4546

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Description

minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Prior to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4, nested *() extglobs produce regexps with nested unbounded quantifiers (e.g. (?:a|b)**), which exhibit catastrophic backtracking in V8. With a 12-byte pattern *(?(a|b)) and an 18-byte non-matching input, minimatch() stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default minimatch() API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects +() extglobs equally. Versions 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, and 3.1.4 fix the issue.

Mitigation

Upgrade minimatch to version 10.2.3, 9.0.7, 8.0.6, 7.4.8, 6.2.2, 5.1.8, 4.2.5, 3.1.4

References

URL: <https://avd.aquasec.com/nvd/cve-2026-27904>

URL: <https://access.redhat.com/errata/RHSA-2026:7896>

URL: <https://access.redhat.com/security/cve/CVE-2026-27904>

URL: <https://bugzilla.redhat.com/2441268>

URL: <https://bugzilla.redhat.com/2442922>

URL: https://bugzilla.redhat.com/2448754

URL: https://bugzilla.redhat.com/2453151

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2441268

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2442922

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2448754

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453151

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-21710

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-26996

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27135

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27904

URL: https://errata.almaLinux.org/9/ALSA-2026-7896.html

URL: https://errata.rockylinux.org/RLSA-2026:7896

URL: https://github.com/isaacs/minimatch

URL: https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce

URL: https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74

URL: https://linux.oracle.com/cve/CVE-2026-27904.html

URL: https://linux.oracle.com/errata/ELSA-2026-8339.html

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-27904

URL: https://www.cve.org/CVERecord?id=CVE-2026-27904

Images

No images found.

Finding 695 - lodash:2.4.2 | CVE-2026-2950

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	1321 ['CVE-2026-2950'] 4547

Description

Impact:

Lodash versions 4.17.23 and earlier are vulnerable to prototype pollution in the `.unset` and `.omit` functions. The fix for (CVE-2025-13465: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>) only guards against string key members, so an attacker can bypass the check by passing array-wrapped path segments. This allows deletion of properties from built-in prototypes such as `Object.prototype`, `Number.prototype`, and `String.prototype`.

The issue permits deletion of prototype properties but does not allow overwriting their original behavior.

Patches:

This issue is patched in 4.18.0.

Workarounds:

None. Upgrade to the patched version.

Mitigation

Upgrade lodash to version 4.18.0

References

URL: <https://avd.aquasec.com/nvd/cve-2026-2950>

URL: <https://access.redhat.com/security/cve/CVE-2026-2950>

URL: <https://github.com/lodash/lodash>

URL: <https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh>

URL: <https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-2950>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-2950>

Images

No images found.

High

Finding 696 - tar:4.4.19 | CVE-2026-29786

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.6)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-29786']	4548

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

Upgrade tar to version 7.5.10

References

URL: <https://avd.aquasec.com/nvd/cve-2026-29786>

URL: <https://access.redhat.com/security/cve/CVE-2026-29786>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-29786>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-29786>

Images

No images found.

Finding 697 - tar:6.2.1 CVE-2026-29786								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (8.6)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	[CVE-2026-29786]	4549

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.10, tar can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as C:../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This issue has been patched in version 7.5.10.

Mitigation

Upgrade tar to version 7.5.10

References

URL: <https://avd.aquasec.com/nvd/cve-2026-29786>

URL: <https://access.redhat.com/security/cve/CVE-2026-29786>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-29786>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-29786>

Images

No images found.

Medium

Finding 698 - tar:4.4.19 CVE-2026-31802									
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID	
Medium (6.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4550	

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:../../target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

Upgrade tar to version 7.5.11

References

URL: <https://avd.aquasec.com/nvd/cve-2026-31802>

URL: <https://access.redhat.com/security/cve/CVE-2026-31802>

URL: <https://github.com/isaacs/node-tar>

URL: <https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad>

URL: <https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-31802>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-31802>

Images

No images found.

Finding 699 - tar:6.2.1 | CVE-2026-31802

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.2)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	22	['CVE-2026-31802']	4551

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Description

node-tar is a full-featured Tar for Node.js. Prior to version 7.5.11, tar (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as C:/../././target.txt, which enables file overwrite outside cwd during normal tar.x() extraction. This vulnerability is fixed in 7.5.11.

Mitigation

Upgrade tar to version 7.5.11

References

URL: https://avd.aquasec.com/nvd/cve-2026-31802

URL: https://access.redhat.com/security/cve/CVE-2026-31802

URL: https://github.com/isaacs/node-tar

URL: https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad

URL: https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-31802

URL: https://www.cve.org/CVERecord?id=CVE-2026-31802

Images

No images found.

Finding 700 - file-type:16.5.4 | CVE-2026-31808

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	835	['CVE-2026-31808']	4552

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

file-type detects the file type of a file, stream, or data. Prior to 21.3.1, a denial of service vulnerability exists in the ASF (WMV/WMA) file type detection parser. When parsing a crafted input where an ASF sub-header has a size field of zero, the parser enters an infinite loop. The payload value becomes negative (-24), causing tokenizer.ignore(payload) to move the read position backwards, so the same sub-header is read repeatedly forever. Any application that uses file-type to detect the type of untrusted/attacker-controlled input is affected. An attacker can stall the Node.js event loop with a 55-byte payload. Fixed in version 21.3.1.

Mitigation

References

URL: <https://avd.aquasec.com/nvd/cve-2026-31808>

URL: <https://access.redhat.com/security/cve/CVE-2026-31808>

URL: <https://github.com/sindresorhus/file-type>

URL: <https://github.com/sindresorhus/file-type/commit/319abf871b50ba2fa221b4a7050059f1ae096f4f>

URL: <https://github.com/sindresorhus/file-type/security/advisories/GHSA-5v7r-6r5c-r473>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-31808>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-31808>

Images

No images found.

High

Finding 701 - multer:1.4.5-lts.2 | CVE-2026-3304

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	459	['CVE-2026-3304']	4553

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing resource exhaustion. Users should upgrade to version 2.1.0 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.0

References

URL: <https://avd.aquasec.com/nvd/cve-2026-3304>

URL: <https://access.redhat.com/security/cve/CVE-2026-3304>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-xf7r-hgr6-v32p>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-3304>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-3304>

Images

No images found.

Medium

Finding 702 - socket.io-parser:4.0.5 | CVE-2026-33151

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-33151']	4554

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Socket.IO is an open source, real-time, bidirectional, event-based, communication framework. Prior to versions 3.3.5, 3.4.4, and 4.2.6, a specially crafted Socket.IO packet can make the server wait for a large number of binary attachments and buffer them, which can be exploited to make the server run out of memory. This issue has been patched in versions 3.3.5, 3.4.4, and 4.2.6.

Mitigation

Upgrade socket.io-parser to version 3.3.5, 3.4.4, 4.2.6

References

URL: <https://avd.aquasec.com/nvd/cve-2026-33151>

URL: <https://access.redhat.com/security/cve/CVE-2026-33151>

URL: <https://github.com/socketio/socket.io>

URL: <https://github.com/socketio/socket.io/commit/719f9ebab0772ffb882bd614b387e585c1aa75d4>

URL: <https://github.com/socketio/socket.io/commit/9d39f1f080510f036782f2177fac701cc041faaf>

URL: <https://github.com/socketio/socket.io/commit/b25738c416c4e32fbff62ee182afa8f6d0dacf78>

URL: <https://github.com/socketio/socket.io/security/advisories/GHSA-677m-j7p3-52f9>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-33151>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-33151>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	705	['CVE-2026-3449']	4555

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Versions of the package @tootallnate/once before 3.0.1 are vulnerable to Incorrect Control Flow Scoping in promise resolving when AbortSignal option is used. The Promise remains in a permanently pending state after the signal is aborted, causing any await or .then() usage to hang indefinitely. This can cause a control-flow leak that can lead to stalled requests, blocked workers, or degraded application availability.

Mitigation

Upgrade @tootallnate/once to version 3.0.1, 2.0.1

References

URL: https://avd.aquasec.com/nvd/cve-2026-3449

URL: https://access.redhat.com/security/cve/CVE-2026-3449

URL: https://github.com/TooTallNate/once

URL: https://github.com/TooTallNate/once/commit/b9f43cc5259bee2952d91ad3cdbd201a82df448a

URL: https://github.com/TooTallNate/once/issues/8

URL: https://github.com/TooTallNate/once/releases/tag/v2.0.1

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-3449

URL: https://security.snyk.io/vuln/SNYK-JS-TOOTALLNATEONCE-15250612

URL: https://www.cve.org/CVERecord?id=CVE-2026-3449

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	674	['CVE-2026-3520']	4556

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Description

Multer is a node.js middleware for handling multipart/form-data. A vulnerability in Multer prior to version 2.1.1 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing stack overflow. Users should upgrade to version 2.1.1 to receive a patch. No known workarounds are available.

Mitigation

Upgrade multer to version 2.1.1

References

URL: <https://avd.aquasec.com/nvd/cve-2026-3520>

URL: <https://access.redhat.com/security/cve/CVE-2026-3520>

URL: <https://cna.openjsf.org/security-advisories.html>

URL: <https://github.com/expressjs/multer>

URL: <https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752>

URL: <https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-3520>

URL: <https://www.cve.org/CVERecord?id=CVE-2026-3520>

Images

No images found.

Medium

Finding 705 - libc6:2.41-12+deb13u2 CVE-2026-4046								
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	617	['CVE-2026-4046']	4557

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

The iconv() function in the GNU C Library versions 2.43 and earlier may crash due to an assertion failure when converting inputs from the IBM1390 or IBM1399 character sets, which may be used to remotely crash an application.

This vulnerability can be trivially mitigated by removing the IBM1390 and IBM1399 character sets from systems that do not need them.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-4046>

URL: <https://access.redhat.com/errata/RHSA-2026-20587>

URL: <https://access.redhat.com/security/cve/CVE-2026-4046>

URL: <https://bugzilla.redhat.com/2453117>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438>

URL: <https://errata.almalinux.org/8/ALSA-2026-20587.html>

URL: <https://errata.rockylinux.org/RLSA-2026-20597>

URL: <https://inbox.sourceware.org/libc-announce/76814edf-cf7f-47ec-979d-2dce0a2c76bf@gotplt.org/T/#u>

URL: <https://linux.oracle.com/cve/CVE-2026-4046.html>

URL: <https://linux.oracle.com/errata/ELSA-2026-50291.html>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-4046>

URL: <https://packages.fedoraproject.org/pkgs/glibc/glibc-gconv-extra/>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=33980

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0007;hb=HEAD

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4046>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (4.8)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	787	['CVE-2026-41907']	4558

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

uuid is for the creation of RFC9562 (formerly RFC4122) UUIDs. Prior to 14.0.0, v3, v5, and v6 accept external output buffers but do not reject out-of-range writes (small buf or large offset). This allows silent partial writes into caller-provided buffers. This vulnerability is fixed in 14.0.0.

Mitigation

Upgrade uuid to version 11.1.1, 12.0.1, 13.0.1

References

URL: https://avd.aquasec.com/nvd/cve-2026-41907

URL: https://access.redhat.com/security/cve/CVE-2026-41907

URL: https://github.com/uuidjs/uuid

URL: https://github.com/uuidjs/uuid/commit/32389c887c9e75f90442ee4cc95bbab0c4e8346e

URL: https://github.com/uuidjs/uuid/commit/3d2c5b0342f0fcb52a5ac681c3d47c13e7444b34

URL: https://github.com/uuidjs/uuid/commit/3d61d6ac1f782cf6b1dd8661c60f11722cd49a0d

URL: https://github.com/uuidjs/uuid/commit/9d27ddf7046ce496ef39569ff84d948eeff9cb2a

URL: https://github.com/uuidjs/uuid/releases/tag/v11.1.1

URL: https://github.com/uuidjs/uuid/releases/tag/v12.0.1

URL: https://github.com/uuidjs/uuid/releases/tag/v13.0.1

URL: https://github.com/uuidjs/uuid/releases/tag/v14.0.0

URL: https://github.com/uuidjs/uuid/security/advisories/GHSA-w5hq-g745-h8pq

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-41907

URL: https://www.cve.org/CVERecord?id=CVE-2026-41907

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	125	['CVE-2026-4437']	4559

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Description

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C Library version 2.34 to version 2.43 could, with a crafted response from the configured DNS server, result in a violation of the DNS specification that causes the application to treat a non-answer section of the DNS response as a valid answer.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: https://avd.aquasec.com/nvd/cve-2026-4437

URL: https://access.redhat.com/errata/RHSA-2026:19061

URL: https://access.redhat.com/security/cve/CVE-2026-4437

URL: https://bugzilla.redhat.com/2449777

URL: https://bugzilla.redhat.com/2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437

URL: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438

URL: https://errata.almalinux.org/10/ALSA-2026-19061.html

URL: https://errata.rockylinux.org/RLSA-2026:20597

URL: https://nvd.nist.gov/vuln/detail/CVE-2026-4437

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34014

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4437>

URL: <https://www.openwall.com/lists/oss-security/2026/03/23/2>

Images

No images found.

Low

Finding 708 - libc6:2.41-12+deb13u2 | CVE-2026-4438

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Low (4.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	20	['CVE-2026-4438']	4560

CVSS v3

CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Description

Calling gethostbyaddr or gethostbyaddr_r with a configured nsswitch.conf that specifies the library's DNS backend in the GNU C library version 2.34 to version 2.43 could result in an invalid DNS hostname being returned to the caller in violation of the DNS specification.

Mitigation

Upgrade libc6 to version 2.41-12+deb13u3

References

URL: <https://avd.aquasec.com/nvd/cve-2026-4438>

URL: <https://access.redhat.com/errata/RHSA-2026:19061>

URL: <https://access.redhat.com/security/cve/CVE-2026-4438>

URL: <https://bugzilla.redhat.com/2449777>

URL: <https://bugzilla.redhat.com/2449783>

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449777

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2449783

URL: https://bugzilla.redhat.com/show_bug.cgi?id=2453117

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4046>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4437>

URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-4438>

URL: <https://errata.almalinux.org/10/ALSA-2026-19061.html>

URL: <https://errata.rockylinux.org/RLSA-2026:20597>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-4438>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34015

URL: <https://www.cve.org/CVERecord?id=CVE-2026-4438>

URL: <https://www.openwall.com/lists/oss-security/2026/03/23/2>

Images

No images found.

High

Finding 709 - ws:8.17.1 | CVE-2026-45736

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
High (7.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	908	['CVE-2026-45736']	4561

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Description

ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.

Mitigation

Upgrade ws to version 8.20.1

References

URL: <https://avd.aquasec.com/nvd/cve-2026-45736>

URL: <https://github.com/websockets/ws>

URL: <https://github.com/websockets/ws/commit/c0327ec15a54d701eb6ccefaa8bef328cfc03086>

URL: <https://github.com/websockets/ws/security/advisories/GHSA-58qx-3vcg-4xpx>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-45736>

Images

No images found.

Medium

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (5.9)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	787 ['CVE-2026-5435']	4562

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:H

Description

The deprecated functions ns_printrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to enforce the caller-supplied buffer length, and can result in an out-of-bounds write when printing TSIG records.

References

URL: <https://avd.aquasec.com/nvd/cve-2026-5435>

URL: <https://access.redhat.com/security/cve/CVE-2026-5435>

URL: <https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/>

URL: <https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5435>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34033

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain,f=advisories/GLIBC-SA-2026-0011

URL: <https://www.cve.org/CVERecord?id=CVE-2026-5435>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	122 ['CVE-2026-5450']	4563

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:H

Description

Calling the scanf family of functions with a %mc (malloc'd character match) in the GNU C Library version 2.7 to version 2.43 with a format width specifier with an explicit width greater than 1024 could result in a one byte heap buffer overflow.

References

URL: <https://avd.aquasec.com/nvd/cve-2026-5450>

URL: <https://access.redhat.com/security/cve/CVE-2026-5450>

URL: <https://inbox.sourceware.org/libc-announce/b11f0003-6ec1-4bd6-b9de-9e38a4efeca3@redhat.com/T/#u>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5450>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5450#range-21286997>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=CVE-2026-5450

URL: <https://www.cve.org/CVERecord?id=CVE-2026-5450>

Images

No images found.

Finding 712 - libc6:2.41-12+deb13u2 | CVE-2026-5928

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE	Vulnerability IDs	Dojo ID
Medium (5.0)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	127	['CVE-2026-5928']	4564

CVSS v3

CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:N/A:H

Description

Calling the ungetwc function on a FILE stream with wide characters encoded in a character set that has overlaps between its single byte and multi-byte character encodings, in the GNU C Library version 2.43 or earlier, may result in an attempt to read bytes before an allocated buffer, potentially resulting in unintentional disclosure of neighboring data in the heap, or a program crash.

A bug in the wide character pushback implementation (`_IO_wdefault_pbackfail` in `libio/wgenops.c`) causes `ungetwc()` to operate on the regular character buffer (`fp->_IO_read_ptr`) instead of the actual wide-stream read pointer (`fp->_wide_data->_IO_read_ptr`). The program crash may happen in cases where `fp->_IO_read_ptr` is not initialized and hence points to `NULL`. The buffer under-read requires a special situation where the input character encoding is such that there are overlaps between single byte representations and multibyte representations in that encoding, resulting in spurious matches. The spurious match case is not possible in the standard Unicode character sets.

References

URL: <https://avd.aquasec.com/nvd/cve-2026-5928>

URL: <https://access.redhat.com/security/cve/CVE-2026-5928>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-5928>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=33998

URL: <https://www.cve.org/CVERecord?id=CVE-2026-5928>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (6.5)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	126 ['CVE-2026-6238']	4565

CVSS v3

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:H

Description

The deprecated functions ns_printrrf, ns_printr and fp_nquery in the GNU C Library version 2.2 and newer fail to validate the RDATA content against the RDATA length in a DNS response when processing LOC, CERT, TKEY or TSIG records, which may allow an attacker to craft a DNS response, causing a target application to crash or read uninitialized memory.

These functions are for application debugging only and hence not in the path of code executed by the DNS resolver. Further, they have been deprecated since version 2.34 and should not be used by any new applications. Applications should consider porting away from these interfaces since they may be removed in future versions.

References

URL: <https://avd.aquasec.com/nvd/cve-2026-6238>

URL: <https://access.redhat.com/security/cve/CVE-2026-6238>

URL: <https://inbox.sourceware.org/libc-alpha/cover.1777546194.git.fweimer@redhat.com/>

URL: <https://inbox.sourceware.org/libc-announce/7a655d55-276f-41fe-b550-feb3ebb2ce91@redhat.com/T/#u>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-6238>

URL: https://sourceware.org/bugzilla/show_bug.cgi?id=34069

URL: https://sourceware.org/git/?p=glibc.git;a=blob_plain;f=advisories/GLIBC-SA-2026-0012

URL: <https://www.cve.org/CVERecord?id=CVE-2026-6238>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	CWE Vulnerability IDs	Dojo ID
Medium (5.3)	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	476 ['CVE-2026-8723']	4566

CVSS v3

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Description

Summary

qs.stringify throws TypeError when called with arrayFormat: 'comma' and encodeValuesOnly: true on an array containing null or undefined. The throw is synchronous and not handled by any of qs's null-related options (skipNulls, strictNullHandling).

Details

In the comma + encodeValuesOnly branch, lib/stringify.js:145 mapped the array through the raw encoder before joining:

```
obj = utils.maybeMap(obj, encoder);
```

utils.encode (lib/utils.js:195) reads str.length with no null guard, so a null or undefined element throws TypeError. skipNulls and strictNullHandling are both checked in the per-element loop below this line and never get a chance to run.

Same class of bug as the filter-array path fixed in 0c180a4. The vulnerable shape of the comma + encodeValuesOnly branch was introduced in 4c4b23d ("encode comma values more consistently", PR #463, 2023-01-19), first released in v6.11.1.

PoC

```
const qs = require('qs');
```

```
qs.stringify({ a: [null, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [undefined, 'b'] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
qs.stringify({ a: [null] }, { arrayFormat: 'comma', encodeValuesOnly: true });
```

```
// TypeError: Cannot read properties of null (reading 'length')
```

```
//   at encode (lib/utils.js:195:13)
```

```
//   at Object.maybeMap (lib/utils.js:322:37)
```

```
//   at stringify (lib/stringify.js:145:25)
```

Fix

lib/stringify.js:145, applied in 21f80b3 on main and released as v6.15.2:

```
- obj = utils.maybeMap(obj, encoder);
```

```
+ obj = utils.maybeMap(obj, function (v) {
```

```
+   return v == null ? v : encoder(v);
```

+ });

null and undefined now pass through maybeMap unchanged and reach the join(',') step as-is. For { a: [null, 'b'] } this produces a=,b, matching the non-encodeValuesOnly comma path (which already joins before encoding and produces a=%2Cb for the same input). Single-element [null] arrays still collapse via the existing obj.join(',') || null and remain subject to skipNulls / strictNullHandling in the main loop.

Affected versions

>=6.11.1 <6.15.2 – fixed in v6.15.2.

The vulnerable code shape was introduced in 4c4b23d and first shipped in v6.11.1. Earlier versions – including all of 6.7.x, 6.8.x, 6.9.x, 6.10.x, and 6.11.0 – implemented the comma + encodeValuesOnly path differently (joining before encoding) and are not affected. Empirically verified across released versions.

Impact

Application code that calls qs.stringify with both arrayFormat: 'comma' and encodeValuesOnly: true (both non-default) on input that may contain a null or undefined array element will throw synchronously instead of producing a query string. In a typical Node.js HTTP framework (Express, Fastify, Koa, hapi) the sync throw is caught by the framework's error boundary and the affected request returns a 500; the worker process does not exit and subsequent requests are unaffected. The "kills the worker process" framing applies only to call sites outside a request-handler error boundary (background jobs, startup paths, stream pipelines) or to deployments with framework error handling explicitly disabled.

The vulnerable input is a null or undefined entry inside an array; this is reachable from JSON request bodies or from application code constructing arrays from user input, but not from standard HTML form submissions (which produce strings or omitted fields, not literal null).

Mitigation

Upgrade qs to version 6.15.2

References

URL: <https://avd.aquasec.com/nvd/cve-2026-8723>

URL: <https://github.com/ljharb/qs>

URL: <https://github.com/ljharb/qs/commit/21f80b33e5c8b3f7eba1034fff0da4a4a37a1d41>

URL: <https://github.com/ljharb/qs/security/advisories/GHSA-q8mj-m7cp-5q26>

URL: <https://nvd.nist.gov/vuln/detail/CVE-2026-8723>

Images

No images found.

Critical

Finding 715 - marsdb:0.6.11 | GHSA-5mrr-rgp6-x4gr

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Critical	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['GHSA-5mrr-rgp6-x4gr']	4567

Description

All versions of marsdb are vulnerable to Command Injection. In the DocumentMatcher class, selectors on \$where clauses are passed to a Function constructor unsanitized. This allows attackers to run arbitrary commands in the system when the function is executed.

Recommendation

No fix is currently available. Consider using an alternative package until a fix is made available.

References

URL: <https://github.com/advisories/GHSA-5mrr-rgp6-x4gr>

URL: <https://github.com/bkimminich/juice-shop/issues/1173>

URL: <https://www.npmjs.com/advisories/1122>

Images

No images found.

Medium

Finding 716 - base64url:0.0.6 GHSA-rvg8-pwq2-xj7q							
Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['GHSA-rvg8-pwq2-xj7q']	4568

Description

Versions of base64url before 3.0.0 are vulnerable to to out-of-bounds reads as it allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below.

Recommendation

Update to version 3.0.0 or later.

Mitigation

Upgrade base64url to version 3.0.0

References

URL: <https://github.com/advisories/GHSA-rvg8-pwq2-xj7q>

URL: <https://github.com/brianloveswords/base64url>

URL: <https://github.com/brianloveswords/base64url/commit/4fbd954a0a69e9d898de2146557cc6e893e79542>

URL: <https://github.com/brianloveswords/base64url/pull/25>

URL: <https://hackerone.com/reports/321687>

Images

No images found.

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
Medium	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-154']	4569

Description

Sanitize-html is a library for scrubbing html input of malicious values.

Versions 1.11.1 and below are vulnerable to cross site scripting (XSS) in certain scenarios:

If allowed at least one nonTextTags, the result is a potential XSS vulnerability.

PoC:

```
var sanitizeHtml = require('sanitize-html');

var dirty = '<textarea>&lt;/textarea><svg/onload=prompt`xs`&gt;</textarea>!';
var clean = sanitizeHtml(dirty, {
  allowedTags: [ 'textarea' ]
});

console.log(clean);

// <textarea></textarea><svg/onload=prompt`xs`></textarea>!
```

Mitigation

Upgrade sanitize-html to version >=1.11.4

References

URL: <https://github.com/punkave/sanitize-html/commit/5d205a1005ba0df80e21d8c64a15bb3accdb2403>

URL: <https://github.com/punkave/sanitize-html/issues/100>

Images

No images found.

High

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4570

Description

It is possible for an attacker to bypass verification when "a token digitally signed with an asymeric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

Upgrade jsonwebtoken to version >=4.2.2

References

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Finding 719 - jsonwebtoken:0.4.0 | NSWG-ECO-17

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-17']	4571

Description

It is possible for an attacker to bypass verification when "a token digitally signed with an asymmetric key (RS/ES family) of algorithms but instead the attacker send a token digitally signed with a symmetric algorithm (HS* family)" [1]

Mitigation

Upgrade jsonwebtoken to version >=4.2.2

References

URL: <https://auth0.com/blog/2015/03/31/critical-vulnerabilities-in-json-web-token-libraries/>

URL: <https://github.com/auth0/node-jsonwebtoken/commit/1bb584bc382295eeb7ee8c4452a673a77a68b687>

URL: <https://www.timmclean.net/2015/02/25/jwt-alg-none.html>

Images

No images found.

Finding 720 - base64url:0.0.6 | NSWG-ECO-428

Severity	EPSS Score / Percentile	Status	Date discovered	Age	Reporter	Vulnerability IDs	Dojo ID
High	N.A. / N.A.	Inactive, Duplicate	June 7, 2026	0 days	Admin User (admin)	['NSWG-ECO-428']	4572

Description

base64url allocates uninitialized Buffers when number is passed in input on Node.js 4.x and below

Mitigation

Upgrade base64url to version >=3.0.0

References

URL: <https://hackerone.com/reports/321687>

URL: <https://github.com/brianloveswords/base64url/pull/25>

Images

No images found.